IT 246 — IT Ethics and Cybersecurity

BIM 6th Semester · 3 credits · 48 lecture hours · Complete Course Notes

These are your full course notes for IT 246. Everything taught across all nine units is here, written in plain language with an example attached to almost every idea. You do not need the lecture slides alongside this.

How the notes are written. Each topic starts with a one-line answer, then explains it in simple words, then gives you an example you already know from daily life in Nepal. Exam words (the technical terms your examiner expects) are printed in **bold** the first time, always with a plain-English meaning next to them. Tables are used wherever two things are easy to mix up. Where students commonly get something wrong, there is a ⚠ **Common mistake** line with the correction.

Books the course is based on: Reynolds, *Ethics in Information Technology* (6th ed.) · Tavani, *Ethics and Technology* (5th ed., Wiley 2016) · Quinn, *Ethics for the Information Age* (8th ed., Pearson) · Steinberg, Beaver, Coombs & Winkler, *Cybersecurity All-in-One for Dummies* (Wiley 2023) · Holt, Bossler & Seigfried-Spellar, *Cybercrime and Digital Forensics* (3rd ed., Routledge 2022) · Electronic Transaction Act and Rules, and the IT Policy of Nepal.

Contents

Unit	Title	LH	What it covers
1	An Overview of Ethics	5	Ethics vs morals vs law vs etiquette · the legal/ethical grid · ethics in business · CSR and Carroll's pyramid · stakeholder theory · improving business ethics · the 5-step decision process and four lenses · why IT ethics is different (PAPA)
2	Ethics for IT Workers and IT Users	5	Managing IT worker relationships · professionalism and professional codes · encouraging ethical use of IT resources · privacy and anonymity · social networking ethical issues
3	Intellectual Property	6	Copyright · patent · trade secrets · trademark · plagiarism · reverse engineering · open source · competitive intelligence · trademark infringement · cybersquatting
4	Ethical Decisions in Software Development and Ethics of IT Organizations	5	Software quality and why it matters · strategies for quality software · contingent workers · outsourcing · whistle-blowing · green computing
5	Fundamentals of Cybersecurity	6	Cyberspace and cybersecurity · perspectives · technological change, economic model shifts and outsourcing · risks cybersecurity mitigates · common cyberattacks · poisoned web services · network infrastructure poisoning · technical attack techniques · attackers and their coloured hats
6	Personal Cybersecurity	5	Evaluating your cybersecurity posture · home computer, mobile and IoT devices · physical security · working from home · securing accounts · passwords
7	Social Engineering and Cyber Terrorism	5	Why social engineering works · building trust and exploiting relationships · performing attacks · countermeasures and prevention · cyber terrorism, its types, effects on infrastructure and how to counter it
8	Digital Forensics	7	Computer to digital forensics · stages · digital evidence · methods and the lab · collecting, seizing and protecting evidence · recovering data · mobile forensics · legal aspects · cyber forensics in Nepal
9	Cyber Law in the Context of Nepal	4	Legal perspective of cybercrime · Electronic Transaction Act · Electronic Transaction Rules · IT Policy · information security and policies
—	Quick Revision	—	Every table, list, framework, Nepal fact and keyword in one place

Unit 1 — An Overview of Ethics

5 lecture hours. Ethics · ethics in the business world · corporate social responsibility · fostering CSR and good business ethics · improving business ethics · ethical considerations in decision making · ethics in information technology.

1.1 Four words people mix up

Most people use *ethics*, *morals*, *law* and *etiquette* as if they mean the same thing. A professional should not. Here is the difference, and it matters for the rest of the course.

- **Ethics** is a code of right and wrong belonging to a **group, profession or society**. It is *shared*. That is why your college can have a code of conduct, the ACM can have a different one, and Nepali society can have its own norms — all at the same time.
- **Morals** are an **individual's personal** beliefs about right and wrong, usually from family, religion or upbringing. Two equally ethical professionals can hold different personal morals.
- **Law** is the set of rules the **state enforces**, with real penalties. It is written down and backed by force — but it changes slowly and cannot cover every situation.
- **Etiquette** is **social manners**. Breaking it is rude, not wrong in a deep sense.

> **The relationship in one line:** law is what you *must* do · ethics is what you *should* do · morals are what *you personally* believe · etiquette is what is *polite*. They usually overlap — but the cases that matter are the ones where they **pull apart**.

Concept	Meaning	Who decides	If broken	Example
Ethics	Shared standards of right and wrong for a group or profession	Professional bodies, organisations, society	Loss of trust, disciplinary action, suspension, lost reputation	A doctor shares a patient's records → disciplinary action, possible loss of licence
Morals	An individual's personal beliefs about right and wrong	The individual	Personal guilt, a troubled conscience	Returning a lost wallet because keeping it feels wrong, even though nobody would know
Law	Official rules created and enforced by government	Legislature and courts	Fines, imprisonment, legal penalties	Driving under the influence → arrest, fine, licence suspension
Etiquette	Social rules of politeness and good manners	Society and culture	Seen as rude; normally no legal or professional penalty	Using your phone during a formal meeting

The same act can sit in several columns at once. Paying a bribe (*ghus*) is **illegal and unethical**. Jumping a government-office queue using *source-force* is **unethical but legal**. Eating with your left hand at a feast is **only** an etiquette breach. Exploiting a tax loophole is perfectly **legal yet widely judged unethical**.

> ⚠ **Common mistake:** "*If it's legal, it's ethical.*" **Correction:** the law is the **floor, not the ceiling**. It is the *minimum* society will tolerate, not the *maximum* you should aim for. History is full of things that were legal and deeply wrong — so "it's legal" can never end an ethical conversation.

A one-line recall table:

Concept	The question it answers
Ethics	Is this professionally acceptable?
Morals	Does this align with my own values?
Law	Is this legal?
Etiquette	Is this good manners?

1.2 The legal/ethical grid

Draw two axes — *legal* ↔ *illegal* and *ethical* ↔ *unethical* — and you get four boxes. This is the most useful single tool in Unit 1.

Quadrant	What it contains	Examples
Legal + Ethical	The easy quadrant	Paying your taxes honestly; keeping a promise to a customer
Legal + Unethical	**The danger zone**	Exploiting a tax loophole; jumping a queue with connections; selling legally collected customer data without consent
Illegal + Ethical	Rare and debated	Justified civil disobedience; a whistle-blower breaking an NDA to expose fraud
Illegal + Unethical	The obvious-wrong quadrant	Paying a bribe; leaking someone's private data

Real cases placed on the grid:

Instance	Legal?	Ethical?	Quadrant
Paying *chiya kharcha* to push your file up the pile	No	No	Illegal + Unethical
Sharing one paid Netflix or Canva login among 8 friends	Grey — a contract breach	No	Legal-ish + Unethical
Using *source-force* to skip a government queue	Yes	No	Legal + Unethical
Selling legally collected customer data without consent	Yes	No	Legal + Unethical
Paying your taxes honestly and on time	Yes	Yes	Legal + Ethical
Whistle-blowing on employer fraud, breaking an NDA	No — a breach	Yes (debated)	Illegal + Ethical
A student pirating software they cannot afford	No	Debated	Illegal + arguably Ethical
Leaking a customer's private photos from a database	No	No	Illegal + Unethical

> **Why this matters for your career.** Most business and IT scandals live in **legal but unethical** — technically allowed, clearly wrong. Nothing external stops you there. Only your own judgement does.

1.3 Ethics in the business world

Business ethics means applying ethical standards to commercial conduct and decisions.

Why business needs its own ethics. A business serves **several stakeholders at once**, and their interests **conflict**. What maximises this quarter's profit can harm customers or staff. Business ethics is fundamentally about managing that conflict, and the central tension is always **short-term profit against long-term trust**.

Stakeholder	What they want from the business
Customers	Quality products, fair prices, safety, honesty
Employees	Fair wages, safe conditions, respect
Owners / shareholders	Profit, growth, return on investment
Suppliers	Fair contracts and timely payment
Government	Compliance with law, payment of taxes
Society and community	Environmental responsibility, ethical behaviour, contribution

Why trust is the real asset. A customer cannot verify most of what a business tells them. Does this medicine work? Is this really organic? Is my data safe? Business therefore runs on **trust**, and trust is **slow to build and instant to lose**. Every unethical shortcut spends down a reserve that took years to fill.

> **Shop A and Shop B.** During a festival shortage, Shop A triples its prices and Shop B holds them. Shop A wins today. But customers remember who exploited them, and Shop B's queue is longer every Dashain afterwards. *Good ethics is usually good business — just on a longer clock.*

Business scenario	Short-term profit move	Long-term cost	Verdict
Festival shop triples oil and sugar prices in a shortage	One fat margin	Customers desert it every Dashain after	Trust lost
Trekking agency hides a route safety risk to keep a booking	Keeps one deposit	Client harmed, lawsuits, and future tourists scared off	The whole sector loses
A wallet firm quietly reuses user data for advertising	Extra ad revenue	Users switch wallets once they find out	Trust lost
A Daraz seller ships a counterfeit as genuine	One quick sale	Bad reviews, returns, delisting	Reputation crash
A bank buries fees in the fine print	More fee income now	Complaints, NRB scrutiny, customers leaving	Trust lost
A college promises placements it cannot deliver	Higher admissions this year	Angry students, falling reputation	Enrolment falls
A momo restaurant reuses stale ingredients	Saves on stock	One food-poisoning post ends it	Business closes

And ethics pays in concrete ways:

Ethical practice	Business benefit
Honest advertising	Builds customer confidence
Fair pricing	Encourages loyalty
Paying employees fairly	Improves motivation and retention
Protecting customer data	Strengthens trust
Selling safe, quality products	Improves reputation
Environmental responsibility	Supports sustainable growth
Transparent communication	Fewer disputes, more credibility

1.4 Why good people and good businesses still go wrong

Students assume unethical behaviour comes from "bad people". Mostly it comes from **ordinary people under predictable pressure**.

Pressure	What it is	How it sounds
Results pressure	Hit the target or you are out	"The target crowds out the ethics"
Normalization	Everyone does it, so it stops feeling wrong	"Everyone in this office rounds the numbers"
Weak oversight	Nobody is watching or accountable	"No one audits this desk"
Diffusion of responsibility	The decision belonged to someone else	"I just followed the process / my manager decided"

Scenario	Pressure at work
A junior accountant rounds up numbers because everyone here does	Normalization
A sales rep oversells a policy to hit target or lose the job	Results pressure
A clerk approves a shortcut because nobody audits that desk	Weak oversight
A staffer follows a manager's "just do it" on a dodgy file	Diffusion of responsibility
An IT admin skips a security patch because the team never bothers	Normalization
A bank teller waives KYC for a VIP under branch-target pressure	Results pressure + weak oversight
A team member stays silent though the plan clearly feels wrong	Groupthink / diffusion

Why this is good news: if bad behaviour is *situational*, then **good systems and culture prevent it**. You do not just hire good people; you build conditions where good behaviour is the easy default.

> **The brakes analogy.** People think ethics is the brakes that slow a business down. Wrong. Brakes are exactly what let a car drive **fast safely** — take the brakes off and you cannot speed, you can only crash. A business with strong ethics can move aggressively *because* it will not destroy its own reputation doing so.

1.5 Corporate Social Responsibility (CSR)

Definition: CSR is a company's **duty to act for the benefit of society**, not only its shareholders. The crucial word is *duty* — the claim that a business **owes** something to the society that lets it operate, using its infrastructure, workers, resources and trust.

This replaced the older view that the only job of business is to make a profit. The modern consensus is profit **and** responsibility.

Carroll's CSR pyramid

Four levels, built from the bottom up. **Order matters** — the lower layers must hold before the upper ones mean anything.

Level	What it means	Example	Nepal context
Economic (base)	Be profitable and viable	Earn enough to pay staff and reinvest	A bank must be solvent before it can fund anything
Legal	Obey all laws and regulations	Follow labour, tax and environmental law	Comply with Nepal Rastra Bank and government rules
Ethical	Do what is right beyond the law	Fair wages, honest marketing, safe products	Not exploiting a legal loophole that harms customers
Philanthropic (top)	Give back to the community	Donations, scholarships, relief, tree planting	Telecom rural-coverage and education programmes

The Nepal point worth remembering: Nepal Rastra Bank directs commercial banks to allocate a portion of profit to CSR. So in Nepal, part of CSR is not optional charity — it is **built into how the banking sector is regulated**.

Real activity	Carroll level	Why
A commercial bank staying solvent and profitable	Economic	Survival funds everything above it
A bank allocating a share of profit to CSR as NRB directs	Legal	A regulatory requirement, not charity
A firm paying all taxes and following labour law	Legal	Society's codified minimum
A company paying fair wages and advertising honestly	Ethical	Right beyond what the law forces
A telecom not exploiting a billing loophole that overcharges	Ethical	Above the legal floor
Ncell or NTC extending coverage to remote villages	Philanthropic	Serves society beyond pure profit
A bank funding scholarships and flood relief	Philanthropic	Giving back to the community

> ⚠ **Common mistake:** "*CSR is just charity or a PR stunt.*" **Correction:** real CSR is **responsibility embedded in operations** — fair wages, clean production, honest marketing, safe products. Donations are only the visible tip. A company that donates to charity while underpaying staff is doing CSR **backwards** — buying image without the foundation.

Stakeholder theory

The question: to whom does a company answer? **The narrow answer:** shareholders, the owners. **Stakeholder theory widens it:** a business answers to **everyone materially affected by it** — customers, employees, suppliers, the community, the environment, government *and* owners.

The practical consequence: under a stakeholder view, a decision that is great for owners but harmful to the community is a **failure**, not a success.

Business decision	Shareholder lens	Stakeholder lens	The hidden cost
A factory is profitable but pollutes a village's drinking water	Success — profits up	Failure — the village is harmed	Health costs, lawsuits, lost licence to operate
A wallet firm sells user location data to advertisers	Revenue up	Privacy violated	Customers leave, regulator acts
A garment exporter underpays workers to win a contract	Lower cost, more orders	Workers exploited	Strikes, boycotts, reputation damage
A bank pushes loans farmers cannot repay	Loan book grows	Farmers trapped in debt	Defaults, social backlash
A college over-enrols far beyond capacity	More fee income	Students get poor teaching	Falling reputation, dropouts
A hydropower project skips community consultation	Faster build	Locals displaced and angry	Protests, delays, lawsuits

> **The line to remember:** the costs pushed onto non-owner stakeholders are **hidden, not absent**. They come back as lawsuits, boycotts or a lost social licence to operate. *Ethics fails when we count only the stakeholders who appear on the balance sheet.*

Fostering CSR and an ethical culture

Good ethics is **built**, not wished for. Four levers:

- **Tone from the top** — staff copy what leaders *do*, not what posters *say*. If the CEO cuts a corner, everyone learns that corners are fine.
- **A clear, public code of ethics** — turns vague values into specific expectations.
- **An ethical culture** — where raising a concern is rewarded rather than punished, and doing the right thing is the path of least resistance.
- **Social-responsibility reporting** — publishing your impact creates accountability you cannot quietly walk back.

Genuine CSR or greenwashing?

Greenwashing means advertising responsibility you do not actually practise. **The one-line test: does the company's everyday operation match its CSR message, or does the advertisement contradict the behaviour?**

CSR claim or activity	Does daily operation match?	Verdict
A bank advertises "we care about farmers" while its loan terms crush them	No	Greenwashing
A firm plants trees for a photo opportunity but pollutes a river daily	No	Greenwashing
"Eco-friendly" labels added with no change to the packaging	No	Greenwashing
A one-off Dashain donation heavily used in ads by a low-wage employer	No	Greenwashing
A firm with years of fair wages runs a modest "we treat staff well" campaign	Yes	Genuine CSR
A telecom runs real rural-coverage and digital-literacy programmes	Yes	Genuine CSR
A bank publishes an audited social-responsibility report matching practice	Yes	Genuine CSR

> **The advertisement is never the evidence. The operation is.**

1.6 Improving business ethics

> **The puzzle to start with:** a company hires consultants, writes an inspiring Code of Ethics, prints it on glossy paper, frames it in reception — and behaves exactly as before. Why did the document change nothing?

Because a value written down is not a value practised. Ethics needs **systems, not posters**.

An **ethics program** is the set of systems that turn stated values into actual behaviour. Take two companies with the *identical* code: in one, leaders visibly follow it and violations have consequences; in the other, leaders quietly break it. **Same**

document, opposite cultures. The document was never the cause.

Aspect	Company A — values practised	Company B — values on the wall
The code	Specific and enforced	Glossy but ignored
Leaders	Visibly follow it	Quietly break it
Violations	Have real consequences	Overlooked, especially at the top
Reporting a concern	Safe and rewarded	Risky, so you stay quiet
Result	Ethical behaviour is the default	The code is decoration

The code says	What actually happens	What staff learn
"Zero tolerance for bribery"	A manager who takes a kickback is dismissed	The rules are real
"Zero tolerance for bribery"	A senior person is quietly excused	The code is theatre
"Report concerns safely"	A whistle-blower is thanked and protected	Speaking up is safe
"Report concerns safely"	The reporter is sidelined and punished	Stay quiet
"We respect data privacy"	Staff who peek at accounts are disciplined	Privacy is enforced
"Deadlines never justify cutting corners"	A rushed, unsafe release is rolled back	Quality genuinely matters
"Deadlines never justify cutting corners"	Corners are cut to ship on time, and praised	The code does not apply under pressure

The components of an effective ethics program

The cycle: **Code → Training → Reporting → Audit → Consequences → back to Code.**

Component	What it does	Nepal example
Ethics officer or committee with real authority	Gives ethics a genuine owner, not a side duty everyone ignores	A compliance officer at a commercial bank
Board-level oversight	Reports ethics to the top so it cannot be buried by middle management	Board audit or compliance committee
A specific code of conduct	Turns "be good" into concrete rules	"No gifts over Rs X; do not install unlicensed software; report conflicts of interest"
Ongoing training	Keeps the rules alive with real scenarios, not a one-time slideshow	AML (anti-money-laundering) staff training
Safe reporting channels	Lets staff report **anonymously and without retaliation** — otherwise nobody uses them	A whistle-blower or grievance hotline
Periodic ethics audits	Checks the rules are actually followed, not just posted	Internal compliance audit

Nepali banks are **regulated** to have AML training and a grievance hotline — this is the concrete machinery that turns "we value integrity" into daily practice.

> ⚠ **Common mistake:** "*Having a code of conduct guarantees ethical behaviour.*" **Correction:** enforcement and culture matter far more than the document. **An unenforced code can be worse than none** — it signals that the rules are for show, which teaches everyone to ignore them.

Measuring and sustaining ethics

A program is not set-and-forget. Maintain it with **ethics audits**, **anonymous culture surveys**, **consistent consequences at every level**, and by **tracking reported concerns and acting on them** so that reporting feels worthwhile.

The make-or-break factor is consistency. The fastest way to destroy an ethics program is to punish violations *selectively*.

Situation	How it was handled	What everyone learned
A senior and a junior both take a kickback	Both dismissed	The rules apply to everyone
The senior is excused, the junior fired for the same breach	Selective	The code is power-dependent

Situation	How it was handled	What everyone learned
A culture survey flags a bullying manager	Acted on quickly	Reporting is worthwhile
Reported concerns are collected but never acted on	Ignored	Reporting is pointless, so people stop
An ethics audit finds a compliance gap	Fixed before it became a scandal	Audits protect the firm
A branch skips the mandated AML training	Overlooked, no consequence	Rules are optional here
A director's conflict of interest is disclosed	Managed openly	Ethics applies at the top too

> **Selective punishment destroys trust faster than having no code at all**, because the hypocrisy is visible to everyone watching.

1.7 Ethical decision making

> **The dilemma to hold in mind:** the night before an exam, a classmate accidentally shares a Drive folder — and inside are tomorrow's answers. The question is not "what is right?" but **"how would you even decide?"**

The 5-step process

This is the spine of the whole course. You will reuse it in intellectual property, security, forensics and cyber law.

Step	What it involves	On the leaked-answers dilemma
1. Get the facts	Most dilemmas dissolve once you have the facts. Never reason on assumptions	Are these really tomorrow's answers? How did I get them?
2. Identify stakeholders and options	Who is affected, and what are your *realistic* options — not just two extremes	You, honest classmates, the teacher, the institution
3. Evaluate the options	Test them through the four ethical lenses	Fairness: using them cheats honest students
4. Choose and act	Decide, and own it	Report the leak, or delete it without looking
5. Reflect	What was the outcome, and what would you do differently? This is how judgement improves	What pressure made it tempting?

> **Steps 1 and 2 are the ones people skip — and that is where most bad decisions are born.**

Dilemma	First fact to establish	Key stakeholders	Defensible action
A classmate shares a Drive with tomorrow's exam answers	Are these really the exam?	Honest students, teacher, institution	Report, or delete without looking
A vendor offers your procurement officer a "gift" before a tender	Gift or bribe? What is the policy limit?	Other bidders, employer, the public	Decline and disclose
Your boss asks you to backdate an invoice	Is this legal? Why is it needed?	Auditors, tax office, the firm	Refuse and escalate
User data was leaked from your app	What leaked, to whom, when?	Affected users, the regulator	Contain, disclose, notify
A friend asks you to share paid software licence keys	Is the licence transferable?	The vendor, your employer	Decline; suggest a legal option
You spot a bug that overcharges some customers	How many are affected, and by how much?	Overcharged customers, the firm	Report and refund

The four ethical lenses

Four different ways to test an option. Each has a one-line test question.

Lens	Its test question	Verdict on an ambulance asking to jump a fuel queue
Utilitarian	Which option does the most good for the most people?	Let it pass — a life outweighs everyone's wait
Rights / duty (deontology)	Does this respect basic rights and duties, *regardless* of the outcome?	The patient's right to life takes priority
Fairness / justice	Am I treating similar cases alike? Is this fair?	A medical emergency is genuinely a different case, so it is not unfair
Virtue / common good	What would a person of good character do? What serves the community?	A decent person waves them through

All four converge on the ambulance — which is exactly *why* it feels obviously right. **The hard cases are the ones where the lenses disagree, and naming the disagreement is half the work.**

Situation	Lens that fits best	What it decides
Ambulance jumps the fuel queue in a shortage	All four converge	Let it pass
Lay off 10 staff to save 200 jobs	Utilitarian	Greatest good for the greatest number
Read a subordinate's private chats "for the company"	Rights / duty	No — it violates their privacy
Pay two equally qualified interns the same	Fairness / justice	Treat like cases alike
Report a friend who is stealing from the till	Virtue / common good	What a person of good character does
Promote strictly on merit, not on *source-force*	Fairness / justice	Fair to all candidates
Use user data profitably in a way most users would object to	Rights/duty vs utilitarian	**They disagree** — name it and decide on the merits

> ⚠ **Common mistake:** "*Ethics is just personal opinion — anything goes.*" **Correction:** structured reasoning gives **defensible, comparable** answers. Two people using the lenses can still disagree — but they can explain and compare their reasoning. That is the opposite of "just opinion".

The four decision traps

Trap	How it sounds in real life	How to counter it
Rationalization	"It's not really cheating — everyone uses these notes"	Name the act plainly. Would you defend it openly?
Groupthink	"The whole team agreed, so it must be fine"	Ask for one dissenting view; decide on the merits
Slippery slope	"Just this once, it won't happen again"	Set the bright line *before* the pressure, not during
Blind obedience	"My manager told me to, so it's on them"	It is not. You remain responsible — run the 5 steps

> **Watch for traps arriving in pairs.** "Just fudge this one report, only this once" uses **blind obedience plus slippery slope** at the same time. Naming the trap out loud strips half its power.

1.8 Ethics in information technology

> **The framing line:** a dishonest shopkeeper cheats one customer at a time. A bad line of code or a bad data policy can harm **millions in seconds** — and the harm can be **permanent**.

Why IT ethics is different

Factor	Offline	At IT scale	The consequence
Scale	One person at a time	Millions at once, from one setting or algorithm	A single choice harms a whole population

Factor	Offline	At IT scale	The consequence
Speed	Slow to spread	Seconds	The harm is done before anyone can react
Anonymity	The wrongdoer is visible	They can hide, and act across borders	Hard to catch or hold accountable
Permanence	A rumour in a village fades	A screenshot online is forever	Leaked data can never be fully erased
Capability–regulation gap	The law usually exists	Technology outruns the law	"Is it legal?" often has no answer yet

IT incident	Amplifying factor
Personal data leaked from a Nepali online service	Permanence + speed
A default privacy setting exposes millions of accounts	Scale
A viral election deepfake the night before voting	Speed
An anonymous account harasses a victim across borders	Anonymity
A loan algorithm rejects an entire neighbourhood (digital redlining)	Scale
A leaked private photo re-shared across many groups	Permanence
A new AI tool with no law yet governing its use	Capability–regulation gap

Why this connects back to 1.1: because the legal "floor" is often **missing entirely** in IT, your own ethics is frequently the only thing holding.

PAPA — the four pillars of IT ethics

PAPA = Privacy · Accuracy · Property · Access. This single framework is a map of the entire IT 246 course.

Pillar	The question it raises	Example	Where in this course
Privacy	Who can collect and see your data?	An app sells your location data	Unit 2 (privacy), Unit 9 (law)
Accuracy	Who is responsible when data or an algorithm is **wrong** and someone is harmed?	A biased loan algorithm wrongly rejects you	Unit 1; the cybersecurity units
Property	Who **owns** information and software?	Pirating software; copying a code repository	Unit 3 (intellectual property)
Access	Who **gets to use** technology, and who is left out?	The rural digital divide	Course-wide; policy

Security threads through all four pillars — that is Units 5 to 8.

Real concern	PAPA pillar
An app sells your location data to advertisers	Privacy
A wallet reuses your transaction history without consent	Privacy
A biased loan algorithm wrongly rejects you	Accuracy
Wrong information on a government portal blocks your service	Accuracy
Pirating Windows or Adobe; copying a code repository	Property
Villages with no internet miss e-services like the Nagarik App	Access
Only smartphone owners can use a digital-ID system	Access

> ⚠ **Common mistake:** "*It's just technology — the tool is neutral.*" **Correction: technology is not value-neutral.** *What* you choose to build, *what* data you collect and *how* an algorithm decides all encode human values — and human bias. A hiring algorithm trained on biased data will discriminate automatically, at scale.

"Can" versus "should"

The defining question of IT ethics: just because you **can** build or do something, does that mean you **should**?

This lands on you personally. As a BIM graduate you will be the one choosing what data to collect, how an algorithm treats people, what to log and what to expose. Professional codes — **ACM** and **IEEE** — exist precisely to put your **duty to users and the public** above an employer's short-term convenience.

You can…	Should you?	The ethical catch
Scrape 100,000 users' public posts for a project	Usually no	"Public" is not consent to **this** use
Log every keystroke of staff "for productivity"	No	Violates reasonable privacy
Sell "anonymised" data that can be re-identified	No	"Anonymised" often is not
Build a face-recognition tool from public photos	Rarely	People did not consent to be identified
Read user DMs because you have admin access	No	**Access is not permission**
A/B test a dark pattern that tricks users into paying	No	Deception harms the user
Deploy an untested medical-advice chatbot because it "works"	No	Accuracy failures can harm people

Key words from Unit 1

Ethics · morals · law · etiquette · legal/ethical grid · legal-but-unethical quadrant · business ethics · stakeholder · short-term profit vs long-term trust · results pressure · normalization · weak oversight · diffusion of responsibility · CSR · Carroll's pyramid (economic, legal, ethical, philanthropic) · stakeholder theory · greenwashing · tone at the top · ethics program · code of conduct · whistle-blower hotline · ethics audit · consistent enforcement · 5-step decision process · utilitarian · rights/duty (deontology) · fairness/justice · virtue/common good · rationalization · groupthink · slippery slope · blind obedience · scale, speed, anonymity, permanence · capability–regulation gap · PAPA (Privacy, Accuracy, Property, Access) · digital redlining · value-laden technology · can vs should · ACM and IEEE codes.

Summary — Unit 1

- **Ethics** is a group's shared code; **morals** are personal; **law** is state-enforced; **etiquette** is manners. **Law is the floor, not the ceiling.**
- The **legal/ethical grid** has four quadrants, and the dangerous one is **legal but unethical** — where most real scandals live, because nothing external stops you.
- **Business ethics** manages conflict between stakeholders, trading short-term profit against long-term trust. Misbehaviour is usually **situational**, so systems and culture are the fix.
- **CSR** is a duty to society. Carroll's pyramid runs **economic → legal → ethical → philanthropic**, and in Nepal NRB makes part of bank CSR a regulatory requirement. Test claims for **greenwashing** by asking whether daily operations match the message.
- **Stakeholder theory** says a business answers to everyone it affects; costs pushed onto non-owners are hidden, not absent.
- Ethics programs need **leadership, a specific code, training, safe reporting and audits** — and above all **consistent enforcement**. An unenforced code is worse than none.
- Decide using the **5 steps** (facts → stakeholders/options → evaluate → act → reflect) and the **four lenses** (utilitarian, rights/duty, fairness, virtue), while watching for the **four traps**.
- IT amplifies ethical impact through **scale, speed, anonymity and permanence**, and often outruns the law. Its four pillars are **PAPA**, and the professional's question is always **can vs should**.

Unit 2 — Ethics for IT Workers and IT Users

5 lecture hours. Managing the IT worker relationship · encouraging professionalism of IT workers · encouraging ethical use of IT resources among users · key privacy and anonymity issues · social networking ethical issues.

2.1 Why IT workers face special pressure

An **IT worker** is a professional who designs, builds, maintains or manages IT systems **and the data inside them**.

What makes IT workers ethically different from most other employees is **privileged access**. A clerk can see their own desk. A database administrator can see **everyone's records**. A developer holds the source code; a system administrator holds root rights; a support technician can read your files "to fix the problem".

> **The chain to remember: access is power, and power is responsibility.** Being technically able to do something — read a balance, copy a file, reset a password — does not make it right.

IT role	What they can technically do	The duty their access creates
Database administrator	Read or edit any record — every customer's balance, any citizen's KYC	View only what the job needs; never browse out of curiosity
Developer	Hold the full source code and business logic	Do not leak, sell or reuse the employer's or client's code
System administrator	Root rights — read anyone's email, reset any password	Do not snoop; act only on authorised tasks
Support technician	Open your files, install software, take remote control	Touch only what fixes the stated problem; keep what you see private
Network administrator	See all traffic, block or log any user	Monitor to policy, not to spy on individuals
Bank IT staffer (Nepal)	Look up any account — a neighbour's, a celebrity's, an ex's	Look only for a work reason

Nothing in the right-hand column is enforced by the system. The system *grants* the access. Only trust and ethics stop the abuse.

Scenario	Can?	Should?
A bank staffer checks an ex's balance	Yes — the system permits it instantly	**No** — no work reason; a betrayal of trust
A sysadmin reads the CEO's private email	Yes — root rights make every inbox readable	**No** — snooping, not an authorised task
A support tech copies a customer's photos	Yes — remote control opens all their files	**No** — touch only what fixes the fault
A developer keeps a copy of the employer's source code	Yes — they already hold the codebase	**No** — reusing it elsewhere is IP theft
A telecom engineer pulls a celebrity's call records	Yes — network logs expose everyone's metadata	**No** — curiosity is not authorisation
A hospital IT clerk browses a neighbour's records	Yes — the database shows any patient's history	**No** — the privacy duty forbids it

> ⚠ **Common mistake:** "*IT is just a back-office technical job — ethics is for managers.*" **Correction:** access **is** power. The more you can technically do, the more responsibility you carry, title or no title. **A junior with admin rights holds more trust than a senior manager without them.**

2.2 The six relationships an IT worker manages

Picture yourself at the centre of a web with six arrows pointing outward.

Relationship	Core duty	A concrete risk in Nepal / IT
Employer	Loyalty and honesty; protect assets and IP	Copying source code to a personal side project
Client	Honest advice; deliver what was promised; disclose risks	Hiding a security flaw to hit a deadline
Suppliers	Deal fairly; no bribes or kickbacks	Accepting a vendor's pre-tender "gift"
Peers	Mutual respect; no résumé inflation; no poaching trade secrets	Blaming a teammate to look better
Users	Support and train them; do not exploit their skill gap	Burying a customer in jargon to overcharge
Society	Build safe systems; do not enable harm	Shipping a system that leaks citizen data

Notice: none of these risks required hacking. Every one comes from **ordinary access plus a pull on your loyalty**.

The employer

Two core duties: **loyalty** (protect their assets and intellectual property — source code, client lists, internal data) and **honesty** (be truthful about your work and your qualifications).

Four places this relationship strains:

Pressure point	What it looks like	Why it is an ethical problem
Conflict of interest	Moonlighting for a rival	Your judgement now serves two masters
Résumé fraud	Claiming a certification or skill you do not have	A breach of honesty before you even start
Software licence compliance	Using pirated software at work	Legal liability for the firm **and** you
Whistle-blowing tension	The employer itself is doing wrong	Loyalty has a limit — it never requires covering up harm (Unit 4)

> **The case to think through.** Your employer tells you to install pirated Microsoft Office or AutoCAD on all office machines to cut costs. Everyone does it, and it saves money. **Who is liable if it is discovered?** Liability can fall on the company **and on the individual who installed it**. "I was just following orders" is Unit 1's **blind-obedience trap**, and it does not transfer the responsibility away from you.

The client

Three professional duties: give **honest technical advice**, **deliver what was promised**, and **disclose risks**.

Why this relationship is ethically loaded: information asymmetry. The client usually **cannot judge technical quality**. They cannot read your code, cannot tell secure architecture from a shortcut, cannot know whether your "it's done" is true. They are forced to rely on your honesty — the same way a patient must trust a doctor. When one party cannot verify and the other can exploit that, **ethics is the only protection the weaker party has**.

What the vendor did	Duty broken	Why the client could not catch it
Sold an NGO an oversized ERP it did not need	Honest advice	They cannot judge what capacity they need
Marked a half-built e-governance module "done"	Deliver as promised	No technical staff to test before paying
Hid that the portal cannot handle election-day load	Disclose risks	Load only shows up in production, months later
Used cheap unlicensed libraries without saying	Disclose risks	The client cannot read the dependency list
Left no documentation, to lock in future work	Honest advice	They do not know documentation was owed
Quietly stored client data on a free foreign host	Disclose risks	Invisible unless a leak exposes it

> ⚠ **Common mistake:** "*If the contract doesn't ban it, it's fine.*" **Correction:** professional duty goes **beyond the contract's letter**. The contract is a floor, not the limit of your responsibility — the same Unit 1 idea. **A loophole is not an ethical permission slip.**

Suppliers — and the gift-versus-bribe test

Deal fairly, and avoid bribery and kickbacks. In Nepal, festival (Dashain) gifting is culturally normal, which is exactly why you need a test that separates a normal gift from a bribe.

The three questions	A genuine gift	A bribe
Would it survive being made public?	Yes — a logo pen at a conference is fine to disclose	No — you would hide the "free iPhone" from your boss
Is it timed around a decision?	No — unrelated to any pending choice	Yes — it arrives the week before the tender
Could it influence your judgement?	No — token value, no leverage	Yes — that is the entire point of giving it

A vendor's **free iPhone a week before a Rs 2-crore tender fails all three** — it is a bribe. A pen with the vendor's logo passes all three — it is a gift.

> **The pharmacist analogy.** An IT worker is like a hospital pharmacist: trusted with powerful "medicine" — access and data — that heals or harms depending on whose hand holds it. The pharmacist's *skill* is not the safeguard; their *ethics* is. Same for you and your admin password.

2.3 Is IT a profession?

A **profession** is not just a serious job. There is a four-part test.

Criterion	Medicine / engineering	Information technology
Specialized education	Medical or engineering degree required	✅ Yes — IT degrees, including this BIM
Recognized body of knowledge	Established, documented, examined	✅ Yes
Code of ethics	Yes, enforced by the council	✅ Yes — ACM, IEEE-CS (but voluntary)
Self-regulation — licensing and discipline	Yes — the council can strike you off	❌ **No universal licensing to lose**

IT scores three out of four. The missing piece — self-regulation — is the whole reason "is IT a profession?" is a genuine debate rather than an exam phrase.

The Nepal fact that makes it concrete: doctors are licensed by the **NMC (Nepal Medical Council)** and engineers by the **NEC (Nepal Engineering Council)** — you legally cannot practise without registration. **IT workers generally are not licensed.** You could start building banking software tomorrow with no government permission.

Field	Licensed / self-regulated?	Verdict
Doctor (NMC)	Yes — can be struck off	Full profession
Civil engineer (NEC)	Yes — registration required	Full profession
Lawyer (Nepal Bar Council)	Yes — must be enrolled	Full profession
Chartered accountant (ICAN)	Yes — licensed and disciplined	Full profession
Software developer	No licence needed to build banking software	**Partial** — knowledge and codes, no licensing
Freelance "computer technician"	No credential required at all	Not a profession — anyone can claim the title

> ⚠ **Common mistake:** "*Anyone who fixes computers is an IT professional.*" **Correction:** professionalism is about **standards and accountability**, not technical skill alone. A brilliant coder who hides bugs and pads invoices is *skilled*, not *professional*.

2.4 Codes, certification, licensing and professional bodies

These four are constantly confused in exams. **The test that separates them: who grants it, and does it carry legal force?**

Mechanism	Who grants it	Legal force?	What it proves or does	Example
Certification	A vendor or industry body	**No** — voluntary	You have a specific skill	CCNA, CISSP, AWS
Licence	**Government**	**Yes** — legally enforced	The legal right to practise	NMC doctor registration; a driving licence
Code of ethics	A professional body	No — but can discipline members	Shared ethical commitments	ACM's "avoid harm"
Professional body	(It *is* the organisation)	No — it sets standards	Publishes codes, runs certifications, advocates	ACM, IEEE-CS, ISACA, CAN-Nepal

Codes of ethics

A **code of ethics** is a published set of principles that members commit to upholding. The big two in IT are the **ACM Code of Ethics** and **IEEE-CS**. A code does four jobs:

Job	What it achieves
Sets expectations	Turns vague "be good" into specific commitments — avoid harm, respect privacy, be honest about limitations
Builds public trust	Outsiders can see the standard the field holds itself to
Guides decisions	A reference when you are unsure, instead of just your gut
Provides a basis for discipline	Membership or employment can be tied to it — so it has *some* teeth even without a state licence

The ask at work	Principle invoked	What the code says to do
Build hidden user tracking without consent	Avoid harm; respect privacy	Object, disclose, or refuse
Ship now with a known security hole	Avoid harm; be honest about limits	Disclose the risk
Claim a system is more secure than it is	Be honest about limitations	State the real capabilities
Reuse a rival's leaked source code	Respect property	Refuse — it is not yours to use
Quietly weaken data protection to cut cost	Respect privacy	Push back
Blame a junior for your own bug	Be honest; give fair credit	Own the error

> **A code is only useful when you can apply it to a concrete request — and it hands you professional language to say no.**

Certification

A **certification** is a vendor or industry credential proving a **specific skill**. Four defining traits: it **signals competence** to employers, it is **voluntary**, it can become **outdated**, and it is **not a licence**.

Certification	What it proves	Issued by
CCNA	Cisco networking fundamentals	Cisco (vendor)
CISSP	Information-security management	(ISC)²
CEH	Ethical hacking / penetration testing skill	EC-Council
CompTIA A+	Core IT support, hardware and OS troubleshooting	CompTIA
AWS Certified	Building and operating on AWS	Amazon (vendor)
CISA / CISM	IT audit / security governance	ISACA

In Nepal, graduates pursue **CCNA and CEH** largely to get a CV past a foreign client's first filter for outsourcing and remote work.

> ⚠ **Common mistake:** "*Certification means ethical behaviour.*" **Correction:** certification proves **skill, not integrity**. A Certified Ethical Hacker has the *skill* to break into systems. Whether they use it ethically is a separate question the certificate cannot answer.

Licensing and the professional bodies

A **licence** is government-granted permission to practise, legally enforced. Its purpose is to **protect the public in high-stakes fields** — you cannot practise medicine or structural engineering without one *because mistakes kill people*.

The live debate: should safety-critical software — medical devices, aviation, banking core systems — require a licensed engineer the way a bridge does? The trade-off is real: licensing adds protection but also brings **gatekeeping, fees and slower entry**, which is why IT has resisted it. *Evidence of how unsettled this is:* in the United States a "**Professional Engineer (PE) — Software" licence was created and then largely discontinued for lack of demand.**

Body	Focus	What it runs
ACM	Global computing standards and ethics	The ACM Code of Ethics; conferences, digital library
IEEE-CS	Computing and engineering standards	Standards; the software-engineering code (with ACM)
ISACA	Governance, audit and security	The CISA and CISM certifications
CAN (Computer Association of Nepal)	Nepal's IT community	Advocacy, events, training

> **The whole map in one line:** professional **organisations** publish the **codes** and run the **certifications**; **government** runs **licensing**.

2.5 Ethical use of IT resources — the user side

An **IT user** is **anyone who uses an organisation's IT resources** — staff, students, customers, contractors. Not just the IT department.

The key idea: most security and ethics incidents start with ordinary users, not hackers. This is the **insider risk**, and it is usually not malicious — just careless.

Everyday user action	The harm it causes
Clicking a phishing link	Credentials stolen, malware installed across the network
Reusing one password everywhere	One leak unlocks every account
Plugging in a personal USB	Malware jumps onto work machines
Installing a cracked app "to get work done"	Malware plus a licence violation
Installing games on a shared lab PC	Slows the machine and ruins it for the next class
Sharing the Wi-Fi or server password freely	Untraceable misuse — torrents, crypto-mining

Why the reframing matters: if most harm starts inside, **buying more security tools will not fix it**. You have to change user behaviour.

> ⚠ **Common mistake:** "*Only the IT department is responsible for misuse.*" **Correction: every user shares responsibility.** The IT department locks the doors — but if you prop them open, that is on you. Security is a shared duty, not a department.

Acceptable Use Policy (AUP)

An **AUP** is a document stating what users may and may not do with the organisation's IT resources. Every AUP defines four things:

Element	What it states	Example clause
Permitted use	What you may do	Work tasks; reasonable brief personal use
Prohibited use	What you may not do	No piracy, no personal USBs, no side business on company email
Monitoring	That the organisation may watch use	"Your email and web use may be monitored"
Consequences	What happens on breach	Warning → suspension → dismissal → legal action

The ethical hinge is the signature. Users acknowledge and sign the AUP, which converts a vague expectation into an **informed, consented agreement** — "I didn't know" stops being available. The monitoring clause is also what makes later monitoring *fair* (see 2.7).

Allowed	Prohibited
Using PCs for coursework and assignments	Installing cracked or unlicensed software
Reasonable brief personal use on a break	Torrenting movies or games on the network
Saving work to approved storage	Plugging in personal USB drives without scanning
Printing documents you need	Accessing offensive or illegal content
Reporting a fault to IT	Running a side business on company email
Using licensed, provided applications	Crypto-mining or unauthorised background jobs

Nepali banks, telecoms (NTC, Ncell) and universities all run AUPs of this kind — banning personal USB drives and unlicensed software, and requiring students to agree at enrolment.

Software piracy

Software piracy is copying, installing or distributing software **without a valid licence**. It takes three forms:

Form	What it is	Example
Counterfeiting	Selling fake copies as genuine	A shop selling pirated Windows DVDs as "original"
Unlicensed install	One purchased copy on many machines, or a cracked version	Cracked AutoCAD across a whole office
Licence violation	Exceeding what the licence permits	A 5-seat licence used by 50 staff

Piracy is **both a legal harm** (copyright infringement — Unit 3) **and an ethical harm** (you took the value of someone's work without paying — a fairness violation). The ethics stands on its own even where enforcement is weak.

Nepal and South Asia have **high software-piracy rates**, with countless offices running cracked Windows and Office. The "everyone does it" defence is Unit 1's **normalization trap** — name it as a trap, not an excuse.

> ⚠ **Common mistake:** *"It's only piracy if I sell it."* **Correction: using an unlicensed copy is already a violation.** No sale is required. The wrong is not *profiting*; it is *using value you never paid for*.
>
> **The cinema analogy.** Cracked software is like sneaking into a movie hall. The film still plays, nobody is obviously poorer tonight, it feels victimless — but you were **never entitled to the seat**.

Inappropriate use

Inappropriate use is using organisational resources for unauthorised, personal or harmful purposes. Unlike piracy, the software may be perfectly licensed — **the problem is the purpose**.

Action	Typical verdict	Why
Charging your phone on the office PC	Depends	Trivial, but some AUPs restrict USB ports
Installing a cracked PDF editor	**Prohibited**	Software piracy
A quick eSewa or Khalti payment on a break	**Allowed**	Reasonable, brief, no impact on work
Running a weekend freelance project on the work laptop	**Prohibited**	Resource misuse plus an IP conflict with the employer

Action	Typical verdict	Why
Plugging in a personal USB to print a file	Depends	Malware risk; often needs a scan or is banned
Streaming cricket all afternoon	**Prohibited**	Excessive personal use — hits work and bandwidth

The working test: reasonableness + the AUP + impact on your work. The "depends" rows are exactly the ones an AUP must spell out in advance — **ambiguity is where misuse hides**.

2.6 Data privacy

Data privacy is the **right of individuals to control how their personal data is collected, used and shared**. The keyword is **control** — privacy is not secrecy, it is *who decides*.

Three principles make privacy operational:

Principle	One-line meaning	Violation example in Nepal
Consent	Collect data only with informed agreement	A SIM dealer selling your number to loan marketers
Purpose limitation	Use data only for the reason it was collected	Loan-form data reused to target you with ads
Data minimization	Collect only what you actually need	A mall QR form demanding your citizenship number

What happened	Principle violated	The harm
A SIM dealer sells your number to loan marketers	Consent	A flood of unsolicited calls
Loan-form data is reused to target you with ads	Purpose limitation	Profiling you never agreed to
A mall QR form demands your citizenship number	Data minimization	Over-collection you cannot take back
Bank KYC records leak to a data broker	Consent + minimization	Fraud and impersonation risk
An app asks for contacts it does not need	Data minimization	Your friends' data is exposed too
A clinic shares its patient list with a pharmacy	Purpose limitation	Sensitive health data misused

The harms when these fail: profiling (being silently categorised and targeted) and **fraud** (leaked data enabling impersonation).

Nepal context: KYC data held by banks and telecoms is among the richest personal datasets in the country. Nepal's **Individual Privacy Act, 2075 (2018)** recognises a legal right to privacy of personal information — but **reported leaks of citizen data** show the gap between having a law and enforcing it.

> ⚠ **Common mistake:** "*I have nothing to hide, so privacy doesn't matter to me.*" **Correction:** privacy is about **control and power**, not hiding wrongdoing. You lock your door not because you are doing something wrong inside, but because **it is yours to control who enters**. "Nothing to hide" confuses *secrecy* with *control* — you still close the curtains.

2.7 Surveillance

Surveillance is the **systematic monitoring** of people's activities, communications or location. The word *systematic* matters: a one-off glance is not surveillance; a system that logs everyone, always, is.

Forms: workplace monitoring (email, screens, keystrokes) · CCTV · government surveillance · app and location tracking.

The unavoidable tension: security versus privacy. More monitoring *can* mean more safety — catching fraud, deterring crime — but every increment **costs privacy**. The ethical work is deciding how much monitoring is **proportionate** to the actual risk, and whether people were **told**.

The decisive question is not the technology — it is disclosure. Keystroke logging can be either legitimate monitoring or spying, depending entirely on whether people knew and agreed.

The monitoring	Disclosed and consented?	Verdict
Employer logs email, stated in a signed AUP	Yes	**Legitimate monitoring**
A boss secretly installs a keylogger on your PC	No — hidden	**Spying**

The monitoring	Disclosed and consented?	Verdict
CCTV at a bank entrance with visible signage	Yes — signposted	Legitimate and proportionate
A hidden camera in a staff changing room	No — and disproportionate	**Spying** — a clear violation
An ISP logs traffic per a disclosed policy	Yes	Legitimate if proportionate
A manager reads staff personal DMs "to be safe"	No — undisclosed and excessive	**Spying**

> **This is exactly why the AUP has a monitoring clause.** A disclosed policy is the difference between *monitoring* and *spying*.

Nepal context: rising CCTV across Kathmandu; employers monitoring staff email and screens; and **SIM and biometric registration** linking identity to activity. Each trades some privacy for some claimed security — the question to ask each time is whether the trade is proportionate.

2.8 Anonymity and identity

Anonymity is acting online without revealing your real identity. It is **neither good nor bad — it is a tool with two edges**, and the same feature does both jobs.

Who is behind the mask	How anonymity is used	Edge
A whistle-blower leaking proof of corruption	Exposes wrongdoing without being fired	**Protective**
An activist under political pressure	Speaks freely without reprisal	**Protective**
A domestic-abuse survivor seeking help	Asks for support without being traced	**Protective**
A troll on a throwaway account	Harasses a public figure without consequence	**Harmful**
A scammer running a fake profile	Defrauds contacts while hiding	**Harmful**
A rumour page spreading fake news	Panics the public with no accountability	**Harmful**

Why it cannot simply be banned: any rule that silences the bottom three **also silences the top three**. That is precisely why real-name registration policies are so contested.

In Nepal: anonymous Facebook and X pages exposing corruption, versus anonymous pages spreading rumours and harassment. **Same tool, opposite uses.**

> ⚠ **Common mistake:** "*Online, I'm completely anonymous.*" **Correction: IP logs, metadata and device fingerprints** make true anonymity rare. You almost always leave a trail — which is why people do get traced and arrested for anonymous posts. **Feeling anonymous is not the same as being anonymous.**

Identity and identity theft

Online, your **identity** is **the data that represents you** — your name, citizenship number, bank and eSewa logins, biometrics. To a system you are not a person; you are a bundle of data fields, and **whoever controls those fields can be you**.

Method	How it works	Everyday defence
Phishing SMS or call	A fake "eSewa / bank" message tricks you into sharing an OTP	Never share an OTP — banks never ask for it
Fake social profile	Impersonates you or a public figure to defraud contacts	Report it; verify before trusting a request
Stolen credentials	A leaked or reused password unlocks your accounts	Unique passwords plus two-factor authentication
Data-leak reuse	Leaked KYC data used to impersonate you elsewhere	Minimise what you share; watch for misuse

Phishing is the single most common attack ordinary Nepalis actually face — fake SMS posing as eSewa or a bank to steal your OTP. Full treatment in Unit 7.

> **The house-key analogy.** Your personal data is like your house key — **easy to copy**, and you usually do not notice until someone is already inside. Nobody steals the house; they copy the key and walk in the front door.

2.9 Social networking ethical issues

> **The scenario that frames it.** A doctored screenshot of a Nepali celebrity goes viral on TikTok and Facebook before lunch. By evening a teenager is being mocked in her school group chat, and a "breaking news" rumour has sparked a panic. **How many servers were hacked? None.** Ordinary users did all the damage, using the apps exactly as designed.

The five amplifiers

Amplifier	What it does	Example
Scale	One post reaches thousands, not a roomful	A rumour shared to a 50,000-follower page
Speed	Spreads before anyone can check or correct it	A fake "breaking news" clip trending in minutes
Anonymity	People say what they would never say to your face	Abusive comments from throwaway accounts
Virality	The algorithm actively boosts the most emotional content	An outrage post pushed into millions of feeds
Bystander effect	In a huge crowd, everyone assumes someone else will act	Thousands watch a pile-on and nobody intervenes

These are Unit 1's scale, speed and permanence factors, now made personal. **The harm grows in the silence** — passive bystanders are part of the mechanism.

Nepal has very high Facebook and TikTok usage, where viral content shapes public opinion and even elections. That is a scale of influence ordinary individuals now hold in their thumbs.

> ⚠ **Common mistake:** "*It's just online — it isn't real.*" **Correction:** online harm has **real legal, social and psychological consequences** — lost jobs, depression, arrests. The screen is not a shield between the act and the harm.

Cyberbullying and online harassment

Definition: using digital tools to **repeatedly** threaten, humiliate or target a person. The word *repeatedly* matters — a single rude comment is unkind; a **pattern** aimed at someone is harassment.

Form	What it is
Trolling	Deliberately provoking to upset or derail
Doxxing	Publishing someone's private details to expose them to harm
Group pile-on	Many people targeting one, amplified by scale
Gendered harassment	Targeting aimed especially at women
Group-chat bullying	Repeated mocking in a shared chat
Threats and intimidation	Direct threats of harm

The **mental-health impact is severe and well documented** — anxiety, withdrawal, and in extreme cases self-harm. In Nepal this shows up as harassment of women and public figures in Facebook and TikTok comment sections, and as ordinary school group-chat bullying — the same dynamic at national and classroom scale.

> **The bystander question.** Your friend group starts mocking a classmate in a shared chat and you say nothing. **Are you complicit?** Silence in a group chat reads as agreement and *fuels* the pile-on. "I just didn't join in" is not innocence. Low-cost things a bystander can do: DM the target, name it as too far, or leave the chat.

Fake news — misinformation versus disinformation

	Misinformation	Disinformation
Intent	None — you believed it and shared carelessly	**Deliberate** — intent to deceive
Typical source	An ordinary user who did not check	Propagandists, scammers, coordinated campaigns

	Misinformation	Disinformation
Nepal example	Forwarding a fake health cure you trusted	A staged rumour to sway an election or scam money
Are you responsible?	**Yes** — the share button is an act	Yes — and the intent makes it worse

Why false information spreads faster than truth: it exploits **emotion** (fear, outrage), rides **confirmation bias** (we share what fits what we already believe), and is rewarded by **engagement algorithms that boost outrage** because outrage keeps people scrolling. Truth is boring; outrage is viral.

In Nepal: false earthquake and disaster rumours that trigger panic, fake health cures, and election misinformation.

> ⚠ **Common mistake:** "*Sharing isn't creating it, so I'm not responsible.*" **Correction:** forwarding unverified content **spreads the harm — the share button is an act**. You become a link in the chain that delivers the lie to a thousand more people.

Three checks before you share: (1) Who is the **source**, and are they credible? (2) Is it **reported anywhere reputable**, or only forwarded? (3) Does it mainly **trigger emotion or urgency**? Manufactured urgency — "*withdraw your money now*" — is the single most common signature of disinformation and scams.

Defamation

Defamation is a **false statement, presented as fact, that damages someone's reputation.**

The dividing line to learn: opinion and criticism are NOT defamation. The test is **fact versus opinion**, and **true versus false**.

Statement	Classification	Why
"I didn't enjoy this café's coffee."	**Opinion**	Personal taste, not a factual claim
"This café's service is slow and overpriced."	**Criticism**	Honest evaluation of experience; low risk
"The owner of this café is a thief."	**Defamation**	A false statement of fact alleging a crime
"I think shop X overcharges."	**Opinion**	Framed as a personal view
"Shop X is a fraud that steals money."	**Defamation**	A false factual accusation of a crime
Repeatedly posting a classmate's photo with insults	**Harassment**	Repeated targeting of a person, not defamation

The practical rule: state experiences and opinions, not invented facts about people.

In Nepal, online defamation **can be treated as a cybercrime under the Electronic Transactions Act, 2063** (full legal treatment in Unit 9), and there have been cases of arrest for defamatory Facebook posts. There is a genuine live debate here: critics argue the same law has been used to **chill free speech and silence criticism**, not only to punish genuine lies. You should be able to present both sides.

> ⚠ **Note on the law:** the ETA 2063 is older legislation and Nepal's cyber-law landscape has been evolving through amendments and proposed new bills. Treat the specifics here as illustrative of the debate and **check the current legal position** before relying on it.

Key words from Unit 2

IT worker · privileged access · can vs should · duty of care · the six relationships · loyalty · honesty · conflict of interest · résumé fraud · moonlighting · information asymmetry · gift vs bribe test · kickback · profession (four-part test) · self-regulation · NMC · NEC · code of ethics · ACM · IEEE-CS · ISACA · CAN-Nepal · certification · CCNA · CISSP · CEH · CISA/CISM · licence · PE-Software debate · IT user · insider risk · Acceptable Use Policy · permitted/prohibited/monitoring/consequences · software piracy · counterfeiting · unlicensed install · licence violation · inappropriate use · data privacy · consent · purpose limitation · data minimization · profiling · Individual Privacy Act 2075 · surveillance · proportionality · monitoring vs spying · anonymity · double-edged tool · identity · identity theft · phishing · OTP · social networking · scale, speed, anonymity, virality · bystander effect · cyberbullying · trolling · doxxing · pile-on · misinformation · disinformation · confirmation bias · defamation · opinion vs criticism vs defamation · Electronic Transactions Act 2063.

Summary — Unit 2

- IT workers hold **privileged access**, and access is power. The system grants the "can"; only ethics supplies the "should".
- They manage **six relationships** — employer, client, supplier, peers, users, society — each with its own duty. **Information asymmetry** is what makes the client duty *professional*, not merely contractual.
- The **gift-versus-bribe test** has three questions: would it survive publicity, is it timed around a decision, could it influence judgement?
- IT is a **partial profession**: it has education, knowledge and codes but **no universal licensing**. **Certification proves skill, a licence has legal force, a code guides behaviour, and a professional body sets standards.**
- Most incidents come from the **insider risk** — careless users, not hackers. The **AUP** sets permitted use, prohibited use, monitoring and consequences, and its force comes from the **signature**.
- **Piracy** (counterfeiting, unlicensed installs, licence violation) is wrong even with no sale. **Inappropriate use** is the right tool for the wrong purpose.
- **Privacy is control**, built on **consent, purpose limitation and data minimization**. **Surveillance** trades security against privacy — and **disclosure plus consent** is what makes monitoring legitimate rather than spying.
- **Anonymity cuts both ways**; true anonymity is rare. **Identity theft** usually begins with **phishing**.
- Social media turns small acts into mass harm through **scale, speed, anonymity, virality and the bystander effect**. Know the difference between **misinformation and disinformation**, and between **opinion, criticism and defamation**.

Unit 3 — Intellectual Property

6 lecture hours. Intellectual property · copyright · patent · trade secrets · IP issues: plagiarism, reverse engineering, open source code, competitive intelligence, trademark infringement and cybersquatting.

3.1 What intellectual property is

Intellectual property (IP) means **legal rights over creations of the mind** — works, inventions, names and secrets. There are **four families**, and each protects a *different kind of thing*.

Family	Protects	Everyday example
Copyright	Original **expression** fixed in some form	Your app's source code; a song; a novel
Patent	A new, useful, non-obvious **invention**	A drug formula; a novel machine
Trade secret	**Confidential information** kept secret	Wai Wai's masala ratio; a search algorithm
Trademark	A **brand's identifying sign**	The Goldstar name and logo; eSewa's logo

Why IP exists — the bargain. IP protects expression and invention, **not abstract ideas**, and it balances **rewarding creators against public access**. Creators get **temporary control** so that creating is worth it; society **eventually gets access** so knowledge spreads. Innovation needs both halves: pure monopoly starves the public, a pure free-for-all starves the creator.

One question sorts almost any IP case: is it **expression** (copyright), an **invention** (patent), a **kept secret** (trade secret), or a **brand sign** (trademark)?

The creation	Which family?	Why
Your college app's source code	Copyright	Original expression, automatic on creation
Wai Wai / CG Foods' exact masala ratio	Trade secret	Confidential, never filed
The "Goldstar" name and shoe logo	Trademark	A source identifier for the brand
A DoI-filed herbal-extraction machine	Patent	New, useful, non-obvious invention
A bank's fraud-scoring algorithm (server-side)	Trade secret	Never shipped; protected by secrecy
eSewa's app name and green logo	Trademark	Brand identity customers recognise

Nepal's IP framework. IP is administered by the **Department of Industry (DoI)** under the **Patent, Design and Trademark Act, 2022 BS (1965)**, while **copyright** sits with the **Copyright Registrar's Office** under the **Copyright Act, 2059 (2002)**. As a **WTO / TRIPS member**, Nepal must meet international IP minimums — so a foreign outsourcing client's IP expectations map onto **real Nepali law**, not just goodwill.

> ⚠ **Common mistake:** "*If it's on the internet, it's free to use.*" **Correction: publication is not permission.** Being able to right-click and save a photo gives you **access, not rights**. The default is **owned**, not free.

3.2 Copyright

Copyright protects original expression fixed in a tangible form — text, music, film, software code, art.

The single most tested point: it protects the EXPRESSION, not the underlying idea, fact or method. Two people can write different code for the same idea, and each owns their own expression. Facts, ideas and methods are **free**; only your **particular way of expressing them** is protected.

The work	The IDEA — *not* protected	The EXPRESSION — protected
A mobile app	"An app that splits a restaurant bill"	Your actual code implementing it
A song	A chord progression or a genre	The specific recorded melody and lyrics
A textbook	The facts and concepts taught	The author's particular wording and layout
A photo	"A sunrise over the Himalayas"	This photographer's specific shot

The work	The IDEA — *not* protected	The EXPRESSION — protected
A recipe	The dish and its method	The written wording of the cookbook page
A news event	What happened (the facts)	A journalist's specific article about it

This is why two teams can legally build rival bill-splitting apps.

How you get it: copyright **arises automatically the instant the work is fixed. No registration is needed** — though registration is powerful *evidence* in a dispute. Your source code is copyrighted the instant it is written.

In Nepal: the **Copyright Act, 2059 (2002)**, registered at the **Copyright Registrar's Office**. Piracy of Nepali films and music — a film like *Kabaddi* copied to YouTube or sold as pirated DVDs in New Road — infringes the creators' copyright in their **expression**. The film's *idea* (a rural love-and-marriage comedy) is free for anyone; the *specific film* is not.

Duration and fair use

Copyright is **not forever**. It lasts a limited term and then the work enters the **public domain**, free for all. In Nepal the general term is the **author's lifetime plus 50 years**. The public-domain endpoint is deliberate — it is the second half of the bargain.

Fair use is the limit that operates *during* the term: limited use for **education, research, news, criticism and parody** without permission. It is judged on **purpose, the amount used, and the effect on the work's market**.

Use of the work	Fair use?	Why
Quoting a few lines of a Nepali poem in an essay	**Fair use**	Small amount, educational, no market harm
Photocopying a whole textbook for the class	**Infringement**	Copies the entire work; harms the book's market
A short clip in a news report or review	**Fair use**	News or criticism purpose, limited amount
Uploading a full movie to YouTube	**Infringement**	Whole work, no permission, destroys its market
A parody of a popular song	Often fair use	Parody is a recognised transformative purpose
Reposting an artist's full image on your page	**Infringement**	Whole work copied without permission

> ⚠ **Common mistake:** "*Crediting the author makes copying legal.*" **Correction: attribution and permission are separate things.** Crediting the author avoids **plagiarism** (an *integrity* offence); it does **not** grant **copyright permission** (a *legal* one). You can cite scrupulously and **still infringe** by copying too much. Two different problems, two different fixes.
>
> **The cookbook analogy.** Copyright is like owning a written recipe. Others may **cook the dish** (the idea is free) — but they cannot **photocopy and sell your cookbook** (your expression).

3.3 Patent

A **patent** is an **exclusive right granted for an invention** — a new, useful, non-obvious product or process — **in exchange for public disclosure**. Copyright protects the *expression*; a patent protects the **functional idea itself**. It typically lasts about **20 years**, after which the invention becomes public.

The three patentability tests

Test	The question it asks	Fails if…
Novelty	Is it genuinely new?	It is already known or published — *prior art* exists
Inventiveness (non-obviousness)	Is it non-obvious to a skilled expert?	An expert would find it an obvious next step
Industrial applicability	Is it useful and can it be made?	It is abstract, a pure discovery, or a law of nature

All three must pass. Being popular or clever is not enough.

Claimed "invention"	Patentable?	Why
A new herbal water-filter mechanism	**Yes**	Novel, non-obvious, industrially useful
"The idea of paying by mobile phone"	No	A pure idea — fails industrial applicability

Claimed "invention"	Patentable?	Why
A genuinely new, faster momo-steamer design	**Yes**	Passes all three
Adding an obvious "share" button to an app	No	Fails inventiveness
A law of nature or a formula	No	A discovery, not an invention
A machine already sold in India last year	No	Fails novelty — prior art exists
A novel agricultural threshing device	**Yes**	New, useful, makeable — DoI-filable

> ⚠ **Common mistake:** "*You can patent any good idea.*" **Correction:** pure ideas, discoveries and laws of nature are **not patentable**. "I thought of mobile payments first" patents nothing; a **specific new mechanism** for doing it might.

The software patent debate

Software patents cover software-implemented methods or algorithms, and they are **controversial worldwide**. The key distinction: **copyright already covers the CODE**; a patent would cover the **METHOD** itself — a much bigger hammer, because a broad software patent can block a whole approach, not just one product.

Many jurisdictions — **and Nepal in practice** — restrict or disallow pure-software patents, partly because of the "**patent troll**" problem: entities that acquire patents only to sue, not to build.

Question	Copyright	Patent
What does it cover?	The specific written code	The underlying method or function
How strong is it?	Blocks copying your code	Blocks anyone using the technique at all
How do you get it?	Automatic on writing the code	Apply, disclose, pass three tests, pay fees
Available for pure software?	Yes	Often restricted or disallowed, including Nepal in practice
Typical use by a Nepali startup	Yes — protects the codebase	Rare — copyright plus trade secret instead

Global cases that show the reach: the Amazon "**1-Click**" patent, and the **Apple vs Samsung** smartphone patent wars.

Software asset	Realistic protection in Nepal	Why not a patent
A startup's app source code	Copyright	Automatic; code is already copyrightable
A clever server-side load-balancing algorithm	Trade secret	Never shipped; a patent would disclose it
A framework the team wants widely adopted	Open-source licence	Adoption matters more than monopoly
A fintech app's fraud-detection logic	Copyright + trade secret	The standard Nepali combination
A "one-click checkout" style method	Hard to protect	Pure-software patents restricted here

> ⚠ **Common mistake:** "*We should patent our software to protect it.*" **Correction:** for pure software this is often impossible or impractical. The realistic tools are **copyright plus trade secret**, sometimes open source.

The patent process and its four traits

The sequence: prior-art search → file an application with **claims** → examination → grant → maintenance and renewal fees. The **claims** mark the precise boundaries of your monopoly, like a land survey.

Trait	What it means for you	Consequence
Slow	Examination can take years	Not a quick fix for a fast-moving product
Costly	Filing, attorney and renewal fees	Prices out many small Nepali startups
Public	Your invention is fully disclosed	Rivals learn exactly how it works
Territorial	A Nepal patent protects **only in Nepal**	Global cover needs a filing per country

In practice Nepal has **relatively few local tech patents** — most filings are designs, agricultural or herbal products. A startup that files only in Nepal but exports to India has **no protection in India**.

> ⚠ **Common mistake:** "*Once I have a patent, I'm protected everywhere.*" **Correction:** patents are **territorial**. A Nepal patent means nothing in India, the US or the EU. Worldwide protection means filing and paying in each jurisdiction — which is why global patents are a big-company game.
>
> **The land-claim analogy.** A patent is like staking a land claim: you must publicly mark your boundaries (the claims) so everyone can see what is yours — and after the 20-year lease, the land becomes public again.

3.4 Trade secrets

A **trade secret** is **confidential business information that gives a competitive edge and is kept secret through reasonable effort** — formulas, recipes, processes, customer lists, algorithms, source code.

Two features make it strange and powerful:

- **No government grant and no filing.** The protection **is** the secrecy, plus reasonable effort.
- It can last **indefinitely** — Coca-Cola's formula is over a century old and still secret.

The catch: a trade secret offers **no protection against independent discovery or legitimate reverse engineering**. The moment the secret leaks or is figured out, the protection evaporates. It is **unlimited but fragile**.

The information	A trade secret?	Why
Wai Wai / CG Foods' exact masala ratio	**Yes**	Confidential, valuable, kept secret
A remittance firm's internal pricing model	**Yes**	Secret information giving a competitive edge
A company's phone number on its website	No	Already public
A restaurant's signature sauce recipe	**Yes**	Kept in-house, never disclosed
A published, patented machine design	No	The patent disclosed it
A software house's private source-code repository	**Yes**	Confidential and access-controlled

How trade secrets are protected

Not by a government grant, but by **secrecy measures**:

Measure	What it does	Nepal / IT example
NDA / confidentiality clause	Legally binds insiders to keep quiet	Standard in Nepali IT and BPO contracts
Access controls	Limits who can even see the secret	A source repository restricted to a small team
Need-to-know	Shares the secret only where essential	Only two staff know the full masala ratio
Non-compete agreement	Limits a leaver from helping a direct rival	A departing developer's contract terms
Legal remedy	Sue only if the secret was **misappropriated**	No remedy if a rival independently invents it

"**Reasonable effort**" **is a legal requirement** — a company that did not try to protect its secret may lose the right to call it one.

What happened	Misappropriation?	Why
A developer emails the source code to a rival	**Yes**	Theft of confidential information
An ex-employee reuses general skills learned on the job	No	General know-how is theirs to reuse
A rival independently invents the same algorithm	No	Independent discovery is never misappropriation
A staffer leaks the masala ratio despite an NDA	**Yes**	Breach of the NDA
A competitor legally reverse-engineers a shipped product	No	Legitimate reverse engineering breaks no law
Bribing an insider for a customer list	**Yes**	Theft of a trade secret via bribery
The firm never locked down the "secret" and it leaks	No remedy	No reasonable effort — it may not count as a secret

The hard boundary case. A developer leaves a Lalitpur software house and rebuilds a similar module from memory at a rival. **General skills and know-how you carry in your head are yours to reuse**; the employer's **specific confidential code, data or documented processes are not.** NDAs and non-competes are what make that line enforceable.

⚠ **Common mistake:** "*If I didn't copy any files, I can't have stolen a trade secret.*" **Correction:** misappropriation covers **taking confidential information, not just files** — rebuilding a protected proprietary process from memory can still breach an NDA.

Trade secret versus patent — choosing

Dimension	Trade secret	Patent
Public or private?	Private — kept confidential	Public — fully disclosed
How long?	Unlimited, while it stays secret	~20 years, then public domain
Registration?	None	Formal application and fees
Protects against independent discovery?	**No**	**Yes**
Protects against reverse engineering?	**No**	Yes, within the term

The rule of thumb. Use a **trade secret** if it is **hard to reverse-engineer** and its value is **long-term** (recipes, server-side algorithms). Use a **patent** if it will be **sold or visible** and is **reverse-engineerable** (a machine, a device mechanism).

The asset	Best protection	Why
Coca-Cola's formula	Trade secret	Hard to reverse-engineer; long-term value
A new drug molecule	Patent	Reverse-engineerable once sold
Google's search ranking	Trade secret	Runs server-side; never shipped
A novel machine mechanism	Patent	Visible in the product
Wai Wai's masala ratio	Trade secret	Kept in-house; a patent would disclose and expire it
A consumer gadget's circuit	Patent	Ships to customers who can open it up

The deciding question: once it is in customers' hands, can they figure it out? If yes, patent. If it stays behind your walls, keep it secret. Many products use **both** — patent the visible mechanism, keep the tuning secret.

⚠ **Common mistake:** "*Stronger protection is always better, so always patent.*" **Correction:** patenting a recipe would **publish it and start a 20-year clock**, when secrecy could protect it forever. The right choice depends on **reverse-engineerability and time horizon**.

3.5 Plagiarism

Plagiarism is **presenting someone else's work or ideas as your own, without credit.**

The critical framing: plagiarism is an **ethical and academic offence**, distinct from **copyright infringement, which is a legal one** — although they often overlap.

- **Plagiarism can occur even with uncopyrighted material** — copying an idea with no credit.
- **Infringement can occur even when you credit the source** — copying too much protected expression.

The definition now covers **self-plagiarism** (reusing your own past submitted work as new) and **passing off AI-generated text as your own**.

What you did	Plagiarism?	Why
Copy-paste a senior's project report as your own	**Yes**	Presenting others' work as yours
Paraphrase a source but cite it properly	No	Genuine attribution, your own wording
Submit an AI-generated essay as your own	**Yes**	Passing off non-original work as yours
Reuse your own past submitted essay as new	**Yes** — self-plagiarism	Presenting old work as new

What you did	Plagiarism?	Why
Quote two lines and attribute them	No	Properly quoted and credited
Reword a paragraph but keep its structure and ideas, no credit	**Yes**	Copied structure and ideas

In Nepal, copy-paste BIM project reports and thesis sections lifted from seniors or online are plagiarism under **Tribhuvan University's** rules — an integrity offence that can fail you regardless of whether the source was copyrighted.

> ⚠ **Common mistake:** "*Changing a few words, or citing the source, means it's not plagiarism.*" **Correction:** paraphrasing **without real understanding** — or keeping the original's structure and ideas — is **still plagiarism**. A reference dumped at the end does **not launder copied text**.
>
> **The medal analogy.** Plagiarism is wearing someone else's medal in your own race photo. You did not run the race — you just borrowed the proof that you did.

3.6 Reverse engineering

Reverse engineering is **analysing a finished product to discover how it was built or how it works.**

The surprising truth first: it is legal and common. Three legitimate purposes: **interoperability** (making products work together), **security research** (finding vulnerabilities, studying malware) and **learning**. Whole security careers depend on it.

It crosses into misuse when used to **copy protected code** or **misappropriate a trade secret**, and **EULAs often forbid it outright** — which adds a *contract* problem on top of the copyright one.

Purpose	Legitimate?	Why
Building a tool that interoperates with an app	**Legitimate**	Interoperability is a recognised lawful purpose
Security research — studying malware, finding bugs	**Legitimate**	Protects users; standard practice
Learning how a technique works	**Legitimate**	Understanding is not copying
Cloning an app's protected code 1:1	**Misuse**	Copies protected expression
Extracting a competitor's trade secret	**Misuse**	Misappropriation
Reverse-engineering where the EULA forbids it	**Misuse** (contract)	Breaches the licence you agreed to

> **Same technique, opposite ethics.** A Nepali developer decompiles eSewa's app — to build a **compatible tool** that works alongside it (legitimate interoperability), or to **clone its features and UI 1:1** (copying protected expression). The act of decompiling is identical; **the purpose and the output** decide which side of the line you are on.

The lawful workaround when you need to match a function: a "**clean-room**" **re-implementation** — rebuild from **behaviour, not from the code**.

> ⚠ **Common mistake:** "*Reverse engineering is hacking / always illegal.*" **Correction:** it is a standard, lawful practice. **Intent and use define the line.**

3.7 Open source code

Open source software is released under a licence granting rights to **use, study, modify and share** the source.

The single most important correction: open source is NOT the absence of copyright — it is copyright PLUS a licence. The author **keeps copyright** and uses the licence to grant specific rights on specific conditions.

Question	**Permissive** (MIT, Apache)	**Copyleft** (GPL)
Can you use it in closed software?	Yes	Only if you also open your derivative
Main obligation	Keep the attribution / licence notice	Release derivative source under the same licence
Why a company might avoid it	Rarely avoided	Can "infect" proprietary code with openness
Example projects	React (MIT); much of Apache's stack	Linux, Android core (GPL)

What the team did	Licence violation?	Why
Ships GPL code inside a closed proprietary app	**Yes**	Copyleft requires derivatives be open
Uses React (MIT) in a closed product, keeps the notice	No	Permissive — only attribution required
Drops the MIT attribution notice	**Yes**	Attribution is MIT's one obligation
Modifies GPL code and releases the source under GPL	No	Share-alike honoured
Builds a government site on WordPress, keeps its licence	No	Compliant use
Removes GPL notices and sells it as their own	**Yes**	Copyright infringement

Nepali startups and government projects build on **WordPress, Linux and open frameworks** to cut cost — exactly what open source is for. But the licences carry obligations, and **honouring them is not optional politeness; it is the condition of the grant.**

> ⚠ **Common mistake:** "*Open source means free with no rules.*" **Correction:** ignoring the licence **is copyright infringement** — companies have been sued for shipping GPL code inside closed products.

3.8 Competitive intelligence versus industrial espionage

Competitive intelligence (CI) is **legally and ethically gathering public information about competitors** to inform strategy. It is legal business homework — reading what a rival has already made public: websites, advertisements, public filings, job posts, trade shows.

It becomes **industrial espionage** when it involves **theft, bribery, hacking, misrepresentation or stealing trade secrets**.

> **The line is crossed by HOW you get the information, not by wanting it.**

Method	CI or espionage?	Why
Reading a rival's public annual report and rates	**CI**	Public, legal source
Studying competitors' advertisements and job postings	**CI**	Freely published
Walking a competitor's public trade-show booth	**CI**	Openly available to anyone
Hacking a rival's servers for their data	**Espionage**	Illegal intrusion
Bribing a staffer for a customer list	**Espionage**	Theft of a trade secret via bribery
Posing as a customer to extract secret pricing	**Espionage**	**Misrepresentation** — even though nothing was hacked

That last row is the sharp edge worth remembering: **lying about who you are is espionage even with no hacking at all.**

> **The playbook analogy.** Competitive intelligence is reading the other team's **published** playbook. Espionage is **breaking into their locker room to steal it.** Same information, completely different act.

3.9 Trademark and trademark infringement

A **trademark** is a **sign, name, logo or slogan that identifies the SOURCE of goods or services**. **Infringement** is unauthorised use of a **confusingly similar** mark.

The purpose: protect brand identity and **prevent consumer confusion**. The harm is that buyers cannot tell who really made the product.

Three features students routinely get wrong:

- A mark can last **indefinitely**, as long as it is **used and renewed** — unlike copyright and patents, which expire.
- Infringement **does not need an identical copy** — a confusingly **similar** mark is enough.
- **Company registration and trademark registration are separate filings.**

In Nepal, trademarks are registered at the **Department of Industry** under the Patent, Design and Trademark Act.

Situation	Infringement?	Why
Selling fake "Goldstar" shoes with the logo	**Yes**	Passing fakes off as genuine
Counterfeit "Wai Wai" packets	**Yes**	Confuses buyers about the true source
A momo stall using a near-identical famous logo	**Yes**	Confusingly similar → consumer confusion
Your own original shop name and logo	No	Distinct mark; no confusion
Naming a product with a common dictionary word	Usually no	Generic terms are weak marks
A comparative advertisement naming a rival truthfully	Usually no	Nominative reference, not passing off

> ⚠ **Common mistake:** "*Registering my company name means I own the trademark.*" **Correction:** these are **separate filings**. To protect a brand identity you must register the **trademark** specifically.

3.10 Cybersquatting

Cybersquatting is **registering a domain name matching someone else's trademark in bad faith** — to resell it or divert traffic. **Bad faith toward a known brand is the defining element.**

Draw the boundaries carefully:

- **Legitimate domain investing** — generic names, no target brand — is **lawful and different**.
- **Typosquatting** registers **misspellings** (e-sewa vs esewa) to catch mistyped traffic, often for **phishing**. It is a close cousin.
- **Disputes:** `.com` goes through the **UDRP** (ICANN's dispute process); `.np` **domains** are managed by **Mercantile (register.com.np)**, which handles local disputes.

Scenario	Verdict	Why
Registering a Nepali bank's name as `.com.np` to resell it	**Cybersquatting**	Bad-faith grab of a known trademark
Registering `e-sewa.com.np` to mimic eSewa	**Cybersquatting + phishing risk**	Lookalike to divert and deceive
Registering a generic word like `momos.com`	Legitimate	No target brand
Buying and selling generic domains as investment	Legitimate	Domain investing
Typosquatting `gogle.com` to catch typos	**Cybersquatting** (typosquatting)	Bad-faith lookalike
Owning your own brand's domain	Legitimate	Rightful use of your own mark

> ⚠ **Common mistake:** "*First to register a domain owns it fairly.*" **Correction:** registration in **bad faith toward a known trademark** is cybersquatting, not fair ownership. The brand can recover it through UDRP or the `.np` registry.

3.11 The capstone — all four types side by side

	Copyright	Patent	Trade secret	Trademark
What it protects	Original expression	A new invention (method)	Confidential information	Brand identity (name/logo)
How you get it	Automatic on creation	Apply + disclose + 3 tests	Keep it secret — no filing	Register (DoI) + renew
How long it lasts	Life + 50 years	~20 years	While it stays secret	Indefinite, with renewal
Then what?	Public domain	Public domain	Gone if leaked or found	Lost if not used or renewed
Nepal example	A pirated *Kabaddi* film	A DoI-registered device	Wai Wai's masala ratio	Fake Goldstar logo

One product can involve all four. A Nepali fintech app: its **code is copyrighted** (automatic), a **novel mechanism** inside it might be **patented** (rare for software), its **fraud-scoring algorithm is a trade secret** (NDA-protected, server-side), and its **name and logo are trademarked** (registered at the DoI, plus grabbing the domain).

Nepali asset	Correct IP type	The common wrong answer
A brand name like "eSewa"	Trademark	"Copyright the name" — names are not copyrighted

Nepali asset	Correct IP type	The common wrong answer
The source code of the eSewa app	Copyright	"Patent the code"
Wai Wai's masala ratio	Trade secret	"Patent it" — that would disclose and expire it
A pirated *Kabaddi* film copy	Copyright	"A trademark issue"
A DoI-registered herbal machine	Patent	"Trade-secret it" — a visible product is copyable
A momo shop's registered logo	Trademark	"Company registration covers it"
A `daraz.com.np` domain grabbed in bad faith	Trademark (cybersquatting)	"First to register owns it fairly"

Key words from Unit 3

Intellectual property · Department of Industry · Patent, Design and Trademark Act 2022 BS · Copyright Act 2059 · Copyright Registrar's Office · WTO/TRIPS · copyright · expression vs idea · fixation · automatic protection · public domain · life + 50 years · fair use · attribution ≠ permission · patent · novelty · inventiveness / non-obviousness · industrial applicability · prior art · claims · disclosure bargain · software patent · patent troll · slow/costly/public/territorial · trade secret · reasonable effort · misappropriation · NDA · non-compete · need-to-know · independent discovery · plagiarism · self-plagiarism · reverse engineering · interoperability · clean-room re-implementation · EULA · open source · permissive (MIT, Apache) · copyleft (GPL) · share-alike · competitive intelligence · industrial espionage · misrepresentation · trademark · consumer confusion · cybersquatting · typosquatting · UDRP · register.com.np.

Summary — Unit 3

- **IP** is legal rights over creations of the mind, in **four families**: copyright (expression), patent (invention), trade secret (confidential information), trademark (brand).
- **Copyright protects expression, not ideas**, arises **automatically**, lasts **life + 50 years** in Nepal, and is limited by **fair use**. **Attribution avoids plagiarism, not infringement.**
- **Patents** protect novel, non-obvious, useful inventions for ~20 years in exchange for **public disclosure**, and are **slow, costly, public and territorial**. Pure-software patents are restricted, so Nepali software relies on **copyright plus trade secret**.
- **Trade secrets** are protected by secrecy and NDAs, not registration; they last **forever but are fragile** — no protection against independent discovery or legal reverse engineering. Choose by **reverse-engineerability**.
- **Plagiarism** is an ethical offence (passing off work as your own, including AI text and self-plagiarism); **infringement** is a legal one. They overlap but are not the same.
- **Reverse engineering** is lawful for interoperability, security and learning; **intent and use define the line**.
- **Open source is copyright plus a licence** — permissive needs attribution, copyleft needs derivatives kept open. Breaking either is infringement.
- **Competitive intelligence is legal**; it becomes **espionage** when the method is theft, bribery, hacking or lies.
- **Trademarks** prevent consumer confusion and can last indefinitely; **cybersquatting** is bad-faith domain grabbing, resolved by **UDRP** or the `.np` registry.

Unit 4 — Ethical Decisions in Software Development and Ethics of IT Organizations

5 lecture hours. Software quality and its importance · strategies for developing quality software · use of contingent workers · outsourcing · whistle-blowing · green computing.

4.1 What software quality means

Software quality is **the degree to which software meets its stated requirements AND users' real expectations — reliably and safely.**

> **The slogan to memorise: quality = conformance to requirements + fitness for use.**

It has two dimensions: **functional quality** (it does what the spec says — correctness) and **non-functional quality** (reliability over time, usability, security, maintainability, performance).

"**Passes the demo" is not quality.** A demo exercises the happy path once, on the developer's laptop. Quality is judged **in production** — under real load, over time, for real users on weak networks and low-end phones. *Fitness for use* means it works in the **user's** actual context, not the developer's ideal one.

Attribute	What it means	Failure example
Correctness	Does what the requirements say	A wallet that miscalculates a balance
Reliability	Works consistently over time and load	A banking app that crashes every Dashain rush
Usability	Real users can actually use it	A government e-service no ordinary citizen can navigate
Security	Protects data and resists attack	An app that leaks KYC data
Maintainability	Can be fixed and extended safely	Spaghetti code where each fix breaks two things
Performance	Fast enough under real conditions	A tax portal that times out on deadline day

Real case	Attribute that failed	Verdict
eSewa/Khalti crashes in the Dashain rush	Reliability	Passed the demo but cannot hold festival load
Tax/PAN portal times out on filing-deadline day	Performance	Logic is correct but too slow at peak
A government e-service citizens cannot navigate	Usability	Works for the developer, not the user
A mobile-banking app leaks KYC data	Security	Functionally "works" yet exposes data
A wallet miscalculates a balance by a paisa	Correctness	Does not meet the spec at all
Each bug fix quietly breaks two other features	Maintainability	Cannot be changed safely

> ⚠ **Common mistake:** "*Quality just means no bugs / it passed the demo.*" **Correction:** quality is the **whole set** — a correct app that is insecure, slow or unusable still fails its users.

4.2 The cost of poor quality

The cost of poor quality is every cost caused by defects — rework, downtime, lost customers, lawsuits and reputation damage.

> **The rule to remember: the cost to fix a defect rises roughly 10× at each later stage** (requirements → design → code → release → post-release). A bug caught while writing requirements is trivial; the same bug found after release is enormously expensive.

Picture an iceberg. The **visible cost** — a refund, a patch — is the small tip. The **hidden costs** — lost trust, a support surge, churn, liability — are the huge mass below the water, and they **land later, when the fix is dearest**.

The defect	Visible cost	The hidden, larger cost
A payment bug refunds the wrong users	The refunded amount	Support surge, manual reconciliation, emergency audit
An app crashes at peak (Dashain rush)	A patch release	Lost transactions; users switch to a rival
A data field is wrong (e.g. blood group)	The correction	Possible harm, liability, loss of trust
A government e-service glitches on deadline	A hotfix	Citizens flood help desks; trust in e-government drops
A security defect leaks data	The fix plus disclosure	Lawsuits, regulatory penalty, brand damage
A rushed release with no tests	The rework	Cascading bugs, missed deadlines, a burnt-out team

> ⚠ **Common mistake:** "*We'll ship now and fix it in production — it's cheaper.*" **Correction:** "fix it later" is usually the **most expensive option available**. Prevention — early testing and QA — is cheaper than cure.

4.3 Safety-critical software

Safety-critical software is software whose failure can cause death, injury or major loss — medical, aviation, transport, power.

Here **the ethics changes**: a bug is no longer "inconvenient", it is **dangerous**. Safety-critical software therefore ethically demands **higher rigour** — redundancy, formal verification, exhaustive testing, independent review and clear accountability. **In this class of system, quality is not a preference; it is a duty.**

System	What went wrong	Consequence
Therac-25 (medical)	A race-condition bug plus removed hardware interlocks	Massive radiation overdoses; deaths
Boeing 737 MAX (aviation)	MCAS acted on **one faulty sensor**, with poor disclosure	Two crashes, **346 deaths**, global grounding
Ariane 5 (space)	A 64-bit value forced into 16 bits → overflow	Rocket self-destructed seconds after launch
Power-grid control	Control-software failure or misconfiguration	Cascading regional blackouts
ICU / patient monitoring	Wrong data shown or an alarm missed	Direct risk to patient life

Nepal has safety-critical systems too — power load-dispatch and grid control software, aviation systems serving Tribhuvan International Airport, and hospital ICU and patient monitoring.

> ⚠ **Common mistake:** "*A bug is just a bug — we can always patch it.*" **Correction:** in safety-critical software a bug can **kill before any patch ships**. You cannot "fix it in production" when production is an ICU or a cockpit. **The rigour must be proportional to the stakes.**

4.4 Strategies for developing quality software

Testing

Testing is systematically running software to find defects before users do. It works as a ladder of levels:

Level	What it checks	Who and when
Unit	Each function or module in isolation	Developer, continuously, usually automated
Integration	Modules working together correctly	Developers and QA as parts are joined
System	The whole application end-to-end	QA team before release
Acceptance (UAT)	That it meets the user's real needs	The client signs off — e.g. a bank's UAT with NRB

Other distinctions you need: tests are **manual or automated** (automated tests run on every change — continuous integration — catching **regressions** instantly); **black-box** tests behaviour without seeing the code, **white-box** tests internal logic; and **regression testing** re-checks old features so a new fix does not silently break them.

> **The famous truth: testing shows the PRESENCE of bugs, not their absence.** So it must be structured, not ad-hoc.

Concrete scenario	Level	What it catches
Check one interest-calculation function returns the right paisa	Unit	Math bugs, automatically on every commit
Verify the wallet and bank API talk correctly during a top-up	Integration	Broken hand-offs between modules
Run the full eSewa payment flow end-to-end before release	System	Whole-journey failures
NRB or the bank signs off a digital-banking go-live	Acceptance (UAT)	That it meets the client's real need
Re-run old tests after a Dashain hotfix	Regression	That the fix did not break paid features
Enter a negative amount, or retry on a weak network	Edge case (black-box)	The failures real users actually hit

> ⚠ **Common mistake:** "*If it works on my machine, it's tested.*" **Correction: ad-hoc clicking is not testing.** You need defined test cases, edge cases and regression coverage — and real testing **proves you looked**.

QA versus QC

These are **different jobs**, and students constantly conflate them.

Question	Quality Assurance (QA)	Quality Control (QC)
Focus	The **process** that builds software	The finished **product**
Stance	**Proactive** — prevent defects	**Reactive** — catch defects
Activities	Standards, code reviews, audits, checklists	Testing, inspection, defect logging
Goal	Fewer defects are created	Defects do not reach the user
Analogy	Designing a clean kitchen and recipes	Tasting each dish before it leaves

> **The one-liner: QA reduces how many defects are created; QC catches those that slip through anyway.** You need both.

Activity	QA or QC?
Writing a coding-standards and code-review policy	**QA** — shapes the process
A senior reviews every merge request	**QA** — stops bad code entering
Running the system test suite before release	**QC** — checks the product
A tester logs bugs from a release candidate	**QC**
Maintaining an ISO/CMMI-aligned checklist	**QA** — makes quality repeatable
Inspecting a generated report for wrong totals	**QC**

> ⚠ **Common mistake:** "*We have a great tester, so quality is covered.*" **Correction:** that is **QC only** — catching defects, not preventing them. Relying on a single heroic manual tester at the end is **fragile and unethical**: there is no prevention and no documentation, and the whole quality story collapses the day that person is on leave. Real quality is **engineered into the process** so it survives any one person leaving.

Standards and process models

Standard / model	What it does	Why it matters
ISO 9001	A general quality-management system	Signals a disciplined organisation
ISO/IEC 25010	A software product-quality model	Defines the quality attributes to measure
CMMI	Rates process maturity, levels 1–5	Western clients often require a CMMI level
IEEE standards	Engineering practices and documentation	A shared professional baseline
Waterfall	Sequential, plan everything up front	Suits stable, well-known requirements
Agile / Scrum	Short iterations, continuous feedback	Suits changing requirements

The business point for Nepal: for Nepali outsourcing firms, **ISO or CMMI certification is a business requirement** to win Western contracts — foreign clients often will not sign without it. Standards make quality **repeatable**; certification makes it **sellable**.

> ⚠ **Common mistake:** "*Agile means no documentation and no standards.*" **Correction:** Agile changes **how** quality is built in — it does not remove the need for it. Agile teams still write tests, review code and document. "Move fast" is not "skip quality"; the best Agile teams are rigorous.

Risk management

Risk management is identifying, assessing and mitigating things that could cause failure.

> **The scoring rule: risk = likelihood × impact.**

You keep a **risk register** (a logged, ranked list), plan **mitigation** (reduce the risk) and **contingency or rollback** (what you do if it happens anyway), and let **safety-critical risks jump the queue** — their impact is catastrophic even at low likelihood.

Risk	Likelihood × impact	Mitigation and contingency
Core-system migration corrupts data	Low × Critical	Test on a copy; schedule off-peak; rollback ready
Festival-day traffic spike crashes the app	High × High	Load-test early; auto-scale; caching fallback
A third-party payment API goes down	Medium × High	Retry and queue; a secondary provider
A key developer leaves mid-project	Medium × High	Documentation; pairing; no single point of knowledge
A security defect ships to production	Low × Critical	Security review and pen-test gate before release

Timing is itself a mitigation: a Nepali bank **defers a risky core-system migration off peak festival and remittance days**, and prepares a **tested rollback** for a Nagarik App update before shipping it.

> ⚠ **Common mistake:** "*We'll deal with problems if they come up.*" **Correction:** risk management is deciding **what could fail before it does**. **Every high risk needs both a mitigation and a contingency.** Reacting after a live failure during the festival rush is exactly the expensive, dangerous position it exists to avoid.

4.5 Contingent workers

Contingent workers are hired on a non-permanent basis — contractors, temps, consultants, gig and freelance workers, and visa-based staff such as H-1B.

Why firms use them: flexibility (scale up and down fast), cost (pay only for what is needed) and scarce skills (buy rare expertise on demand).

Dimension	Permanent employee	Contingent worker
Job security	High — an ongoing role	Low — ends with the contract
Benefits and paid leave	Usually provided	Usually none
Pay rate	Steady salary	Often higher hourly, but no safety net
Loyalty and commitment	Higher	Lower — no long-term stake
Institutional knowledge	Retained	Walks out when the contract ends
Who carries the risk	Shared with the employer	**Mostly the worker**

> **That risk shift is the ethical heart of the topic: the flexibility the client enjoys is the insecurity the worker absorbs.**

Situation in Nepal	What the worker gains and loses
A Kathmandu developer on Upwork paid per project	Good hourly rate, zero job security

Situation in Nepal	What the worker gains and loses
A 3-month renewable contract with no benefits	Flexible, but no paid leave or insurance
A Fiverr freelancer whose client vanishes mid-job	Fast income, no protection if unpaid
A foreign firm's contractor with no onboarding invested	Rare-skill pay, little training
A consultant hired for a one-off migration	Scarce skill on demand; knowledge leaves with them
A gig developer juggling several small clients	Autonomy, but unstable monthly income

Globally, the **H-1B visa debate** in the US frames the same worker as both a bargain and a threat — accusations of undercutting local wages versus a genuine skills shortage.

> ⚠ **Common mistake:** "*Contractors are cheaper, so always use them.*" **Correction:** the hidden costs bite — lost institutional knowledge, lower commitment, constant re-hiring and onboarding, plus an **ethical duty to treat them fairly**. "Cheaper per hour" is not "cheaper overall", and it **externalises risk onto people**.

4.6 Outsourcing and offshore outsourcing

Outsourcing is contracting work to an outside firm; **offshoring** is doing so in another, often lower-cost, country.

Benefit	The matching risk
Lower cost	Quality control is harder at a distance
24/7 **follow-the-sun** work	Timezone and communication gaps
Access to global talent	**Data security and confidentiality across borders**
Scale up and down quickly	Dependency on one vendor or client
Jobs and foreign exchange for Nepal	Night shifts and burnout in BPOs

Nepal is an outsourcing destination — Kathmandu IT, BPO and KPO firms serving Western clients is the "IT export" story — and Nepali firms sometimes outsource pieces onward.

The sharpest risk is data. When a Western client offshores customer data to a Kathmandu BPO operating under weaker data-protection law, **the obligations travel with the data**. The client still owes its customers protection, and the Nepali firm inherits a duty to handle KYC and personal data as carefully as if it were local — **regardless of what the weaker local law strictly requires**.

> ⚠ **Common mistake:** "*Once we offshore it, the risk is the vendor's problem.*" **Correction: responsibility travels with the data.** If a Kathmandu BPO leaks a Western client's customer data, the client's name and liability are on the line too. **Outsourcing the work does not outsource the duty of care.**
>
> **The kitchen analogy.** Outsourcing is like hiring a kitchen across town to cook your restaurant's food — cheaper and scalable. But if hygiene slips there, **your** customers get sick and **your** name takes the blame. The distance saves money; it does not move the responsibility.

The ethical balance — who gains, who pays

Stakeholder	Benefit	Cost or harm
Offshore worker (Nepal)	High-value jobs, forex, skills	Night shifts, burnout, lower pay than the client's country
Home-country worker	Few	Job loss, downward wage pressure
Client / company	Lower cost, scale, 24/7 coverage	Quality and control risk, accountability gaps
End user	Cheaper products	Their data crosses borders; support quality varies
Developing economy	Growth, forex, an IT-export industry	Race-to-the-bottom wage pressure

> ⚠ **Common mistake:** "*Outsourcing is simply exploitation*" — **or** — "*outsourcing is simply opportunity.*" **Correction:** neither is the whole truth. A stakeholder analysis (Unit 1) shows it genuinely **helps some and harms others at once**. The ethical question is not "good or bad" but **"good for whom, at what cost, and is it fair?"**

4.7 Whistle-blowing

Whistle-blowing is an insider revealing wrongdoing — illegal, unethical or dangerous conduct — within an organisation. It takes two forms:

Question	Internal	External
Who do you tell?	Manager, ethics officer, internal audit	Regulator, press, or the public
When?	**First** — give the organisation a chance to fix it	When internal channels fail or are complicit
Risk to you	Lower, though retaliation is still possible	Higher — public exposure and legal risk
Is it disloyalty?	No — it protects the organisation too	No — it protects the public when the organisation will not

At its core is a clash: the duty of loyalty to your employer versus the duty to protect the public. This resolves the Unit 2 tension: **loyalty has a limit — it never requires covering up harm.** Whistle-blowing is a considered act to protect stakeholders, not an impulsive betrayal.

Defining global cases: **Edward Snowden** (NSA mass surveillance) and **Frances Haugen** (leaking internal Facebook/Meta research on known harms). Their very different receptions show how contested and personally costly the act is.

> ⚠ **Common mistake:** "*A whistle-blower is just a disloyal snitch.*" **Correction:** ethical whistle-blowing protects the public **precisely when internal channels have failed**. It is an act of responsibility, not betrayal.

The responsible process — order matters

Step	What you do	Why in this order
1. Get the facts	Gather evidence; keep dated records	Acting on suspicion alone can be wrong and unprovable
2. Weigh the harm	Confirm it is serious — illegal or dangerous	Whistle-blowing is for real harm, not minor gripes
3. Report internally	Manager, ethics officer, internal audit	Gives the organisation a chance to fix it, and builds your record
4. Escalate to a regulator	For example the **CIAA** or the relevant authority	When internal routes are ignored or complicit
5. Go public	Press or public — **last resort**	Highest risk; only when all else has failed

> **Following the order protects both the public and you.** A documented, internal-first attempt is what distinguishes a **responsible whistle-blower from a reckless leaker**.

Action on a "data is being sold" suspicion	Right or wrong?
Immediately tweet the accusation	**Wrong** — unprovable, legally risky, tips off the wrongdoer
Gather dated evidence and keep records	Right — step 1
Confirm the harm is serious, not a gripe	Right — step 2
Report to your manager, then ethics/compliance	Right — step 3
Escalate to the CIAA when ignored	Right — step 4
Go to the press only as a last resort	Right — step 5

Risks and protections

Risk to the whistle-blower	Protection that may help
Being fired or forced out	Whistle-blower laws and employment protections, where they exist

Risk to the whistle-blower	Protection that may help
Blacklisting in a small industry	Anonymous reporting hotlines
Lawsuits, for example defamation	Solid evidence plus legal advice beforehand
Retaliation from management	An independent regulator such as the CIAA
Severe personal stress	Support networks; a documented internal-first record

Nepal's protection is weaker — safeguards run mainly through **anti-corruption / CIAA mechanisms** — so a Nepali employee exposing wrongdoing faces real risk of firing and blacklisting, with a thinner legal net than a counterpart in the US or EU. In a small market, blacklisting is a genuine threat.

> ⚠ **Common mistake:** "*Whistle-blowers are always protected by law.*" **Correction:** protection is limited and varies hugely by country, and **in Nepal it is weak**. That does not make the act wrong — it makes **documentation, evidence and internal-first steps even more important**. Act with courage **and** care.
>
> **The smoke-alarm analogy.** A whistle-blower is the smoke alarm in a building — annoying when it goes off, but you are glad it exists when there is a real fire. **Nobody should rip it off the wall for beeping.**

4.8 Green computing

Green computing is designing, using and disposing of IT in environmentally responsible, energy-efficient ways. It covers the **full lifecycle — manufacture → use → disposal**.

Lifecycle stage	Environmental impact	The green response
Manufacture	Raw materials, water, energy, mining	Durable design; buy only what is needed
Use	Electricity for devices, servers, cooling	Efficient hardware, power management, renewables
Disposal	Toxic e-waste — lead, mercury, cadmium	Reduce, reuse, refurbish, recycle safely
Recycle / reuse	Closes the loop	Recover materials; refurbish for a second life

> ⚠ **Common mistake:** "*Software has no environmental footprint — it's in the cloud.*" **Correction: the cloud is physical data centres burning real electricity and water somewhere.** "Digital" **relocates** the footprint; it does not remove it.

Nepal's genuine opportunity: data centres powered by **clean hydro-electricity** could be a real "green data centre" selling point for attracting international clients. **But the gain is erased if diesel generators kick in during load-shedding** — which shows green computing must be measured across the real, full lifecycle, not claimed on paper.

Cutting energy use

Measure	How it saves energy	Example
Efficient hardware	Less power per unit of work	ENERGY STAR / EPEAT-rated devices
Virtualization / consolidation	Fewer physical servers running	10 VMs on 1 server instead of 10 boxes
Power management	No power wasted on idle machines	Auto-sleep and shutdown of overnight desktops
Efficient code	Less compute per task	Optimising a hot query at data-centre scale
Renewable energy	Cleaner power for the same use	A hydro-powered data centre
Cooling efficiency	Less energy spent removing heat	Better airflow and free-cooling design

> ⚠ **Common mistake:** "*One office's computers can't matter to the environment.*" **Correction:** at scale, **defaults matter enormously**. Fifty desktops left on overnight "for convenience", multiplied across every office, is real power and real emissions. As the IT decision-maker, **your default settings shape the whole organisation's energy footprint.**

E-waste and responsible disposal

E-waste is discarded electronics containing toxic materials — lead, mercury, cadmium — that harm health and the environment when dumped or burned.

> **The ladder is ordered: reduce → reuse → refurbish → recycle**, plus safe disposal, **extended producer responsibility** (makers take back end-of-life devices) and **wiping data before disposal**.

Item	Why it is hazardous	Responsible handling
Old laptop or phone battery	Lead, cadmium, lithium — toxic and a fire risk	Reuse or refurbish; recycle via a proper handler
CRT or old monitor	Contains lead	Never bin or burn; use a dedicated recycler
Circuit boards	Mercury, heavy metals	Specialist recycling to recover materials
Any device holding your data	A data-privacy risk on disposal	**Wipe or destroy the data first**
A still-working old PC	Wasted embodied energy if binned	Donate or refurbish for a second life
An imported second-hand device near end of life	Becomes local junk fast	Reduce imports; plan for disposal

In Nepal, e-waste accumulates in Kathmandu with little formal recycling. Informal dumping and burning in the valley releases lead, mercury and cadmium into soil and air, and imported second-hand electronics quickly become junk. **With weak e-waste regulation, responsible disposal falls heavily on organisations and individuals doing the right thing voluntarily.**

Green computing as corporate responsibility

This closes the loop back to Unit 1: **managing the IT footprint IS corporate social responsibility.**

Measure	What it does	Nepal example
Green procurement policy	Buy efficient, certified hardware **by default**	Government and bank IT tenders favouring efficient devices
Take-back / recycling programme	Responsible end-of-life for devices	Telecoms' device take-back schemes
Sustainability reporting	Public accountability for the footprint	Reporting energy and e-waste within CSR
Telecommuting	Cuts commuting emissions	Remote and hybrid work
Cloud right-sizing	No paying for or powering idle capacity	Scaling servers to actual demand
Renewable-powered facilities	Cleaner energy for operations	Solar or hydro-powered data centres

Action	Real green IT or greenwashing?
A bank adopts a solar-powered data centre	**Real** — embedded in operations
A telecom runs a device take-back scheme	**Real** — policy-level
One tree-planting photo opportunity, nothing changes	**Greenwashing**
A government IT tender favours efficient hardware	**Real** — green procurement as default policy
Publishing energy and e-waste figures in a CSR report	**Real** — accountability you cannot walk back
An "eco-friendly" label while servers stay over-provisioned	**Greenwashing**

> **The same genuine-versus-greenwashing test as Unit 1:** real green IT is **embedded in operations and reported publicly**, not a one-off gesture.

Key words from Unit 4

Software quality · conformance to requirements · fitness for use · functional and non-functional quality · correctness · reliability · usability · security · maintainability · performance · cost of poor quality · the 10× rule · hidden costs · safety-critical software · Therac-25 · Boeing 737 MAX MCAS · Ariane 5 · testing · unit/integration/system/acceptance (UAT) · regression testing · black-box vs white-box · continuous integration · QA vs QC · proactive vs reactive · ISO 9001 · ISO/IEC 25010 · CMMI · IEEE standards · Waterfall · Agile/Scrum · risk management · risk register · likelihood × impact · mitigation · contingency/rollback · contingent worker · H-1B debate · gig and freelance work · risk shift · outsourcing · offshoring ·

follow-the-sun · cross-border data · duty of care travels with the data · stakeholder analysis · whistle-blowing · internal vs external · CIAA · retaliation · blacklisting · green computing · IT lifecycle · ENERGY STAR / EPEAT · virtualization · power management · e-waste · reduce–reuse–refurbish–recycle · extended producer responsibility · green procurement · sustainability reporting · greenwashing.

Summary — Unit 4

- **Quality = conformance to requirements + fitness for real use.** "Passed the demo" is not quality; production is where quality is judged.
- The **cost of a defect rises roughly 10× per later stage**, and the hidden costs — trust, churn, liability — dwarf the visible patch. **Prevention beats cure.**
- **Safety-critical software** can kill, so the rigour must be proportional to the stakes — Therac-25, 737 MAX and Ariane 5 are the standard cautionary cases.
- Quality is produced by **layered testing**, by **QA (prevent) plus QC (catch)**, by **standards** (ISO, CMMI — a business requirement for Nepali outsourcing), and by **risk management** scored as likelihood × impact with both a mitigation and a rollback.
- **Contingent work** trades the worker's security for the firm's flexibility and **shifts risk onto the worker**; "cheaper per hour" is not cheaper overall.
- **Offshore outsourcing** trades cost against control and data security. **The duty of care travels with the data** — outsourcing the work never outsources the responsibility. Judge it by stakeholder analysis, not slogans.
- **Whistle-blowing** is justified because loyalty has a limit, but must be done responsibly: evidence-first, internal-first, regulator next, public last. **Protection in Nepal is weak**, so the personal risk is real.
- **Green computing** spans manufacture, use and disposal. The cloud is physical; small defaults scale; e-waste needs the **reduce–reuse–refurbish–recycle** ladder with data wiped first — and it is genuine CSR only when embedded in policy and reported.

Unit 5 — Fundamentals of Cybersecurity

6 lecture hours. Introduction to cyberspace and cybersecurity · cybersecurity perspectives · key development areas and their impact: technological changes, economic model shifts and outsourcing · risks cybersecurity mitigates · common cyberattacks · poisoned web service attacks · network infrastructure poisoning · technical attack techniques · cyberattackers and their coloured hats.

> **Read this first.** Units 5 to 8 are **defensive and awareness** material. Every attack below is described **only so you can recognise it and defend against it**. There are **no exploit or attack-execution recipes** anywhere in these notes. The goal is to be able to name both **the trick and the defence**.

5.1 Cyberspace

Cyberspace is the interconnected digital environment of networks, systems, data, and the people and devices using them.

The key move: it is **not just "the internet" or "the websites I visit"**. It includes private and bank networks, the cloud, **OT/ICS** (the operational technology and industrial control software running a power grid or water plant), and mobile. Militaries treat it as the "**fifth domain**" of conflict, after land, sea, air and space.

Is this part of cyberspace?	Verdict	Why
The websites you browse	**Yes**	The visible surface — but only a slice
A bank's back-end customer database	**Yes**	Private systems count even if you never see them
NEA grid and billing control software (OT/ICS)	**Yes**	Operational technology is a critical, often-forgotten part
The Nagarik App on your phone	**Yes**	Mobile apps and their cloud back-ends
A smart CCTV or IoT sensor in an office	**Yes**	Connected devices are entry points
A paper land-record ledger in a cupboard	No	Not digital or connected — until it is digitised

Nepal's cyberspace is growing fast: the National ID system, eSewa and Khalti, the Nagarik App, online banking and e-governance portals — plus the NEA grid and billing software you never see.

> ⚠ **Common mistake:** "*Cyberspace = the websites I visit.*" **Correction:** protecting cyberspace means protecting the **plumbing you never see**, not just the pages on your screen.

5.2 Cybersecurity and its three pillars

Cybersecurity is the practice of protecting systems, networks and data from unauthorised access, harm or disruption. It is a **defensive discipline, not a product**, and it rests on three pillars.

Pillar	What it is	What fails without it
People	Trained, aware staff and users	A clerk shares an OTP → the account is drained despite good technology
Process	Policies, patching, backups, incident response, access rules	No patch schedule → a known flaw stays open for months
Technology	Firewalls, antivirus/EDR, MFA, encryption	No MFA → one stolen password gives full access

> **The rule: the weakest of the three pillars decides how secure you really are.**

In Nepal, NPCERT (the national Computer Emergency Response Team) coordinates incident response, and banks run dedicated security teams under **NRB cyber-resilience guidance**.

> ⚠ **Common mistake:** "*Cybersecurity just means installing antivirus.*" **Correction:** antivirus is one piece of the **technology** pillar. Antivirus alone cannot save you from an untrained clerk (people) or a missing patch policy (process).

5.3 The CIA triad

This is **the most important vocabulary in the whole course.** The **CIA triad** is the three goals every security control serves.

	Confidentiality (C)	Integrity (I)	Availability (A)
Goal	Keep data secret	Keep data correct and trusted	Keep the service usable
Broken when…	Data is leaked or read	Data is secretly altered	The service is knocked offline
Typical control	Encryption, access control	Hashing, audit logs, checks	Backups, redundancy, capacity
Nepal example	An eSewa/KYC database leaks	Land-record data is altered	E-banking down in a DDoS
Attack that hits it	Data theft, spyware	Tampering, defacement	DoS, ransomware lockout

Incident	CIA goal violated
Ransomware locks a hospital's files	**Availability**
A leaked eSewa/KYC customer database	**Confidentiality**
An exam result changed on a college portal	**Integrity**
DDoS takes a bank's e-banking offline	**Availability**
Land-record values quietly altered	**Integrity**
Spyware silently copies your messages	**Confidentiality**
Ransomware that also steals data first	**Confidentiality + Availability** — two legs at once

> **The three-legged stool.** Saw off any leg and you fall over. There are also **trade-offs**: locking a system down hard (C) can hurt Availability. Security is a balance of all three.
>
> ⚠ **Common mistake:** "*Security just means keeping secrets.*" **Correction:** a system that is **always down or easily tampered with is insecure even if nothing ever leaks.**

5.4 What keeps reshaping the threat landscape

Technological change grows the attack surface

The attack surface is the sum of all the points where an attacker could try to get in. Every new technology — cloud, mobile, IoT, AI, remote work — adds new devices, data and entry points.

> **The crucial lag: new features usually arrive before their security does.**

New technology adopted	The entry point it adds	The defence to add *with* it
QR payments (FonePay) at a shop	Fake QR / payment-redirect risk	Verify the payee name; train staff; reconcile daily
Customer data moved to the cloud	Data now reachable over the internet	Access control, encryption, MFA on the console
Smart CCTV / IoT in the office	Cheap devices with weak defaults	Change defaults; put them on their own network; patch
Staff use personal phones for work	A lost phone becomes a data leak	Screen lock, remote wipe, separate work data
Remote / work-from-home setup	Home Wi-Fi and PCs you do not control	VPN, endpoint protection, secure configuration policy
An AI chatbot handling queries	New data flows and prompt-abuse risk	Limit the data it sees; monitor; validate outputs

Globally: billions of IoT devices shipped with **weak default passwords** became botnet fuel — the **Mirai botnet** powered massive DDoS attacks.

> ⚠ **Common mistake:** "*New technology is automatically more secure.*" **Correction:** usually the opposite. **Adopt a technology, add its defence in the same breath.**

Economic model shifts — cybercrime as a business

Dimension	~2010 attacker	Today's attacker
Skill needed	High — had to build the tools	**Low — rents ready-made kits**
Where data lives	On-premise servers	Cloud and SaaS platforms — a new target
Business model	A lone hobbyist or vandal	Organised gangs, some with "customer support" desks
What is for sale	Little	**Stolen cards, credentials and KYC in bulk**
Nepal impact	Rare, opportunistic	Pre-packaged phishing kits aimed at Nepali users

Three shifts drive this: **SaaS and cloud** move data onto third-party platforms you do not own; **Cybercrime-as-a-Service / Ransomware-as-a-Service (RaaS)** lets low-skill criminals **rent** ready-made attack tools; and **data itself becomes a commodity**.

> ⚠ **Common mistake:** "*Only a genius hacker could attack us, and we're too small to bother with.*" **Correction:** rented kits mean a low-skill criminal can run a powerful attack cheaply and at scale. **Small, local targets are attacked precisely because they are easy and numerous.**

Outsourcing and supply-chain risk

Relying on third-party vendors introduces THEIR risk into YOUR system. Third-party access, shared credentials and managed services **extend your trust boundary outside your own walls** — and the chain is deep: you trust your vendor, *and* your vendor's sub-vendors.

Outsourcing scenario	The risk inherited	The control
A bank outsources app development	The vendor's insecure code ships into the bank	Security requirements in the contract; code review
Government hosts a portal with a third party	The host's breach exposes citizen data	Data-protection clauses, audits, encryption
A vendor gets remote access to maintain a system	A stolen vendor credential becomes access to you	Least privilege, MFA, time-limited access, logging
A shared admin password is given to a contractor	No accountability if it leaks	Unique named accounts; revoke on exit
A managed SaaS service holds your data	You depend on their uptime and security	Review certifications; keep a backup you control
The vendor uses its own sub-vendor	Risk you cannot even see	Require vendors to vet their sub-vendors

> **The rule: you outsource the WORK, but you keep the ACCOUNTABILITY.** A vendor's carelessness is your customers' breach — which echoes the Unit 4 ethics point exactly.

5.5 Risk: threat, vulnerability, asset

Term	What it is	Everyday analogy	IT example
Threat	Something that **could** cause harm	A flood	A worm; a phishing campaign
Vulnerability	A **weakness** it can exploit	Living in a basement	An unpatched government web server
Asset	What has **value** and is protected	Your belongings	Citizen data; eSewa balances
Threat actor	Who is behind the threat	The storm or a burglar	A criminal gang; an insider

Term	What it is	Everyday analogy	IT example
Exploit	The threat actually using the weakness	Water entering the basement	The worm compromising the server

The chain: a threat actor plus a threat **exploits a vulnerability to harm an asset**. The key consequence: **with no vulnerability, the threat has nothing to land on** — which is exactly what patching achieves.

> ⚠ **Common mistake:** "*Threat and vulnerability are the same thing.*" **Correction:** a **flood is a threat**; **living in a basement is the vulnerability**; your **belongings are the asset**. You usually cannot remove the threat — but you **can** remove the vulnerability.

The risk formula

> ## Risk = Threat × Vulnerability × Impact

The crucial property: you multiply, you do not add. If any factor is near zero, the risk is low.

- High threat + zero vulnerability ≈ **low risk** — nothing to exploit.
- Small vulnerability + catastrophic impact ≈ **high risk** — worth fixing first.

Scenario	Threat × Vulnerability × Impact	Risk
An offline laptop of wedding photos, malware about	High × Low × Low	**Low**
An online bank customer database, same malware	High × Medium × **Critical**	**High**
A defaced public webpage, no data lost	High × Medium × Low	Medium
Leaked student grades on a portal	Medium × Medium × High	**High**
A wiped payroll database with no backup	Low × Medium × **Critical**	**High**
An old test server with no real data	Medium × High × Low	Low

This is exactly how professionals prioritise a limited defence budget. Framing the **NIC ASIA SWIFT fraud** incident as high-impact explains why financial systems get the most defence budget — the impact factor is enormous even when likelihood is low.

> ⚠ **Common mistake:** "*The threat we hear about most is the one to fix first.*" **Correction: fear ranks by headlines; professionals rank by likelihood × impact.** A loud but low-impact threat can rank below a quiet one with catastrophic impact.

What cybersecurity actually achieves

Cybersecurity reduces risk to an ACCEPTABLE level, not to zero. You attack the formula from three sides, and whatever remains is **residual risk** — the leftover you consciously accept.

Control	Which factor it reduces	Effect
Patching software promptly	**Vulnerability**	Removes the weakness the threat needs
MFA on accounts	**Vulnerability**	A stolen password alone is no longer enough
Tested backups	**Impact**	Ransomware or a wipe hurts far less
Network segmentation	**Impact**	A breach is contained to one segment
Not exposing a service to the internet	**Threat exposure**	Fewer attackers can even reach it
Staff phishing training	**Vulnerability** (human)	Fewer people click the lure
Encryption of stored data	**Impact**	A stolen database is unreadable to the thief

> ⚠ **Common mistake:** "*Good security means zero risk.*" **Correction:** zero risk is impossible. Chasing it wastes budget and creates false confidence. You cannot make crossing the road risk-free — but a zebra crossing plus looking both ways makes the risk **acceptable**.

5.6 Common cyberattacks

Malware

Malware is malicious software. Each type behaves differently, but **the defences overlap**.

Type	How it behaves	Warning sign	Key defence
Virus	Attaches to a file; runs when opened	Files corrupted; odd errors	Antivirus; do not open unknown files
Worm	**Self-spreads** across the network	Network slow; devices infected fast	Patch promptly; segment the network
Trojan	Hides inside trusted-looking software	Unexpected behaviour after install	Install only from trusted sources
Ransomware	Encrypts files and demands payment	Files locked; a ransom note	**Tested offline backups**; patch; least privilege
Spyware	Silently watches and steals data	Battery and data drain; strange activity	Anti-malware; app-permission hygiene
Adware / PUP	Floods pop-ups, bundles junk	Constant ads; new toolbars	Careful installs; avoid pirated software

Globally: **WannaCry** spread worldwide through a **single unpatched Windows flaw** — a worm and ransomware combined. *In Nepal:* ransomware has hit businesses and government offices, and **pirated or cracked software is a common infection route** — the "free" download carries the trojan.

> ⚠ **Common mistake:** "*Antivirus alone keeps me safe.*" **Correction:** antivirus is **one layer**. Updates, tested backups, least privilege and careful clicks matter just as much — and **pirated software often *is* the malware**.

Phishing

Phishing tricks a PERSON into giving credentials, money or clicks via fake messages. Because it targets people rather than machines, **no firewall fully stops it**.

The signs: manufactured **urgency**, **mismatched or look-alike links**, and requests for **OTP or PIN**. **The defences: verify out-of-band**, **never share an OTP**, use **MFA**, and **report**.

Lure seen in Nepal	The red flag	What to do
"Your eSewa / IME is blocked — verify here"	Urgency plus a link asking you to log in	Do not click; open the app yourself; report
"You won a Khalti reward — claim now"	A too-good offer plus urgency	Ignore; verify in the official app only
A fake bank-KYC SMS asking for an OTP or PIN	**Any** request for an OTP or PIN	Never share it — banks never ask
"Nepal Police / IRD fine — pay via this link"	A threat plus an unofficial payment link	Verify through official channels
A look-alike bank URL, subtly misspelled	The domain is slightly wrong (e.g. `rn` for `m`)	Type the address yourself
An email "from the principal" wanting gift cards	Urgent, unusual request, odd sender	Verify by phone or in person

Spear-phishing is targeted, researched phishing aimed at one person.

> ⚠ **Common mistake:** "*Only careless people fall for phishing.*" **Correction:** well-crafted spear-phishing **fools experts and executives too**. The defence is not "be smart" — it is a **habit**: pause on urgency, verify out-of-band, never share an OTP, and enable MFA so a stolen password alone fails.

Denial of service (DoS and DDoS)

A denial-of-service attack overwhelms a service with traffic so legitimate users cannot reach it. It attacks **Availability**. A **DDoS** is *distributed* — the flood comes from **many machines, often a botnet**, so you cannot simply block one address.

Defences: rate-limiting, CDNs and traffic-scrubbing services, spare capacity, and **coordinating with your ISP and NPCERT** during a sustained attack — you cannot absorb a large flood alone.

In Nepal: bank and government portals have been knocked offline during hacktivist campaigns. Nothing is stolen or altered, but nobody can use the service — which is still a real harm when a bank is offline during a festival.

Poisoned web services

A poisoned web-service attack turns a trusted website or service into a delivery vehicle — drive-by downloads, malvertising, defacement, or injected malicious content. **The unsettling point: a familiar, HTTPS site can be compromised.**

Sign you see	What it likely is	The defence
A government website shows an attacker's message	**Defacement** (an Integrity hit)	Patching, input validation, WAF, monitoring
A trusted site suddenly pushes a download	A drive-by from a compromised site	Keep browser and OS updated; do not run it
Ads on a normal site trigger scary pop-ups	**Malvertising**	Ad and script hygiene; ignore the pop-up
A cloned bank login on a look-alike URL	Fake login for credential theft	Check the domain and certificate; type the address
A padlock is shown but the site feels wrong	**HTTPS ≠ trustworthy**	The padlock means encrypted only
A form input causes odd server behaviour	Possible injection	Site owner: validate and sanitise input; patch

> ⚠ **Common mistake:** "*A familiar or HTTPS site is always safe.*" **Correction:** trusted sites can be compromised, and **the padlock only means the connection is encrypted — not that the site is genuine.** A cloned phishing site can show a padlock too.

The attack-to-defence map

Attack family	CIA goal it mainly hits	Core defence
Malware / ransomware	Availability (+ Confidentiality)	Patch, EDR, least privilege, tested backups
Phishing	Confidentiality — stolen credentials	Verify out-of-band, MFA, training, report
DoS / DDoS	Availability	Rate-limiting, CDN/scrubbing, capacity, ISP and NPCERT
Poisoned or defaced website	Integrity (+ Availability)	Patching, input validation, WAF, monitoring
Data theft / spyware	Confidentiality	Encryption, access control, anti-malware
Tampering with records	Integrity	Hashing, audit logs, backups, access control

5.7 Network infrastructure poisoning

Man-in-the-middle (MITM)

In a man-in-the-middle attack, an attacker secretly sits between two parties and can READ or ALTER what passes. Because it can both eavesdrop and tamper, MITM breaks **Confidentiality AND Integrity**. The classic setting is an untrusted or public Wi-Fi network.

The universal defence is encryption: HTTPS/TLS and a VPN, plus **taking certificate warnings seriously**.

In Nepal: open Wi-Fi at Kathmandu cafés, the airport and campuses is a real MITM risk for anyone checking e-banking.

> ⚠ **Common mistake:** "*Public Wi-Fi is fine if it has a password posted on the wall.*" **Correction:** a shared, known password protects little against someone **already on the same network**. The real protection is end-to-end encryption.

ARP poisoning

ARP poisoning tricks devices on a LOCAL network into sending their traffic to the attacker by faking hardware-address mappings. The root problem is that **the local network trusts ARP answers blindly**. This enables MITM on a LAN.

Defences: network **segmentation**, **dynamic ARP inspection (DAI)**, encrypted traffic, and monitoring. Crucially — **even on a poisoned LAN, HTTPS and VPN keep the diverted traffic unreadable.** The attacker sees only encrypted, useless traffic.

DNS poisoning

DNS poisoning corrupts the "phonebook" that turns a domain name into an address, so a correct-looking name leads to a **fake server**. Forged or cached DNS answers send users to look-alike sites.

The sign you see	What is happening	The safe response
The right name, but a **certificate warning**	You were sent to a fake server	**Stop. Do not proceed.**
A bank login looks slightly "off"	A cloned site via poisoned DNS	Close it; type the address; use the app
Redirected somewhere unexpected	A forged or cached DNS answer	Use a trusted resolver; check the HTTPS certificate
No padlock, or an invalid certificate	The fake server cannot prove the name	**Never enter credentials**
A different result on mobile data versus Wi-Fi	One resolver may be poisoned	Compare; report to IT or NPCERT
Organisation-wide users hitting a fake site	Cache poisoning at the resolver	DNSSEC and a secure resolver

> ⚠ **Common mistake:** "*If the address bar shows the right name, the site must be real.*" **Correction:** poisoned DNS can show the **right name while pointing at a fake server**. The reliable tell is **the certificate** — a fake server cannot present a valid one, so **a certificate warning means STOP**.
>
> **The directory analogy.** DNS poisoning is tampering with the phone directory so the right name lists the wrong number.

Why infrastructure attacks are dangerous — and the one defence set

These attacks are dangerous because they are **silent, hit many users at once, and operate below the application layer** — the app looks normal while the traffic beneath is compromised.

The good news: **one small set of universal user defences works across all of them.**

Universal defence	Why it works	Covers
Use **HTTPS/TLS** everywhere	Encrypted traffic cannot be read or altered	MITM, ARP, DNS (partly)
Use a **VPN** on untrusted Wi-Fi	Wraps all traffic in encryption	MITM, ARP, rogue hotspot
Heed certificate warnings	The tell that you are on a fake or relayed path	DNS poisoning, MITM
Avoid sensitive logins on public Wi-Fi	Removes the exposure entirely	MITM, rogue hotspot
Keep the device and browser updated	Closes the flaws these attacks lean on	All
Owners: DNSSEC, DAI, segmentation, monitoring	Fixes it at the infrastructure level	DNS, ARP, MITM

> **The unifying lesson: three different plumbing attacks, one repeated user defence — encryption plus heeding warnings.**

5.8 Cyberattackers and their coloured hats

Hackers are classified by INTENT and AUTHORISATION, not by skill. The same technical ability sits behind all three hats.

Dimension	White hat	Grey hat	Black hat
Authorised?	**Yes** — invited	No	No
Intent	Improve security	Mixed or curious	Malicious, criminal

Dimension	White hat	Grey hat	Black hat
Legal?	**Legal**	**Illegal** — no permission	**Illegal**
Typical activity	Penetration test, bug bounty	Unrequested probing, then reporting	Fraud, ransomware, theft
Nepal example	Responsibly reports a bank flaw	Finds a government flaw uninvited	Defaces sites or steals data

⚠ **Common mistake:** "*All hackers are criminals.*" **Correction:** the hat is about **authorisation plus intent, not skill** — many hackers are **paid defenders**. A grey hat may mean well but is **still acting illegally**; good intentions do not make it authorised.

Attacker types by motive

Attacker type	Motive	Typical target	Key defence
Script kiddie	Thrills, notoriety	Easy, exposed systems	Patching, basic hygiene, MFA
Hacktivist	A political or social message	Public government and high-profile sites	DDoS defence, patching, monitoring
Cybercriminal / organ-ised crime	Money	Banks, wallets, personal data	Fraud controls, backups, MFA, monitoring
State / nation-state (APT)	Espionage, sabotage, strategic advantage	Government, critical infrastructure	Defence-in-depth, threat intelli-gence, segmentation
Insider — malicious	Revenge, profit	Their own employer's data	Least privilege, logging, separation of duties
Insider — negligent	None — simple carelessness	Accidental exposure	Training, access reviews

APT stands for *advanced persistent threat* — well-resourced attackers who stay in a system over long periods.

In Nepal: hacktivist defacements of government sites during regional tensions; financially motivated fraud of the NIC ASIA SWIFT type; and insider misuse of access.

⚠ **Common mistake:** "*The biggest threat is always an outside genius hacker.*" **Correction:** in reality, **insiders and simple phishing cause a large share of real damage**, and much crime uses rented, unsophisticated tools. Ranking attackers by their Hollywood image rather than by **motive and likelihood** misdirects your defences.

Why classification matters for defence

Motive predicts target, method and persistence — so knowing who you face shapes your priorities.

Organisation	Top attackers to fear	Defence priority
A commercial bank	Organised crime + insiders	Fraud controls, least privilege, monitoring, MFA
A government ministry	State actors + hacktivists	Defence-in-depth, DDoS defence, threat intelligence
A college campus	Script kiddies + phishing	Patching, MFA, awareness training
A fintech or wallet	Cybercriminals + insiders	Fraud detection, separation of duties, backups
A hospital	Ransomware crews	Tested backups, segmentation, patching
A telecom or ISP	State actors + DDoS crews	Infrastructure hardening, scrubbing, monitoring

⚠ **Common mistake:** "*Just buy a firewall and you're safe from everyone.*" **Correction:** a firewall stops outside network attacks but does little against an **insider who already has access** or a **user tricked by phishing**. Insiders need **trust and monitoring controls** — least privilege, logging, separation of duties — because they are already inside.

Key words from Unit 5

Cyberspace · fifth domain · OT/ICS · cybersecurity · people, process, technology · weakest pillar · NPCERT · CIA triad · confidentiality · integrity · availability · attack surface · Mirai botnet · cybercrime-as-a-service · Ransomware-as-a-Service (RaaS) · supply-chain risk · trust boundary · threat · vulnerability · asset · threat actor · exploit · risk = threat × vulnerability

× impact · residual risk · malware · virus · worm · trojan · ransomware · spyware · adware/PUP · WannaCry · least privilege · EDR · phishing · spear-phishing · out-of-band verification · MFA · OTP · DoS · DDoS · botnet · rate-limiting · CDN / traffic scrubbing · poisoned web service · drive-by download · malvertising · defacement · WAF · input validation · man-in-the-middle · ARP poisoning · dynamic ARP inspection · DNS poisoning · DNSSEC · certificate warning · rogue hotspot · white/grey/black hat · script kiddie · hacktivist · cybercriminal · nation-state actor / APT · malicious and negligent insider · defence-in-depth · separation of duties.

Summary — Unit 5

- **Cyberspace** is the whole connected digital domain, including the back-end plumbing and OT/ICS, not just the websites you visit.
- **Cybersecurity = people + process + technology**, and the **weakest pillar** decides your real security.
- The **CIA triad** — Confidentiality, Integrity, Availability — is the goal every control serves, and every attack breaks at least one leg.
- The landscape keeps shifting because **new technology grows the attack surface**, **cybercrime became a rentable business (RaaS)**, and **outsourcing extends your trust boundary** — you outsource the work, never the accountability.
- **Risk = threat × vulnerability × impact.** The factors **multiply**, so a near-zero factor means low risk. Security reduces risk to **acceptable, never zero**; what is left is **residual risk**.
- **Malware** is beaten by layered defence; **phishing** targets people so the defence is behavioural; **DoS** attacks Availability; and **poisoned or HTTPS sites can still be malicious** — the padlock means encrypted, not safe.
- **MITM, ARP poisoning and DNS poisoning** attack the network's plumbing silently. **One universal user defence set covers all three: encryption plus heeding certificate warnings.**
- **Hats are about authorisation and intent, not skill.** Attackers range from script kiddies to hacktivists, criminals, state actors and insiders — and **motive predicts the defence you need**.

Unit 6 — Personal Cybersecurity

5 lecture hours. Evaluating your current cybersecurity posture: home computer, mobile devices, Internet of Things (IoT) devices · enhancing physical security · cybersecurity considerations when working from home · securing your accounts · passwords.

6.1 Your security posture

Your security posture is the overall state of how well your device and habits resist AND recover from threats. Think of it as four layers:

> ### Patch → Protect → Back up → Contain

Layer	What it does	If you skip it
Patch	Closes known holes attackers already exploit	An unpatched laptop caught by an automated worm
Protect	Antivirus and firewall block malware and bad traffic	A "PC cleaner" pop-up installs the very malware it claims to remove
Back up	Recoverable copies survive ransomware and theft	Thesis files gone when a stolen laptop held the only copy
Contain	Limits the damage when one layer fails	One phished password unlocks everything

The risk frame: low-effort automated attacks are **very likely**, and the impact on a single laptop is **your whole digital life** — photos, college files, banking sessions. A good posture **assumes something will fail** and makes sure you can recover.

> ⚠ **Common mistake:** "*Hackers only target big companies, not me.*" **Correction:** most attacks are **automated and untargeted**. They scan the internet and hit whoever is unpatched and un-backed-up — student or bank alike. **You do not have to be interesting to be a victim; you only have to be reachable and unprotected.** *WannaCry (2017)* spread mostly to unpatched Windows machines that nobody chose.

6.2 Updates and patching

A patch fixes a known security hole that attackers already know about. Once a patch is public, **the hole it fixes is public too** — so unpatched machines become easy, known targets.

The habit: turn on **automatic updates** for the OS, browser and apps. **The trap: end-of-life software** (such as Windows 7) **never gets fixed again** — every hole found after that stays open forever.

Habit	Verdict	Why
Auto-updates ON for Windows and Chrome	**Safe**	Holes close before attackers arrive
"Remind me later" clicked for weeks	Weak	Every known hole stays open the whole time
Pirated or cracked Windows that cannot update	**Dangerous**	No safe patches, and the crack often carries malware
Still running Windows 7 or an old Android	**Dangerous**	End-of-life: new holes are never fixed
Ignoring app updates as "just new features"	Weak	Most updates are security fixes
Updating the OS but never the router firmware	Weak	**The router is a computer too**

> ⚠ **Common mistake:** "*Updates are just annoying new features I can skip.*" **Correction:** most updates are **security fixes** — "skip" means "stay exposed". And pirated software is the worst case in Nepal: it usually **cannot patch safely AND arrives with malware**.

6.3 Antivirus and anti-malware

Antivirus is software that detects and blocks malicious files and behaviour. For most home users **Windows Defender is built in, free and fine.**

It works through **real-time scanning** (as files arrive) plus **on-demand scans**, and combines **signature detection** (known malware) with **behaviour detection** (new threats acting suspiciously).

Situation	Verdict	The tell
Windows Defender on and updated	**Safe**	One good real-time AV is enough
Pop-up: "Your PC has 5 viruses — pay to fix!"	**Scam / malware**	Unsolicited + urgency + pay-now
A free "PC cleaner" from a random pop-up	**Dangerous**	Installs the threat it claims to remove
Installing three antiviruses "to be extra safe"	Weak	They conflict and slow the machine
A cracked "premium" AV from a torrent	**Dangerous**	Cracks commonly carry trojans
Ignoring AV alerts to keep working	Weak	Dismisses the one warning you got

> **The strongest tell of fake antivirus (scareware): it found *you* — a pop-up — then rushes you and asks for money. Real protection is quiet and already installed.**
>
> ⚠ **Common mistake:** "*I need three antiviruses to be really safe.*" **Correction: one good, updated antivirus is enough.** Multiple real-time scanners conflict, slow the machine and can miss threats while fighting each other.

6.4 Backups — the 3-2-1 rule

A backup is a recoverable copy of your important data.

> ### 3 copies · on 2 different media types · with 1 kept offsite or in the cloud — plus a tested restore

Element	What it protects against	Nepal example
3 copies	Any single copy being lost or corrupted	A file deleted, or a drive that silently corrupts it
2 media types	One type of hardware failing	A cheap external drive that dies after a year
1 offsite / cloud	Theft, fire, a whole-room disaster	A laptop snatched in a tempo — the cloud copy survives
A tested restore	A backup that turns out to be broken	Discovering on thesis day that the backup was empty

Load-shedding surges and cheap drives fail often in Nepal, and a stolen laptop takes everything with it. **The offsite or cloud copy is what survives all three.**

> ⚠ **Common mistake:** "*Having the files on my laptop is basically a backup.*" **Correction: one copy on one device is zero backups.** Theft, ransomware or a dead disk wipes it out at once. And **a backup you have never test-restored is a hope, not a backup.**

6.5 Firewalls

A firewall is a filter that controls which network traffic is allowed in and out. You normally have two: a **host firewall** on your operating system (protects one device) and a **router firewall** at your home gateway (protects the whole home).

The safe default is "deny incoming by default" — unrequested connections are blocked unless you allow them — and **do not blindly click "Allow"** on every prompt.

Prompt or situation	The right move
Windows Defender Firewall is on by default	**Keep it on**
An unknown app asks to accept incoming connections	**Deny** — if you did not expect it
A known game or app needs a port to play online	Allow **that app** narrowly
A pop-up says "disable firewall to speed up your PC"	**Ignore** — no legitimate fix requires this

Prompt or situation	The right move
The router admin panel is on its default password	**Change it** — an open gateway firewall is no firewall

> ⚠ **Common mistake:** "*A firewall makes me unhackable.*" **Correction:** it is **one wall, not the whole castle.** A firewall blocks unrequested connections, but it cannot stop malware you download, a phishing site you log into, or a scam call that talks you out of your OTP.

6.6 Mobile devices

App permissions

A permission is the access an app requests — camera, microphone, location, SMS, contacts, storage. The principle is **least privilege: grant only what the app's actual function needs.**

Prefer "**while using the app**" over "**always**", review and revoke in **Settings → Apps → Permissions**, and **match the permission to the function**.

The app asks for…	Reasonable?	Why
A torch app → SMS + contacts + location	**No**	A flashlight needs none of these
A map app → location while using	Yes	Core to its function, and time-limited
A fake "loan" app → SMS + contacts	**No**	**Reads your OTPs and harasses your contacts for "repayment"**
A camera app → camera + microphone	Yes	Needed to record video with sound
A cloned "eSewa" app → SMS + accessibility	**No**	Steals OTPs and can control the screen
A game → contacts + call logs	**No**	Unrelated to gameplay

In Nepal, fake and cloned "loan" and wallet apps demand SMS access precisely to read your OTP messages. The permission request *is* the attack.

> ⚠ **Common mistake:** "*If it's on the Play Store, it must be safe.*" **Correction:** malicious and cloned apps slip through store review regularly. Check the **developer name, review quality and install count** — and above all **judge the permissions**.

Securing the phone itself

Your phone is a computer holding your money, identity and OTPs. Secure it like one.

Habit	Verdict	Why
Biometric lock plus a 30-second auto-lock	**Strong**	A lost phone stays locked
No lock "because it's faster"	Weak	Anyone who grabs it owns your accounts and OTPs
Installing a "Dashain offer" APK from Messenger	**Dangerous**	Banking trojans arrive exactly this way
Apps only from the official store	**Strong**	Far lower chance of malware
A cheap phone that stopped updating a year ago	Weak	Unpatched holes never close
"Find My Device" and remote wipe enabled	**Strong**	Locate or erase a lost phone remotely

> ⚠ **Common mistake:** "*iPhones can't get hacked.*" **Correction: less common is not immune.** Phishing, account theft and malicious profiles hit any platform. Security is about your **habits**, not a brand badge.

Mobile banking and wallet safety

Mobile money is a top target in Nepal.

> **The rule to memorise: eSewa, Khalti and banks NEVER ask for your OTP or MPIN.**

Scenario	The red flag	The correct response
A call: "I'm from eSewa, read me the OTP to reverse a wrong transfer"	Asks for an OTP + urgency	**Refuse and hang up**
SMS: "Verify your Khalti account now or it's blocked"	A threat plus an unknown link	Do not click; open the app directly
The caller already knows your name and number	It feels legitimate	**Knowing your name is not proof** — still refuse
A site `esewa-rewards.com` asks you to log in	A lookalike domain	Only trust `esewa.com.np` or the official app
Your number suddenly loses signal and OTPs stop	Possible **SIM-swap**	Contact your telecom and bank immediately
A login saved on a cyber-café PC	A shared device	Log out; never save credentials there

SIM-swap means an attacker ports your number onto their SIM so they receive your OTPs.

> **The scam to recognise:** "*Tell me the OTP to reverse a wrong transfer.*" Sharing the OTP **reverses nothing** — it **authorises THEIR transfer** out of your wallet.

Internet of Things (IoT)

IoT devices are everyday things with internet connectivity — IP and CCTV cameras, smart bulbs, smart TVs, routers, smartwatches.

Weakness	Why it is dangerous	The fix
Default password (admin/admin)	Anyone online can simply log in	Change it on first setup
Rare or no firmware updates	Known holes stay open for years	Update firmware; retire unsupported devices
Always-on and unmonitored	Misuse goes unnoticed for months	Put IoT on a separate guest network
Exposed directly to the internet	Scanners find it in minutes	Do not port-forward cameras; use the vendor app
Weak or no encryption	Traffic and feeds can be intercepted	Prefer devices with proper security

The Mirai botnet enslaved millions of IoT devices using default passwords alone. In Nepal, home and shop CCTV cameras are commonly left on default logins and exposed online, and ISP routers stay on the sticker admin password.

> ⚠ **Common mistake:** "*An IoT gadget is too small to be a security problem.*" **Correction:** its size does not matter — it is **always-on, reachable and enslavable**. An IoT device on its default password is **a house where the builder's master key still opens the front door**.

6.7 Physical security

Device theft and loss

Losing a phone or laptop physically means losing everything logged in on it.

The defences: full-disk encryption (BitLocker, FileVault; on by default on modern Android and iOS), a **strong screen lock**, **remote-find and remote-wipe** enabled, and not leaving devices unattended.

Situation	Outcome
An encrypted, locked phone snatched in a tempo	**The thief gets a brick**
An unlocked phone still logged into eSewa and Gmail	**Account takeover** — passwords reset, wallet drained

Situation	Outcome
A laptop with no disk encryption stolen	**A full data breach** — files readable by pulling the drive
Remote wipe enabled on a lost phone	Data erased remotely
A device left unattended on a café table	Opportunistic theft
OTP SMS visible on the lock screen	Extra exposure — reset codes read without unlocking

> ⚠ **Common mistake:** "*They'll just sell the hardware — my data is safe.*" **Correction:** the resale value of the phone is **trivial** next to the **eSewa balance and identity** sitting unlocked inside it. **Encryption + lock + remote wipe turn a theft into an inconvenience instead of a breach.**

Shoulder-surfing

Shoulder-surfing is someone watching your screen or keystrokes to steal a PIN or information. It needs **no malware and no skill — just line of sight.**

Situation	The defence
Typing an ATM PIN in a busy queue	**Cover the keypad with your hand**
A stranger "helps" you at the ATM and stands close	Decline help; keep your distance
Entering an MPIN on a bus or micro	Angle the screen; shield entry
Working on a laptop in a café	Sit back-to-wall; use a privacy filter
A camera overlay or skimmer on an ATM slot	Check the slot; use trusted ATMs
Entering a password in a shared room	Shield it; use password-manager autofill

> ⚠ **Common mistake:** "*No one bothers to watch what I type.*" **Correction:** it is the **lowest-effort attack there is**, and it is common **exactly because people assume no one is looking.** Shielding the keypad costs nothing.

Secure disposal

Secure disposal means making data unrecoverable before you sell, donate or discard a device.

Method	How recoverable?	Safe to sell after?
Delete / recycle bin	**Fully recoverable**	No
Quick format	Mostly recoverable	No
Factory reset (unencrypted)	Often recoverable	Risky
Encrypt, then wipe	**Unrecoverable**	**Yes** — only ciphertext is left
Physically destroy the drive	Unrecoverable	Yes — for dead drives

The process: sign out of all accounts first, remove the SIM and SD card, encrypt-then-wipe, and physically destroy dead drives.

In Nepal's second-hand phone and laptop market, **buyers routinely recover the seller's photos and logins from a careless wipe.**

> ⚠ **Common mistake:** "*Deleting files or formatting the disk erases them.*" **Correction:** deleting and quick-formatting only remove the **pointer, not the content**. Data is recoverable until it is overwritten.

Screen locks and access control

Habit	Verdict	Why
A 6-digit PIN or biometric plus 30-second auto-lock	**Strong**	Fast for you, hard for a thief
A simple pattern lock (L or Z shape)	Weak	Guessable **and readable from screen smudges**
No auto-lock, screen stays on	Weak	A set-down device is wide open

Habit	Verdict	Why
Lock on walk-away (Win+L)	**Strong**	No unattended open session
OTP and message previews shown on the lock screen	**Weak**	Codes readable **without unlocking**
Previews hidden until unlocked	**Strong**	OTPs stay private

> **A lock you never trigger protects nothing, and previews that show OTPs defeat the lock entirely.** Short timeout plus hidden previews close both gaps.

6.8 Working from home

Securing the home network

Your router is the front gate of your digital home — secure it first.

Setting	Verdict	Why
Router admin still on the sticker password	**Weak**	Anyone nearby or online can reconfigure it
WPA3 (or WPA2) with a long passphrase	**Strong**	Neighbours cannot join or snoop
Open or "password123" Wi-Fi shared with the building	**Weak**	Everyone sees everyone's traffic
Router firmware updated	**Strong**	Known router holes get patched
WPS left enabled for convenience	Weak	The WPS PIN can be brute-forced
A separate guest/IoT network	**Strong**	A hacked camera cannot reach your work laptop

> ⚠ **Common mistake:** "*My Wi-Fi has a password, so it's secure.*" **Correction:** a weak passphrase, a **default router admin login**, or outdated firmware still leave you exposed. Wi-Fi security is the **whole gate** — passphrase, admin login, firmware and **segmentation** — not one lock.

VPNs

A VPN (Virtual Private Network) encrypts your traffic through a secure tunnel. Use a **company VPN** to reach work resources, and a **trusted VPN on public Wi-Fi** to stop local snooping.

Situation	Does a VPN help?	Why
Working on open café Wi-Fi	**Yes**	Encrypts traffic against local snooping
Reaching internal company systems from home	**Yes** — the company VPN	A secure tunnel into work resources
You click a phishing link and log in	**No**	A VPN protects transport, not your decisions
You download and run malware	**No**	A VPN does not scan or block files
Using a "free" VPN of unknown origin	**Risky**	It may log and sell your traffic
Reusing a weak password over a VPN	**No**	The password is still weak

> ⚠ **Common mistake:** "*A VPN makes me anonymous and 100% safe.*" **Correction: a VPN secures the pipe, not the person.** And a **free VPN can be worse than none** — if the service is free, the product being sold is you.

Separating work and personal

Action	Verdict	Why
Emailing a company file to your personal Gmail	**Risky**	Data leaves company control
Working on the work-issued device and account	**Safe**	Policy, backups and monitoring apply
Saving the client database to your Desktop "for now"	**Risky**	An uncontrolled copy on an unmanaged machine
Using a personal USB for work files	**Risky**	Easy to lose; may carry malware

Action	Verdict	Why
Locking the laptop when you leave the room	**Safe**	Flatmates and guests cannot wander in
The same password for work and personal accounts	**Risky**	One breach cascades across both

> ⚠ **Common mistake:** "*At home there's no one around, so I can relax security.*" **Correction: flatmates, family, guests, insecure IoT and remote attackers are all still in scope.** "Home" is not "safe", and "just for now" copies are exactly how work data leaks.

Video calls and collaboration

Situation	Verdict	Why
A meeting link posted publicly on Facebook	**Risky**	Anyone can join — "Zoom-bombing"
A meeting password plus a waiting room	**Safe**	Only invited people get in
Screen-sharing with other tabs and notifications open	**Risky**	Leaks messages, emails, other data
Sensitive documents visible in your background	**Risky**	An on-camera information leak
Clicking a "meeting invite" from an unknown sender	**Risky**	Fake-invite phishing
A neutral background and sharing only one window	**Safe**	Nothing extra leaks

Nepal saw widespread "**Zoom-bombing**" **of online classes** during lockdown, when links were shared openly with no password.

> **Two habits prevent most incidents: a password plus a waiting room on every meeting, and sharing only the one window you intend — not the whole screen.**

6.9 Securing your accounts

Strong passwords

A strong password is long, unique and hard to guess.

> **Length beats complexity — and uniqueness beats everything.**

Password	Verdict	Why
`nepal123` or your phone number	**Weak**	Guessable and in every wordlist
`P@ss123` — short with symbols	**Weak**	Short, so cracked in seconds despite the symbols
`Ram@2003` — name plus date of birth	**Weak**	Personal information is easy to find
`Kathmandu@2026`	Medium	Better, but still short and guessable
`hariyo!gai-khana-25` — a passphrase	**Strong**	Long and unique — a huge search space
The same password reused everywhere	**Weak**	One breach topples every account

> ⚠ **Common mistake:** "*Adding @ and a number makes a password strong.*" **Correction:** short-but-symbolic is still weak. **No amount of symbols saves a password that is reused everywhere.**

Password managers

A password manager generates and stores a unique password for every site behind one master password. You remember **one strong master password**, protected with MFA, and the manager does the rest — which is what makes "unique everywhere" realistic. Options: **Bitwarden**, your browser's built-in manager, or Google's.

⚠ **Common mistake:** "*A password manager is a single point of failure.*" **Correction:** the realistic comparison is **not** "manager versus perfect memory" — it is "**manager versus reuse and sticky notes**". Nobody can remember 60 unique strong passwords, which is exactly why people reuse. A well-secured vault wins decisively. Autofill also **resists lookalike-phishing domains**, because the manager will not fill on the wrong site.

MFA / 2FA

MFA (multi-factor authentication) adds a second proof beyond your password — something you have or something you are.

Factor	Strength	Trade-off
Password only	**Weakest**	One stolen secret gives full access
SMS OTP	Better	Vulnerable to **SIM-swap** — but far better than none
Authenticator app (TOTP)	**Strong**	Codes generated on your device; no SIM to hijack
Hardware security key	**Strongest**	Resists phishing; small cost
MFA on email specifically	**Highest priority**	**Email resets every other account**

Enable MFA on your email first — it is the master key that can reset everything else.

⚠ **Common mistake:** "*MFA is too much hassle for what it's worth.*" **Correction:** MFA blocks the **vast majority of account takeovers even when your password is stolen** — a few seconds per login against losing your wallet and identity. It is the single highest-value habit after not reusing passwords.

Breach awareness and response

Breach awareness is knowing when your credentials leak, and acting fast. Check **haveibeenpwned.com**.

Situation	The right move	Why
Your email appears on haveibeenpwned	Change that password and enable MFA	Assume it is now public
You reused that password on five sites	**Change it on all five**	**Credential stuffing** tries it everywhere
A scam SMS quotes your real name and last order	Treat it as phishing; do not click	Leaked data makes scams look legitimate
Ignoring a breach notice as "probably nothing"	**Wrong**	The password is already circulating
Adding MFA after a breach	**Right**	Blocks takeover even with the leaked password
Using the same new password everywhere again	**Wrong**	Re-creates the reuse vulnerability

Credential stuffing is the attack that makes reuse so dangerous: one leaked password is replayed automatically across all your other accounts.

⚠ **Common mistake:** "*Reusing one password is fine if it's a strong one.*" **Correction:** once **any one site leaks it**, a strong-but-reused password **topples like a domino**. Reusing one password is using the same key for your house, car, office and locker. **Uniqueness is what contains a single leak to a single account.**

Key words from Unit 6

Security posture · patch, protect, back up, contain · patching · end-of-life software · antivirus / anti-malware · real-time vs on-demand scanning · signature vs behaviour detection · scareware · fake AV · backup · 3-2-1 rule · tested restore · firewall · host vs router firewall · deny by default · app permissions · least privilege · sideloading APKs · cloned app · SIM-swap · OTP · MPIN · IoT · default password · Mirai botnet · full-disk encryption · BitLocker · FileVault · remote wipe · shoulder-surfing · privacy filter · skimmer · secure disposal · encrypt-then-wipe · screen lock · auto-lock · lock-screen previews · router hardening · WPA2/WPA3 · WPS · guest network · segmentation · VPN · work/personal separation · Zoom-bombing · waiting room · passphrase · password manager · master password · MFA/2FA · TOTP · hardware security key · haveibeenpwned · credential stuffing.

Summary — Unit 6

- **Posture = patch + protect + back up + contain.** Most attacks are automated and hit whoever is unpatched — you do not need to be a target, only reachable.
- Turn on **automatic updates**, avoid **end-of-life and pirated** software, and run **one** good antivirus. Fake AV announces itself with a pop-up and a demand for money.
- Keep **3-2-1 backups** with a **tested restore**, and leave the **firewall on** with deny-by-default — but remember it is one wall, not the whole castle.
- On mobile, apply **least privilege to permissions**, install only from official stores, never sideload APKs, and **never share an OTP or MPIN** — banks never ask.
- **Change the default password on every IoT device.** Mirai proves why.
- A lost **unencrypted or unlocked device is a data breach**, not lost hardware. Encrypt, lock, enable remote wipe, hide lock-screen previews, and **encrypt-then-wipe before resale**.
- Working from home: harden the **router** first, use a **trusted VPN** on untrusted networks (it secures the pipe, not the person), keep **work and personal separate**, and protect meetings with passwords and waiting rooms.
- Use **long unique passphrases** via a **password manager**, turn on **MFA — email first**, and assume a breach will happen: **change, de-reuse, enable MFA, and expect follow-on phishing.**

Unit 7 — Social Engineering and Cyber Terrorism

5 lecture hours. Introduction · need for social engineering · reasons for social engineering attacks · understanding the implications · building trust · exploiting the relationship · performing social engineering attacks · social engineering countermeasures · preventing social engineering attacks · cyber terrorism · types of cyber terrorism · effects of cyber terrorism on infrastructure · countering cyber terrorism.

> **Read this first.** This unit is taught **defensively, for awareness only**. You learn to **recognise and prevent** these attacks, never to perform them — there is **no operational how-to** here. Cyber terrorism is kept conceptual: we classify and defend, we do not instruct.

7.1 What social engineering is

Social engineering is manipulating PEOPLE into giving up confidential information or access, instead of breaking technology directly.

> **The attacker hacks the person, not the PC.**

It bypasses the technology entirely — no firewall is defeated if a human opens the door. The "system" being attacked is **a person's judgement**, and it works over **any channel**: a call, an SMS, an email or a face-to-face visit. The technology involved — a fake page, a spoofed number — is **only a prop**; the con is the human manipulation.

Dimension	Technical attack (the machine)	Social engineering (the person)
Target	Code, servers, encryption	A human's trust and judgement
Method	Exploits, brute force, malware	Persuasion, deception, impersonation
What it defeats	A weak system	A **busy, polite or fearful person**
Cost and skill	High — needs deep technical skill	**Low — mostly a convincing story**
Nepal example	Cracking a bank's core system	Phoning a customer as "bank security"
Defence	Firewalls, patching, encryption	**Awareness and verify-before-trust habits**

Real case in Nepal	What the attacker actually did
A fake "NTC/Ncell" SIM-block SMS with a link	Scared the user into "verifying" on a fake page
A "bank head office" call asking for the OTP	Impersonated authority to extract the code
An "IT helpdesk" asking a staffer to confirm a password	Used helpfulness and urgency
A fake eSewa "account suspended" message	Rushed the victim to click and log in
A caller using your real name and branch	Manufactured legitimacy from a leaked list
A "Daraz prize" claim asking for a "fee"	Dangled a reward to extract money

In every row the technology is untouched. That is the signature of social engineering.

> ⚠ **Common mistake:** "*Social engineering is a technical hacking skill.*" **Correction:** it is mostly **persuasion and deception** — the technology is secondary. A scammer needs a **convincing story** far more than coding skill, which is why **anyone** can be targeted.

7.2 Why attackers use it

Social engineering is the path of least resistance — cheaper, faster and more reliable than defeating strong technical controls.

Attack path	Cost and skill	Success and traceability
Breaking strong encryption	Very high, often infeasible	Low success; effort wasted

Attack path	Cost and skill	Success and traceability
Finding a zero-day exploit	High — rare, expensive skill	Works, but costly and perishable
Phoning a customer as "bank security"	**Very low — a phone and a script**	**High success; hard to trace**
Mass phishing SMS to thousands	Very low — one message, bulk send	A few victims still pays off
Tricking a busy employee for a password	Low — a plausible story	**Bypasses every technical control**

The economics: hardened technology raises the cost of a direct attack, so the human becomes the cheap way in. It is far easier to fool a thousand customers than to breach one well-defended bank.

> ⚠ **Common mistake:** "*If the bank is secure, my money is safe.*" **Correction:** the bank's servers may be hardened, but **you are the softer target**. Attackers deliberately skip the strong wall and knock on the human door — so **your own awareness is part of the bank's security.**

7.3 Why humans are the weakest link

Attackers do not break normal human traits; **they use them.**

Human trait	How it is exploited	The defence habit
Helpfulness	"Just confirm your password so I can fix your email"	**No one legitimate needs your password**
Obedience to authority	"I'm calling from the bank / the police"	Verify via the official number **you** look up
Fear of consequences	"A police case is filed unless you pay now"	Real authorities do not demand instant payment by phone
Urgency / time pressure	"Your account blocks in 10 minutes"	**Slow down — urgency is a red flag, not a reason**
Curiosity	"Open this to see who viewed your profile"	Do not open unexpected links or attachments
Trust in familiar brands	A fake eSewa or Daraz logo and sender name	Check the real sender and URL

> ⚠ **Common mistake:** "*Only careless or foolish people fall for scams.*" **Correction: smart, busy, polite people are exactly the target** — the attack exploits normal good traits under time pressure. Assuming "it won't happen to me" **is itself the vulnerability.**
>
> **The castle analogy.** The strongest castle wall is useless if the gatekeeper opens the gate to anyone wearing the right uniform. **Social engineering *is* the right uniform.**

7.4 Understanding the implications

A single successful manipulation rarely stays "one account." Credentials are **keys, not doors**.

Step in the chain	What the attacker reaches	Why it cascades
An OTP or password is shared	The first account, often email	The entry point to everything linked
Email is taken over	Password resets for other services	**Most accounts recover via email**
Bank, eSewa, Khalti	Wallet balance and payment history	Direct financial theft
Social accounts	Identity and the contact list	Enables the next round of scams
Contacts are messaged	Friends and family targeted next	**Trust in YOUR name becomes the weapon**

> ⚠ **Common mistake:** "*It's just one password, no big deal.*" **Correction:** the damage is **a chain, not a point**. One leaked code can unlock email, then the bank, then social, then your contacts — and the impact is usually **delayed and wide**, visible only after the chain has run.

7.5 Building trust — the influence levers

Attackers **manufacture** trust using well-known influence principles. Learn them **only to recognise them**: the friendly, legitimate-sounding front is **engineered, not genuine**.

Lever	How it sounds	The red flag
Authority	"I'm calling from the bank / police / IT"	A title alone is not proof
Liking / rapport	Warm, friendly chat before any request	Unusual friendliness from a stranger who then asks
Social proof	"Everyone has updated their KYC already"	"Everyone's doing it" is pressure, not a reason
Reciprocity	"I helped you — now just confirm this code"	A small favour used to extract a bigger one
Familiarity	Uses your real name, branch or last digits	**Scraped from a leaked list**
Consistency	"You already agreed, so just finish the step"	Manufactured momentum toward the real ask

> ⚠ **Common mistake:** "*If they know my name, my branch and my bank, they must be genuine.*" **Correction:** that information is often **scraped from leaked lists**, and it is **exactly how attackers manufacture legitimacy**. Knowing your details **proves nothing**.

Attackers often stack several levers at once — and the moment you can name the lever, its power drops.

7.6 Exploiting the relationship — "the close"

Once trust exists, attackers add **pressure** so the victim acts before thinking. This is **the close**: the emotional squeeze that converts a friendly conversation into a harmful action.

Scam message	Levers used	The close, and the safe response
"You've won Rs 25 lakh — pay a Rs 5,000 fee to release it"	Greed + authority + scarcity	**Never pay a fee to receive a prize**
"Account blocks in 10 minutes — confirm your OTP now"	Authority + urgency	**Banks never ask for your OTP**
"Police case filed — settle immediately or be arrested"	Authority + fear	Hang up; call the real police line
"KYC expires today — verify on this link"	Social proof + urgency	Visit the bank or app directly
"Parcel held at customs — pay Rs 200 here"	Curiosity + urgency	Verify with the courier's official number
"I'm your boss's assistant — approve this transfer fast"	Authority + rapport	Confirm with the boss on a known number

> ⚠ **Common mistake:** "*A real urgent message means I must act immediately.*" **Correction: manufactured urgency is the attacker's main weapon** — it exists precisely to stop you verifying. The correct response to pressure is to **slow down**; a genuine institution will not punish you for taking time to confirm.
>
> **The magician analogy.** The friendly chatter is the **misdirection**; the "trick" is the request that follows.

7.7 The six attack types

The same con appears across channels under different names.

Type	Channel	How you recognise it
Phishing	Email	A fake "bank/college" email with a link; mismatched URL, generic greeting
Vishing	Voice call	A "bank officer" pressuring you to share the OTP just sent
Smishing	SMS	"eSewa suspended — click here"; "Daraz prize"; "parcel fee"
Pretexting	Any — a story	"I'm the new auditor / your boss's assistant" — an invented role
Baiting	Download or USB	A "free" movie or app, or a USB left in the canteen or car park
Tailgating	A physical door	A stranger following staff through a secure door, "hands full"

The recognition cues repeat: mismatched URLs, urgent threats, requests for OTP or PIN, generic greetings.

Attack	Red flag	Safe response	If you fall for it
Vishing — a "bank" OTP call	Anyone asking you to read out an OTP	Hang up; call the bank's official number	Wallet drained within minutes
Smishing — "account suspended"	A link plus urgency in an unexpected text	Do not click; open the app directly	Credentials phished on a fake page
Phishing — a fake email	Mismatched URL, generic "Dear customer"	Hover the link; verify officially	Inbox used to reset other accounts
Baiting — a dropped USB	Something too tempting or conveniently found	Do not plug it in; report it	Malware on your device or network
Pretexting — a "new auditor"	A stranger with a story wanting access	Verify the role with a known contact	Sensitive data handed to an outsider
Tailgating — door-following	Someone without a badge following you	**Do not hold the door**; direct them to reception	An intruder gains physical access

> ⚠ **Common mistake:** "*Phishing only happens over email.*" **Correction:** it spans **SMS, calls, QR codes and social media**. Guarding only your inbox leaves every other channel open — **the con simply switches pipes to whichever one you trust more.**

7.8 Countermeasures and prevention

Defence is layered. No single control stops social engineering; the layers work together so a slip at one is caught by another.

Layer	Measure	What it stops
People	Awareness training and simulated-phishing drills	Staff recognise and report the lure
Process	**Verify-via-callback** before acting on a request	Impersonation calls fail the check
Process	**Least-privilege** access	A fooled account can reach less
Process	Visitor badges and escort policy	Tailgating into secure areas
Technology	**Multi-factor authentication**	A stolen password alone cannot log in
Technology	Email filtering and anti-spoofing (SPF, DKIM, DMARC)	Many phishing emails never arrive

The strongest cultural control is a bank publicly and repeatedly stating: "**we will NEVER ask for your OTP or PIN.**" That single rule means **any such request is the scam identifying itself.**

Your personal habits

Scenario	The wrong reaction	The safe response
"Parcel held at customs — pay Rs 200 here"	Click the link and pay	Contact the courier's official number
"Bank security" asks for the OTP just sent	Read out the code	**Refuse — banks never ask**; hang up and call them
"You won a prize — pay a small fee"	Pay the fee	Ignore — real prizes never require an upfront fee
"Reset your password here now"	Click the in-email link	Go to the site directly
A found USB or a "free movie" download	Plug it in to see what it is	Hand a found USB to IT; avoid the download
"Your KYC expires today"	Rush to submit details on the link	Visit the branch or official app yourself

STOP, THINK, then CLICK.

Like looking both ways before crossing a road. **Urgency is the attacker's weapon, so the deliberate pause is the protection.** The pattern is always the same: **refuse, then verify independently.**

⚠ **Common mistake:** "*If a message looks official, it's safe to act on it.*" **Correction:** logos, names and official tone are **trivial to fake**. The safe habit **ignores how it looks** and verifies through a channel **you** control.

7.9 Cyber terrorism

Cyber terrorism is the politically or ideologically motivated use of computers and networks to cause serious harm, fear or disruption — especially to critical systems or the public.

Three ingredients define it, and all three must be present:

Ingredient	What it means	Why it matters
Intent	A political or ideological motive — **not profit**	Separates terrorism from profit-driven crime
Target	Critical systems or the public's safety	The aim is society-wide impact, not one victim
Severity	Serious harm, fear or disruption	Nuisance and vandalism alone do not qualify

⚠ **Common mistake:** "*Any hacking is cyber terrorism.*" **Correction:** most hacking is **crime (for profit) or vandalism**. Terrorism requires **political or ideological intent PLUS an intent to terrorise or seriously harm**. Mislabelling a prank or a profit scam as "terrorism" **distorts both the threat and the response**.

Distinguishing the four related terms

They share the same tools, so the tool never decides the label — MOTIVE and ACTOR do.

Term	Primary motive	Typical actor	Example
Cybercrime	**Profit**	Criminals, fraud gangs	A ransomware gang; OTP and eSewa scams
Hacktivism	**Protest or a message**	Activists	A website defacement to make a point
Cyber warfare	**State conflict**	Nation-states	State-versus-state attacks during a conflict
Cyber terrorism	**Ideology plus terror**	Ideologically driven groups	An attempt to disable a national grid to cause fear

Getting the label right changes the legal route and who responds — police, regulator, or national security.

Types of cyber terrorism

Type	Example (awareness level)	Intended effect
Critical-infrastructure attack	Targeting power, water, telecom, finance, aviation	Physical disruption and public fear
Data destruction or manipulation	Corrupting or wiping public records	Erode trust; damage governance
Service denial at large scale	Disrupting essential online services	Freeze daily life and commerce
Propaganda and psychological operations	Disinformation during sensitive national events	Spread fear, divide, recruit
Recruitment and radicalisation	Online content to recruit	Grow the movement
Financing via cyber means	Moving or raising funds online	Fund and sustain the campaign

⚠ **Common mistake:** "*Cyber terrorism only means blowing up power plants.*" **Correction:** the types are broader — **data destruction, large-scale service denial, and especially propaganda and disinformation that attack the public's mind.** An information campaign that spreads fear can be as much a part of it as an infrastructure strike.

Cyber terrorism is "arson with a keyboard" — the goal is not theft, it is fear and damage.

7.10 Effects on critical infrastructure

Critical infrastructure (CI) is the set of systems a society cannot function without. An attack **rarely stays contained** — the danger is the **cascade**.

If this is hit	The cascade it triggers	The real-world effect
National power / load-dispatch	Telecom and data centres lose power	Blackout; communications go dark
Telecom operators	Internet, calls and **OTP delivery** fail	Wallets and banking become unusable
Payment infrastructure (eSewa, Khalti, ConnectIPS)	Digital commerce halts	Shops, salaries and remittances freeze
The banking network	ATMs and transfers stop	People cannot access their own money
A government data centre	Citizen records exposed or altered	Identity risk; loss of trust in e-government
Aviation or hospital systems	Safety-critical operations disrupted	**Direct risk to travel and to life**

Nepal's specific exposure: dependence on **a few telecom operators** and on **digital wallets** concentrates the risk — an attack on national payment or telecom infrastructure could freeze daily commerce.

> ⚠ **Common mistake:** "*Cyber attacks only cause online damage.*" **Correction:** attacks on industrial and control systems cause **physical, economic and human harm**. The "cyber" part is only the **entry point**; the damage is very much in the physical world.

7.11 Countering cyber terrorism

Defence is coordinated across three levels, and no single level is sufficient.

Layer	Key measures	Nepal example
National	CERT and national incident response, critical-infrastructure protection policy, intelligence sharing, legal frameworks, international cooperation	**NPCERT**; the **Electronic Transaction Act** (Unit 9)
National	Cross-agency coordination	NRB, telecoms and government agencies together
Organizational	Network segmentation, monitoring and intrusion detection, backups	Banks isolating and monitoring core systems
Organizational	Incident-response and business-continuity / disaster-recovery plans, regular drills	Tested continuity plans and rehearsals
Personal / citizen	Awareness; reporting suspicious activity	Reporting scams and phishing to the bank or CERT
Personal / citizen	**Not amplifying disinformation or panic**	Verifying before resharing during a crisis

> ⚠ **Common mistake:** "*Cyber terrorism is only the government's problem.*" **Correction:** leaving it entirely to the government **removes two of the three defensive layers**. Citizens counter it partly by **not spreading panic or disinformation** — which is, after all, the attacker's actual goal.

Resilience and preparedness

Resilience means assuming attacks will happen and building the ability to keep operating and recover fast. Plan for "**when**", not "**if**".

Incident-response step	What is done	Why it limits the damage
Prepare (before)	Backups, tested BCP/DR, staff drills	Ready to act — no improvising mid-crisis
Detect	Monitoring and IDS flag the disruption	Faster detection means less spread

Incident-response step	What is done	Why it limits the damage
Contain	Isolate affected systems; fail over	Stops the cascade to other services
Eradicate	Remove the threat from the network	Prevents re-infection on recovery
Recover	Restore service from clean backups	Gets customers back online safely
Review and communicate	Learn, coordinate with NPCERT, inform the public	Prevents recurrence; **limits panic**

> ⚠ **Common mistake:** "*Good defence means never getting attacked.*" **Correction:** no defence is perfect, so **hoping it will not happen is not a plan**. Resilience assumes an incident **will** occur and invests in backups, failover, tested response and coordination.
>
> **The earthquake analogy.** You cannot stop every quake, but **drills, building codes and a recovery plan** decide whether it is a scare or a catastrophe.

Key words from Unit 7

Social engineering · hacking the person · path of least resistance · helpfulness · obedience to authority · fear · urgency · curiosity · brand trust · credential chain · cascade · influence levers · authority · liking/rapport · social proof · reciprocity · familiarity · consistency · the close · scarcity · phishing · vishing · smishing · pretexting · baiting · tailgating · business email compromise · verify-via-callback · least privilege · visitor badge and escort · MFA · SPF/DKIM/DMARC · simulated phishing · "we never ask for your OTP" · STOP-THINK-CLICK · cyber terrorism · intent, target, severity · cybercrime · hacktivism · cyber warfare · critical infrastructure · cascading effect · data destruction · service denial · propaganda and psy-ops · radicalisation · NPCERT · Electronic Transaction Act · BCP/DR · incident response (prepare, detect, contain, eradicate, recover, review) · resilience · assume breach.

Summary — Unit 7

- **Social engineering hacks people, not machines** — persuasion and deception over any channel, with the technology as a mere prop.
- It is the **cheapest, highest-success attack path**, so attackers pivot to the human **by choice** once the machines are hardened.
- Humans are exploited through **helpfulness, authority, fear, urgency, curiosity and brand trust** — normal good traits turned into an attack surface.
- One leaked credential **cascades**: email → bank → wallet → social → your contacts.
- Attackers **manufacture trust** (authority, rapport, social proof, reciprocity) and then apply **the close** (urgency, fear, scarcity). **Naming the lever defuses it.**
- The six types are **phishing, vishing, smishing, pretexting, baiting and tailgating** — and countermeasures must be **layered** across people, process and technology.
- The personal rule is **refuse, then verify independently: STOP, THINK, then CLICK.**
- **Cyber terrorism = ideological intent + a critical target + serious harm**, distinct from cybercrime (profit), hacktivism (protest) and cyber warfare (state conflict). **Motive and actor decide the label, never the tool.**
- Infrastructure attacks **cascade into physical harm**, and countering them needs **national, organizational and personal** layers — plus **resilience: assume breach, back up, drill, recover.**

Unit 8 — Digital Forensics

7 lecture hours. Introduction · computer forensics to digital forensics · stages of digital forensics · role of digital evidence · methods and lab · collecting, seizing and protecting evidence · recovering data · mobile forensics · legal aspects of digital forensics · cyber forensics in Nepal.

> **The spine of this whole unit is chain of custody and evidence integrity** — hashing, write blockers, documentation. Every section comes back to it.

8.1 What digital forensics is

Digital forensics is the scientific process of identifying, preserving, analysing and presenting digital evidence in a way that is legally admissible.

Break the phrase: **forensics** means applying science to legal questions, and **digital** means any device that stores or transmits data.

> **The key move: the goal is court-admissible proof — not just retrieving a file.**

Dimension	Plain data recovery	Digital forensics
Goal	Get the file back	**Court-admissible proof**
The original	May write to or repair it	**Never alter** — work on a hashed copy
Documentation	Optional	**Every step logged** (chain of custody)
Method	Whatever works	Repeatable, defensible, scientific
Output	The recovered data	A report a judge can rely on
Who uses it	IT support	Cyber Bureau, courts, investigators

Globally: the **BTK killer** was caught via **metadata in a Word document** on a floppy disk — the hidden data, not the visible text, cracked the case. *In Nepal:* the **Nepal Police Cyber Bureau** (established **2018, Bhotahity, Kathmandu**) analyses seized devices in online-fraud and social-media-abuse cases.

> ⚠ **Common mistake:** "*Forensics is just data recovery or IT support.*" **Correction:** casual recovery that **alters the original** or **skips documentation** destroys the evidential value **even when the data is found**.

8.2 From computer forensics to digital forensics

"**Computer forensics**" **(1980s–90s)** meant a single PC and one hard disk, seized and imaged in a lab. Then networks, email and servers added **remote and volatile** evidence. Today evidence is **mostly on phones and apps**, with cloud copies elsewhere, and new sources keep arriving — IoT devices, smart TVs, cars, wearables. The field broadened into **digital forensics: multi-device, networked, cloud-connected and mobile-dominant.**

Case type	The old assumption	Today's reality in Nepal
Online fraud	A desktop PC with account files	eSewa/Khalti, the phone, bank app data
Harassment	Emails on a work PC	Facebook, Messenger, TikTok, WhatsApp chats
Blackmail	Local image files on a disk	Phone gallery + cloud backup + chat apps
Financial scam	A spreadsheet on one computer	Mobile wallets, SMS OTPs, **CDRs from NTC/Ncell**
Fake profile	One machine's browser history	Social accounts hosted abroad
Insider data theft	A USB copied at a desk	Cloud sync, personal phone, webmail

> ⚠ **Common mistake:** "*Digital forensics just means examining a hard drive.*" **Correction:** that was the 1990s. **An investigator who only knows disk imaging misses most of the evidence.** The crime scene moved into the pocket.

8.3 The core principles

These echo the **ACPO-style principles** used internationally.

Principle	What it means in practice	Why it matters
Don't alter the original	Use write blockers; never open files on the seized device	A changed byte makes the evidence challengeable
Work on copies	Image the device; analyse the hashed image	The sealed original stays pristine for court
Document everything	Log who, what, when and why for every action	Undocumented steps cannot be defended
Chain of custody	Record every handoff	A gap suggests possible tampering
Repeatability	Another expert can redo your steps and agree	**Science, not opinion** — this convinces a court
Competence	Only trained people touch originals	An untrained click can destroy a case

> ⚠ **Common mistake:** "*Taking a quick look at the file can't hurt.*" **Correction:** opening a file **changes access times, can trigger syncs, and breaks the don't-alter rule**. An officer who "just opens the gallery to check" has already altered the evidence.
>
> **The footprint analogy.** A digital crime scene is a footprint in sand — **walking over it to look closer destroys the very thing you came to capture.** Looking can be destroying.

8.4 The six stages of the forensic process

> ### Identify → Preserve → Collect → Examine → Analyse → Report

This follows standard models such as **NIST SP 800-86**. It is a **fixed, ordered sequence**, not "poke around and see".

Stage	What happens	What it hands on
Identify	Find which devices, accounts and data matter	A list of evidence sources
Preserve	Isolate and prevent any change (airplane mode, Faraday bag)	An unaltered, protected source
Collect	Image or seize the evidence, and hash it	A verified forensic copy
Examine	Extract the relevant data from the copy	Filtered, relevant data
Analyse	Interpret it; reconstruct the timeline	A reasoned account of what happened
Report	Explain it clearly **for a non-technical judge**	A defensible written report

Stage skipped	What happens	The consequence
Identification	You miss the suspect's second phone	Key evidence never collected
Preservation	The phone stays online and the cloud deletes the chat overnight	**Irreplaceable evidence lost**
Collection	Files copied by hand instead of imaged	No hash, no slack space — challengeable
Examination	The analyst wades through everything unfiltered	Slow, error-prone, may miss the data
Analysis	A chat reported with no timeline or context	A judge cannot see what happened
Reporting	The court is handed a raw technical dump	A non-technical judge cannot use it

> ⚠ **Common mistake:** "*Analysis is the real work; the rest is just paperwork.*" **Correction: preservation and chain of custody are what make the analysis usable at all.** Brilliant analysis of contaminated evidence is worthless. **The "paperwork" *is* the admissibility.**
>
> ⚠ **And:** "*We can always go back and re-collect if we miss something.*" **Correction: volatile evidence — RAM, live syncs, cloud-deletable chats — can vanish permanently within minutes.** Preservation is a **one-shot chance**.

8.5 Chain of custody and integrity

Chain of custody is the documented, unbroken record of who handled evidence, when, why and how — from seizure to court. It is **not a stage; it is a band running under all six stages.**

Log field	What it captures	Why the court needs it
Who	Every person who held the exhibit	Names each link in the chain
When	Date and time of each transfer	Shows no unexplained gaps
Why	The reason for the handoff	Justifies each access
How	Sealed bag, hash, transport method	Proves it could not be altered in transit
Seal / label	A tamper-evident bag with a unique ID	Any broken seal is immediately visible
Signature	Sign-off at each handoff	Makes each person accountable

Stage	The integrity action	Why it protects the case
Preservation	Seal in a labelled, tamper-evident bag	Proves no one accessed it in transit
Collection	Compute a **SHA-256 hash** of the image	A later re-hash proves it is unchanged
Storage	Lock in an access-controlled evidence locker	Limits who could have tampered
Every handoff	Sign the custody log	No gap for the defence to exploit
Examination	Work **only on the hashed copy**	The sealed original stays court-ready
Reporting	Cite hashes and the custody log	Shows the court the evidence is trustworthy

> ⚠ **Common mistake:** "*Chain of custody is just bureaucratic paperwork.*" **Correction:** it is **the proof the evidence was not tampered with**. Without it, even perfect data is worthless. **A single unexplained gap can make damning evidence inadmissible.**

The weak point in Nepal is usually not the Bureau but earlier: **an untrained officer at a local thana who seizes a phone without tagging, sealing or logging it** creates a custody gap that can sink an otherwise strong case.

> **The relay-baton analogy.** Every handoff is recorded, and **dropping the baton — a gap in custody — disqualifies the team.**

8.6 Digital evidence

Digital evidence is any data stored or transmitted in digital form that can support or refute a fact in a case.

The five properties of good evidence: admissible, authentic, complete, reliable, believable. Note that **encryption is not one of them** — encryption is how you *protect* evidence, not what makes it evidence.

Type	Where it lives	What it can prove
Files and documents	Disk, phone, cloud	A forged invoice in a fraud case
Metadata	Inside the file — author, timestamps, GPS	When and where a photo was really taken
Logs	System, router, server, app	Which account logged in, and when
Chats and email	App databases, mail servers	A blackmail or harassment conversation
Location / GPS	Phone, app history, **CDRs from NTC/Ncell**	A suspect's movements at a key time
Deleted / residual	Slack and unallocated space	Data a suspect tried to destroy

Much of the strongest evidence is hidden — metadata, logs, deleted residue — not the obvious visible file. That is exactly why forensic imaging captures the **whole device**.

> ⚠ **Common mistake:** "*A screenshot is solid proof.*" **Correction:** screenshots are **easily faked and lack metadata**, so they are weak on their own. They become strong only when backed by a **forensically extracted original**. **A CDR obtained from the telecom operator is far stronger than a phone screenshot.**

8.7 Methods, tools and the forensic lab

Standard methods: imaging, hashing, keyword search, and timeline and artifact analysis.

Tool / category	What it does	Open or commercial
Write blocker	Read a drive while blocking any write	Hardware or software
Imaging tool (dd, FTK Imager)	Make a bit-for-bit forensic copy	Free and commercial
Autopsy / The Sleuth Kit	Analyse disk images, timelines, carving	**Open source (free)**
EnCase	Commercial analysis suite, court-tested	Commercial
FTK	Commercial analysis and indexing suite	Commercial
Cellebrite / mobile kits	Extract data from phones and SIMs	Commercial

> ⚠ **Common mistake:** "*Real forensics needs expensive commercial software.*" **Correction: admissibility depends on sound, documented, repeatable methodology — not the price of the tool.** A free tool used with discipline is just as admissible as a costly one used sloppily. **Method beats brand.**

The forensic lab

A forensic lab is a controlled environment ensuring integrity, security and accreditation.

Lab feature	What it provides	Why it matters
Physical security	Locked, monitored premises	Stops unauthorised access
Access control	Only trained staff enter	Narrows who could contaminate
Evidence lockers	Sealed, logged storage	Preserves chain of custody
Air-gapped machines	Analysis PCs off the network	No malware, remote wipe or contamination
Documentation	Full records of every action	Repeatability and defensibility
ISO/IEC 17025	Accreditation of competence	Court trust in the lab's results

In Nepal, the **Cyber Bureau runs the central lab**, and many **district-level investigations lack lab access entirely** — a real capacity gap that pushes work back to the Bureau and slows cases.

> ⚠ **Common mistake:** "*Any IT technician with a good PC can do forensic analysis.*" **Correction:** without a controlled lab the evidence can be contaminated or challenged. **The environment is part of the integrity**, not an optional extra.

8.8 Seizing devices correctly

Seizing correctly means capturing a device in a state that preserves its data. The moves: photograph the scene and screen · decide power-on versus power-off deliberately · **isolate from networks** (Faraday bag or airplane mode) · follow the **order of volatility**.

> **Order of volatility: RAM and live network state vanish first → disk survives longer → backups longest. Capture the most fragile data first.**

Situation at the scene	The wrong move	The right move
A laptop on, with full-disk encryption **unlocked**	Power it off → **the disk relocks**	Live-acquire RAM and keys first, then image
A phone on and connected to Wi-Fi	Leave it online	**Airplane mode or Faraday bag** — stop remote wipe

Situation at the scene	The wrong move	The right move
The screen shows an open app	Close it "to be tidy"	**Photograph it first** — that state is evidence
Running processes and connections	Ignore them; grab the disk	**Capture RAM first** — most volatile
A device warm, possibly syncing	Wait and finish paperwork	**Isolate now** — the cloud may delete the chat
A USB or SD card in the device	Forget it	Log, seize and image it too

> ⚠ **Common mistake:** "*Always switch a seized device off to be safe.*" **Correction:** powering down **destroys volatile RAM evidence and can re-lock an encrypted disk** you will never get back into. **Isolate from networks first, then choose the power state deliberately.**

Write blockers and hashing

Question	Write blocker	Hashing (MD5 / SHA-256)
What it is	Hardware or software that blocks writes	A mathematical fingerprint of the data
When used	**During imaging** of the original	At collection, then re-checked later
Protects against	Accidentally altering the original	Undetected change to the copy
Proves	The original was **never written to**	The copy is **identical, bit-for-bit**
Analogy	A one-way valve	A tamper-evident seal on a bottle

They work together: the write blocker **prevents** alteration during imaging; the hash **proves**, afterwards and in court, that the copy still equals the original. **Neither alone is enough.** Change one byte and the hash changes visibly — **tampering is detectable**.

> ⚠ **Common mistake:** "*If the analyst is careful, hashing and write blockers aren't really needed.*" **Correction: care is not proof.** "Trust me, I was careful" is not defensible evidence.

8.9 Recovering data

Why "deleted" is not gone

Deleting a file usually removes the pointer or index entry, not the actual data — the bytes stay until overwritten. The file system simply marks the space as "free"; until it is reused, the data remains recoverable.

Action taken	Really destroyed?	Why
Delete a file and empty the recycle bin	**No**	Only the pointer is gone
Quick format a USB drive	**No**	Rebuilds the index; most data remains
Factory reset an old phone, then sell it	**Often no**	Traces and cloud backup can remain
Overwrite the whole drive (secure wipe)	**Yes**	Every byte is replaced
Physically destroy the disk	**Yes**	No medium left to read
Full-disk encryption, then destroy the key	Effectively yes	Data is unreadable without the key

SSD TRIM and full-disk encryption complicate recovery — a useful real-world caveat.

> **The same fact cuts both ways:** suspects who "delete everything" are routinely undone — **and a resold, factory-reset phone can still leak the previous owner's photos.**
>
> **"Delete" removes the label from the box, not the box.**

Disk imaging

A disk image is a bit-for-bit copy of an entire drive — including slack and unallocated space, not just the visible files. The workflow: **image first** (with a write blocker, then hash), **then analyse the image — never the original.**

Dimension	Physical (bit-for-bit) image	Logical copy
What it captures	Every sector, including slack and unallocated space	Only chosen files and folders
Deleted data	**Preserved and recoverable**	**Lost — not copied**
Hash verification	A whole-disk hash proves integrity	Weaker — misses hidden areas
Size and effort	Large, slower	Small, quick
Forensic value	**High — the standard for evidence**	Limited — triage only

> ⚠ **Common mistake:** "*Just copy the important files off the disk.*" **Correction:** copying only visible files misses **deleted data in slack and unallocated space** and produces **no whole-disk hash**. **Imaging the whole disk is what makes deleted-data recovery possible.**

File carving

File carving reconstructs files from raw data using file signatures — headers and footers — when the file-system metadata is gone.

File type	Signature clue	What carving recovers
JPEG	Header `FF D8` … footer `FF D9`	Deleted photos from unallocated space
PNG	Header `89 50 4E 47`	Deleted screenshots and graphics
PDF	Header `%PDF` … trailer `%%EOF`	Deleted documents and receipts
ZIP / Office	Header `PK\x03\x04`	Deleted archives, .docx, .xlsx
MP4 video	An `ftyp` box near the start	Deleted video clips

Carving relies on content signatures, not the index — so it works **precisely when "delete" or a format has removed the index but left the bytes behind.**

> ⚠ **Common mistake:** "*If the file isn't in the index, it's gone.*" **Correction:** carving rebuilds files with **no reliance on the file-system index**, as long as the bytes have not been overwritten. It is like **reassembling a shredded document by recognising the edges and patterns**, even though the folder label is missing.

8.10 Mobile forensics

Mobile forensics is extracting and analysing evidence from smartphones, tablets, SIMs and their apps. It is its own discipline because phones are **always-on, networked, encrypted and OS-locked**, and store extraordinarily rich data.

Complaint type in Nepal	Where the evidence lives	What the phone reveals
Online fraud or scam	eSewa/Khalti, SMS OTPs, bank app	Transactions, payee, timing
Harassment and cyberbullying	Messenger, WhatsApp, Viber, TikTok	The abusive messages and sender
Blackmail / sextortion	Gallery, chat apps, cloud backup	Images, threats, contact history
Fake profile / impersonation	Facebook and Instagram apps	Account access, device linkage
Financial dispute	Call logs and CDRs	Who contacted whom, and when
Location alibi	Maps and app location history	Where the phone was at a key time

Most Nepal Police Cyber Bureau complaints centre on mobile phones and apps — the phone, not a PC, is the crime scene today.

The four extraction levels

Level	How it works	Data yield and trade-off
Manual	Scroll and photograph the screen	Least data; quick but **alters the device**
Logical	Via device APIs or backups	Moderate; less invasive, may miss deleted data

Level	How it works	Data yield and trade-off
File-system	Pull app databases and system files	More — **reaches SQLite chat databases**
Physical	A full bit-for-bit image of storage	**Most data, including deleted**; hardest

> **The rule: the more invasive the level, the more data — but the harder it is.**

Key app-data sources: chat and app databases (usually **SQLite**), call logs, location history, media metadata, and **cloud-synced data** (which needs lawful authorisation).

> ⚠ **Common mistake:** "*If it's deleted in the app, it's gone from the phone.*" **Correction:** app data lives in **local SQLite databases** and often **syncs to a cloud backup**, so fragments and full copies commonly survive a chat "deletion". An investigator must check **at least three places: device storage, the app database, and (lawfully) the cloud backup.**

Challenges — and why the rules do not change

Challenge	Why it is hard on mobile	The integrity response
Encryption	Data unreadable without the key	Live-acquire while unlocked; lawful access
Lock screen	Cannot get in without the passcode	Isolate; document; use lawful means
Constant connectivity	**Remote wipe and cloud sync risk**	**Faraday bag or airplane mode immediately**
OS and version diversity	No single technique fits all	Document the tool and method used
Rapid app changes	Yesterday's method breaks	Validate the tool; note versions
Rich, mixed data	Easy to alter or miss	Hash extractions; work on copies; custody log

> ⚠ **Common mistake:** "*Mobile evidence is so messy that strict integrity rules don't really apply.*" **Correction:** they apply **fully — isolate, document, hash, keep custody — precisely because** phones are volatile and connected. The remote-wipe risk makes **immediate isolation more urgent, not less. Integrity gets no mobile exemption.**
>
> **A smartphone is a diary that writes itself and locks itself.** Forensics is about reading it without it noticing — or destroying — the page.

8.11 Legal aspects

Admissibility is the set of conditions under which a court will accept digital evidence. Every box must be ticked at once.

Condition	What it requires	If it fails
Relevance	It bears on a fact in the case	Excluded as irrelevant
Authenticity	Proven to be what it claims to be	Weight collapses
Integrity	Chain of custody plus matching hashes	Challenged as possibly tampered
Lawful authorisation	A search warrant or lawful seizure	**Excluded — fruit of an unlawful search**
Expert testimony	A competent expert explains it	The court cannot rely on it
Handling	Correct process throughout	Mishandling sinks even true evidence

> ⚠ **Common mistake:** "*If the evidence is true, the court must accept it.*" **Correction: genuine evidence is rejected if illegally obtained or improperly handled.** A broken chain of custody or a warrantless seizure can exclude it entirely. **Lawful process is as essential as the truth of the data.**

Nepal's legal framework

Instrument or body	Role	Note
ETA 2063 (2008)	Recognises electronic records; defines cyber offences	The main legal basis for e-evidence

Instrument or body	Role	Note
Evidence Act provisions	Support acceptance of electronic records	Used alongside the ETA
Nepal Police Cyber Bureau	Investigates and prosecutes cybercrime	Central body, established 2018
The courts	Accept electronic records as evidence	Practice is still maturing
Warrant / lawful seizure	Authorises collection	Required for admissibility
A proposed modern law	Dedicated cybercrime and data protection	Still debated (Unit 9)

⚠ **Common mistake:** "*The ETA 2063 automatically makes any electronic file valid evidence.*" **Correction:** the ETA **recognises** electronic records, but the evidence must still be **authentic, intact and lawfully obtained**. **Screenshots alone do not clear that bar; forensic extraction and custody do.**

The practical case to know. A complainant brings **only WhatsApp screenshots** to the Cyber Bureau. What more is needed? **Forensic extraction of the original messages with metadata, hashing, a chain-of-custody record, and lawful authorisation** — that is what turns weak screenshots into authenticated, admissible evidence.

Cyber forensics in Nepal — the honest picture

Area	Current state	The gap
Central body	The Cyber Bureau investigates cybercrime	Overloaded; limited district reach
Caseload	Rising fast — fraud, abuse, scams	Backlog grows faster than capacity
Personnel	A trained core team exists	Too few trained forensic experts
Lab and tools	A central lab at the Bureau	Limited capacity beyond it
Foreign data	Evidence sits on Facebook, Google and others	**Slow, dependent cross-border access**
Legal framework	ETA 2063 in force	**Ageing**; a modern law is still debated

⚠ **Common mistake:** "*Nepal can't do real cyber forensics.*" **Correction:** it **can and does** — the Cyber Bureau applies sound principles daily. **The principles are sound; the constraint is capacity** (people, labs, law, foreign-data access), which must scale with the rising caseload.

Nepal's cyber forensics is a small fire brigade facing a fast-growing city.

Key words from Unit 8

Digital forensics · admissibility · ACPO principles · don't alter the original · work on copies · documentation · chain of custody · repeatability · competence · the six stages (identify, preserve, collect, examine, analyse, report) · NIST SP 800-86 · volatile evidence · digital evidence · admissible, authentic, complete, reliable, believable · metadata · logs · CDR · slack space · unallocated space · imaging · hashing · MD5 · SHA-256 · write blocker · keyword search · timeline analysis · Autopsy / The Sleuth Kit · EnCase · FTK · Cellebrite · forensic lab · air-gapped · ISO/IEC 17025 · order of volatility · Faraday bag · live acquisition · physical vs logical image · file carving · file signature (header/footer) · SSD TRIM · mobile forensics · manual/logical/ file-system/physical extraction · SQLite app database · cloud backup · Nepal Police Cyber Bureau · ETA 2063 · Evidence Act · search warrant · expert testimony.

Summary — Unit 8

- **Digital forensics is science plus law**: the goal is **court-admissible proof**, not merely recovering a file. That extra discipline is the whole difference from data recovery.
- The field expanded from **one PC** to **phones, cloud, networks and IoT** — in Nepal most cases now hinge on **mobiles and apps**.
- **Core principles:** do not alter the original, work on hashed copies, document everything, maintain custody, stay repeatable, and only let competent people touch originals.
- The process is **identify → preserve → collect → examine → analyse → report**, with **chain of custody and integrity running underneath all six. Preservation is a one-shot chance.**
- **Good evidence is admissible, authentic, complete, reliable and believable**, and much of the strongest evidence is **hidden** — metadata, logs, deleted residue. A **screenshot alone is weak**.

- **Method beats brand** in tools, and the **lab environment is part of the integrity**.
- Seize by the **order of volatility**, **isolate from networks first**, and never power down reflexively. **Write blockers prevent alteration; hashes prove it.**
- "**Deleted**" **is not gone** — only overwriting, destruction or discarding the encryption key truly erases. **Physical images** preserve slack and unallocated space, and **file carving** rebuilds files from signatures without an index.
- **Mobile forensics** has four extraction levels and key sources in **SQLite app databases and cloud backups** — but **integrity gets no mobile exemption**.
- **Admissibility needs legality, authenticity and integrity — not just truth.** Nepal relies on the **ETA 2063** and the **Cyber Bureau**; the principles are sound and **capacity is the bottleneck**.

Unit 9 — Cyber Law in the Context of Nepal

4 lecture hours. Cyber law in the context of Nepal · legal perspective of cybercrime · Electronic Transaction Act · Electronic Transaction Rules · IT Policy · information security and policies.

> ⚠ **Important note on legal specifics.** All **section numbers, chapter references, penalty amounts and dates** in this unit are **illustrative of the framework and the debate**, drawn from the Electronic Transaction Act 2063 (2008) and the Electronic Transaction Rules 2064 as commonly taught. **Verify every section number and penalty against the current official Nepali text** (Nepal Law Commission or the Gazette) before relying on it — figures are easy to misquote, and Nepal has had repeated proposals to amend or replace the ETA. **Learn the concept and the debate, not a memorised number as settled current law.**

9.1 What cyber law is

Cyber law is the body of law governing computers, networks, the internet and electronic transactions.

Its purpose is to **fill the gap where traditional law — written for the paper world — cannot reach digital acts**: online identity, anonymity, electronic evidence and cross-border jurisdiction.

Dimension	Traditional paper-world law	Why it fails online, and cyber law's fix
Identity	Assumes a known, physical person	Fake profiles and anonymity → rules for electronic identity
Evidence	Paper documents, wet-ink signatures	Data and logs → legal recognition of e-evidence
Jurisdiction	A crime happens in one place	Acts cross borders instantly → cross-border provisions
The record	Physical, hard to copy	Digital, copied infinitely → integrity and signature rules
The act itself	Named in the statute (theft, forgery)	"Hacking" and "source-code damage" did not exist → new offences
Speed and scale	One act, limited reach	One post reaches millions → new harms to regulate

Cyber law does two jobs: it **gives electronic records and signatures legal validity**, *and* it **criminalises computer offences**.

International models: **India's IT Act 2000** and the **Budapest Convention on Cybercrime**. *Nepal's answer:* the **Electronic Transaction Act (ETA) 2063 (2008)** — often called "the Cyber Law".

> ⚠ **Common mistake:** "*Nepal has a dedicated 'Cyber Crime Act'.*" **Correction:** Nepal regulates cybercrime **mainly through the ETA 2063** — an e-transactions law that **also** criminalises computer offences — plus provisions in other laws (defamation, the **Criminal Code 2074**, the **Privacy Act 2075**). **There is no single stand-alone Cyber Crime Act.**
>
> **The road analogy.** Cyber law is traffic law for a brand-new kind of road: the cars (data) move fast and cross borders, so you need new rules and a new traffic police — the Cyber Bureau.

9.2 Why Nepal needs cyber law

Daily life has gone digital — e-banking, e-commerce, e-governance, social media — and **every digital transaction needs a legal backbone.**

Digital service in Nepal	What it needs from cyber law	If there were no law
An eSewa or Khalti payment	A digital transaction that is legally binding	A disputed payment has no legal standing
A mobile or internet banking transfer	Electronic records accepted as proof	Neither bank nor customer can prove what happened
Online PAN or a Nagarik App service	Digitally signed records that count in law	Citizens still forced into paper and queues
An emailed, e-signed business contract	Recognition of e-signatures	"It was only an email" — unenforceable

Digital service in Nepal	What it needs from cyber law	If there were no law
A Daraz purchase	Consumer and transaction rules online	No remedy for fraud or non-delivery
A fake profile impersonating you	A named offence and a body to investigate	Impersonation goes unpunished

⚠ **Common mistake:** "*Going digital is about technology, not law.*" **Correction:** without a law giving e-records and e-signatures validity, **an online contract cannot be enforced and a fraudster breaks no named offence. Law is what makes "digital" trustworthy.**

9.3 The legal perspective on cybercrime

A cybercrime is an offence in which a computer or network is either the TARGET (attacked) or the TOOL (used to commit the crime). This split is the cleanest way to classify offences.

Cybercrime	Target or tool?	Typical legal response
Unauthorised access / hacking a server	**Target**	An ETA computer offence; Cyber Bureau investigates
Deleting or altering computer source code	**Target**	An ETA source-code offence
Stealing a customer database	**Target**	ETA + **Privacy Act 2075**; breach of confidentiality
Online payment or wallet fraud	**Tool**	A fraud offence; the Bureau traces the money trail
A fake profile impersonating a person	**Tool**	An impersonation or defamation complaint
A defamatory or obscene post	**Tool**	An ETA e-publication offence — **and a free-speech debate**

Nepal recognises **both** kinds, mainly under the **ETA**, plus the **Criminal Code 2074** and the **Privacy Act 2075**.

The practical fact worth knowing: fake social-media accounts and cyber-defamation are the single largest category handled by the Nepal Police Cyber Bureau (established 2018, Bhotahiti, Kathmandu).

⚠ **Common mistake:** "*Cybercrime just means hacking.*" **Correction:** hacking is only the **target** half. **Most real Nepali cases are tool crimes** — fraud, fake profiles, defamation, harassment — where the computer is the **weapon**, not the victim.

9.4 Reporting cybercrime — the practical path

When you are impersonated, harassed, hacked or defrauded online in Nepal, there is a defined path.

Preserve evidence → file a complaint (Cyber Bureau or local police) → investigation → prosecution under the ETA through the courts / IT Tribunal

Incident	What YOU should do first	Where it goes
Someone opens a fake account in your name	**Screenshot the profile, URL and posts**	An impersonation case
You are defrauded in an online payment	Save transaction IDs, chats, receipts	The Bureau traces the money trail
A private photo is shared to harass you	Preserve evidence; **do not retaliate**	A harassment complaint
Your account is hacked	Record the breach details and recover access	An unauthorised-access (target) offence
A defamatory post targets you	**Keep the post and URL before it is deleted**	A complaint — noting the free-speech debate
A business database is breached	Log the breach; notify those affected	ETA + Privacy Act investigation

⚠ **Common mistake:** "*Nothing can be done about online abuse in Nepal, so I'll handle it myself.*" **Correction:** there **is** a channel (the Cyber Bureau) and a **law** (the ETA). The real mistakes are **destroying the evidence** and **retaliating** — and vigilante "**hacking back**" **is itself an offence. The single biggest practical error is deleting the proof.**

9.5 The Electronic Transaction Act (ETA) 2063

The ETA 2063 (2008 AD) is Nepal's primary cyber law, and it has **two halves**.

Provision area	ENABLE or PUNISH?	What it does in practice
Legal recognition of electronic records	**Enable**	An e-record can count as evidence like paper
Validity of digital signatures	**Enable**	A digitally signed document is legally binding
Dispatch and receipt of e-records	**Enable**	Fixes when and where an e-message legally "arrives"
Certificates, the Controller and CAs	**Enable**	Sets up the PKI trust system
Unauthorised access and source-code damage	**Punish**	Named computer offences with penalties
Illegal or obscene electronic publication	**Punish**	The debated offence — the much-cited "Section ~47"

It is organised in chapters covering e-records and digital signatures, dispatch and receipt, certificates, the **Controller and Certifying Authorities**, network service-provider liability, offences and penalties, and the **IT Tribunal**. In design it **mirrors the UNCITRAL Model Law on E-Commerce** and **India's IT Act**.

⚠ **Common mistake:** "*The ETA is only about cybercrime and punishment.*" **Correction: most of the Act is about ENABLING e-commerce and e-governance.** The offences-and-penalties chapter is only one part. Reading the ETA as a pure "crime law" misses its main purpose.

Electronic records and digital signatures

The ETA gives an electronic record and a digital signature the same legal validity as paper and a handwritten signature.

The mechanism: a digital signature uses **asymmetric (public/private key) cryptography** — the signer **signs with a private key**, and anyone can **verify with the matching public key.**

Paper-world thing	The electronic equivalent	The property it gives
A handwritten signature	A digital signature (private key)	**Authentication** — proves *who* signed
A sealed, unaltered document	A hash-protected signed record	**Integrity** — proves it was *not changed*
"I never signed that"	Only your private key could sign	**Non-repudiation** — the signer *cannot deny it*
A notarised copy	A digital-signature certificate from a CA	Trust — a licensed CA vouches for identity
Posting a letter	Dispatch and receipt rules	Certainty of when a message legally arrived
A paper contract in a court file	An electronic record admitted as evidence	Legal recognition

The three functions to memorise: authentication, integrity, non-repudiation.

⚠ **Common mistake:** "*A scanned image of my signature is a digital signature.*" **Correction:** a scanned signature is **just a picture** — anyone can copy-paste it and it proves nothing. A true digital signature is **cryptographic**: it binds a **specific signer** to a **specific unaltered document**.

A digital signature is like a wax seal that also fingerprints the message — change one word and the seal breaks.

Offences, penalties and the free-speech debate

The offences chapter criminalises **unauthorised access ("hacking"), damage to computer source code, illegal/obscene/defamatory electronic publication, breach of confidentiality or privacy, and computer fraud and forgery.**

Offence	Provision *(illustrative)*	Illustrative penalty
Unauthorised access / hacking	An ETA computer-offence section	A fine and/or imprisonment
Damage or alteration of source code	An ETA source-code section	A fine and/or imprisonment
Illegal / obscene / defamatory e-publication	"**Section ~47**" — the most-cited	Commonly cited as up to about **Rs 200,000 and/or 5 years**
Breach of confidentiality or privacy	ETA + Privacy Act 2075	A fine and/or imprisonment
Computer fraud and forgery	An ETA fraud section	A fine and/or imprisonment
A false statement to obtain a certificate	An ETA certificate section	Certificate void; prosecution

> ⚠ **Treat every figure above as "confirm the exact value".** These numbers are frequently misquoted.

The debate you must be able to argue from both sides. Individuals in Nepal have been **arrested over Facebook and TikTok posts** under the electronic-publication offence.

- **Supporters** argue it **curbs genuine online harm** — defamation, obscenity, fraud.
- **Critics** argue the **wording is vague and over-broad**, and that it has been used to **silence legitimate criticism** — a core reason behind reform and replacement proposals.

> ⚠ **Common mistake:** "*The ETA clearly and precisely defines online defamation and obscenity.*" **Correction:** critics argue "Section ~47" is **vague and over-broad**, which is exactly why it is contested and why reform is proposed. **Teach and learn the concept and the debate**, not a memorised figure as settled law.

9.6 The Electronic Transaction Rules (ETR)

The Electronic Transaction Rules (commonly cited as ETR 2064 BS) are subordinate legislation made under the ETA that spell out the PROCEDURES.

Where the **Act states the principle** ("digital signatures are legal"), the **Rules state the mechanics**: how Certifying Authorities are licensed, how certificates are issued, suspended and revoked, the Controller's duties, and standards, audit and fees.

Question	The Act (ETA)	The Rules (ETR)
What is it?	The **parent primary law**	**Subordinate procedures** under the Act
Who makes it?	**Parliament**	The **executive**, under the Act
What does it do?	States principles and offences	Spells out the how-to
How easy to change?	Hard — needs Parliament	**Easier** — amended by the executive
Example content	"Digital signatures are legally valid"	"How a CA is licensed and audited"

> ⚠ **Common mistake:** "*The Rules and the Act are the same thing.*" **Correction:** they are **different in kind**. The Act is the parent law passed by Parliament; the Rules are detailed procedures issued by the executive under it. **Confusing the two is a classic exam mistake.**

9.7 The Controller and Certifying Authorities (PKI in Nepal)

The Office of the Controller of Certification (OCC, "the Controller"), under the Ministry of Communication and Information Technology (MoCIT), is the government body that LICENSES and SUPERVISES Certifying Authorities (CAs). CAs in turn **issue digital-signature certificates to the public.**

Together they form Nepal's **PKI trust hierarchy**:

Controller (root) → licensed CAs → end-user certificates

Role in the chain	Who, in Nepal	What they do
Controller (root authority)	Office of the Controller of Certification, under MoCIT	Licenses and supervises CAs — **sets the root of trust**
Certifying Authority (CA)	Licensed bodies under the Controller	Issue certificates **after verifying identity**
Certificate	Issued to an end user	Binds a public key to a verified identity
Subscriber / end user	A citizen, bank or business	Signs documents with their private key
Relying party	Anyone verifying a signature	Trusts the signature via the chain above
Audit and revocation	The Controller's supervisory power	Catches a CA issuing certificates carelessly

Trust flows down the chain — a certificate is only as trustworthy as the CA and Controller above it.

> ⚠ **Common mistake:** "*Any company can hand out legally valid digital certificates.*" **Correction:** in Nepal, **only CAs licensed and supervised by the Controller** can issue legally recognised certificates. **An unlicensed "certificate" has no legal standing**, and that supervised chain is the entire point of PKI.

9.8 The IT Policy of Nepal

Nepal's IT Policy is a national policy document setting the government's vision and goals for ICT development — not a law, but a strategic framework.

Its goals typically include building ICT infrastructure, expanding e-governance, growing the IT industry, exports and jobs, promoting digital literacy and inclusion, and improving information security — the **IT Policy 2072** and the **Digital Nepal Framework** ambitions.

The comparison that is most often examined:

Question	Act (ETA)	Rules (ETR)	Policy (IT Policy)
Who makes it?	Parliament	The executive, under the Act	Government, as strategy
Legally binding?	**Yes — primary law**	**Yes — under the Act**	**No — a direction and vision**
What it does	States principles and offences	Spells out procedures	Sets national goals
Can it punish?	**Yes** (offences chapter)	Enforces procedures	**No**
Example	"E-signatures are valid"	"How a CA is licensed"	"Make Nepal an IT hub"

> ⚠ **Common mistake:** "*The IT Policy is legally binding like the ETA.*" **Correction:** it is **not**. **Policy sets direction; laws (the ETA) and rules (the ETR) provide the binding legal mechanism.** Citing the IT Policy as if it could criminalise or enforce is a common and costly exam mistake.
>
> **The map analogy.** The **IT Policy** is the destination on the map, the **ETA** is the road law, and the **ETR and Controller** are the licensing office and traffic police that keep the road usable.

9.9 Information security and policies

Information security is protecting information's Confidentiality, Integrity and Availability — the CIA triad (introduced in Unit 5).

CIA element	What it protects	The threat if lost
Confidentiality	A bank's customer KYC data stays private	A leak → privacy breach, ETA/Privacy Act liability
Integrity	An account balance stays accurate	Tampered records → fraud, wrong decisions

CIA element	What it protects	The threat if lost
Availability	eSewa and mobile banking work when needed	Downtime → customers locked out, trust lost
Confidentiality	Exam results seen only by the right office	A premature leak → unfairness
Integrity	A digitally signed contract is not modified	Silent alteration → non-repudiation lost
Availability	A hospital system reachable in an emergency	An outage → direct risk to patient care

> **The through-line to this unit: law punishes AFTER a breach; security protects the triad BEFORE.**

The information security policy

An information security policy is a documented set of rules governing how an organisation protects its information assets.

The hierarchy to memorise:

> **POLICY (the rule and intent) → STANDARDS (measurable requirements) → PROCEDURES (step-by-step how-to) → GUIDELINES (advisory)**

Policy component	What it governs	The threat it stops
Acceptable-use policy (AUP)	How staff may use company systems	Misuse, shadow IT, risky browsing
Access control and password policy	Who can access what	Weak or shared passwords → account takeover
Data classification	How data is labelled and handled	Sensitive KYC data treated carelessly
Incident response	The steps when a breach occurs	A slow, chaotic reaction that worsens a breach
BYOD policy	Personal devices on the network	An infected personal phone or USB spreads malware
Backup and retention	How data is backed up and kept	Ransomware or data loss with no recovery

> ⚠ **Common mistake:** "*Security is only a technical / IT-team problem.*" **Correction:** it is **governance + people + process**. Firewalls do not stop an employee sharing a password or losing an unencrypted laptop — **policy, training and user behaviour do.** Most breaches exploit people and process gaps, not just technology.

Where law meets policy

Layer	Its role	When it acts	Nepal example
ETA (cyber law)	**Criminalises and punishes**	**After** harm occurs	Prosecuting a hacker or fraudster
IT Policy (national)	**Directs and sets goals**	Ongoing strategy	The "Digital Nepal" e-governance ambition
Security policy (organisational)	**Operationalises protection**	**Before** harm occurs	A bank's AUP, password and incident policy

> ⚠ **Common mistake:** "*Once there's a law, we don't need internal policy*" — **or** — "*policy is enough, the law is irrelevant.*" **Correction:** neither is true. **Law punishes after the fact and deters; policy prevents before the fact and reduces liability.** They are **complementary layers, not substitutes** — and good internal policy reduces both breaches **and** legal liability.

Key words from Unit 9

Cyber law · ETA 2063 · ETR 2064 · IT Act 2000 (India) · Budapest Convention · UNCITRAL Model Law · Criminal Code 2074 · Privacy Act 2075 · cybercrime · target vs tool crime · Nepal Police Cyber Bureau · IT Tribunal · electronic record · digital signature · asymmetric cryptography · private and public key · authentication · integrity · non-repudiation · digital-signature certificate · "Section ~47" · electronic publication offence · free-speech debate · subordinate legislation · Act vs Rules vs Policy · Office of the Controller of Certification (OCC) · MoCIT · Certifying Authority · PKI · trust chain · audit and revocation · IT Policy 2072 · Digital Nepal Framework · information security · CIA triad · information security policy · policy

→ standards → procedures → guidelines · AUP · access control · data classification · incident response · BYOD · backup and retention.

Summary — Unit 9

- **Cyber law governs the digital world** where paper-era law — built on physical identity, place and record — cannot reach.
- **Nepal's primary cyber law is the ETA 2063.** There is **no stand-alone Cyber Crime Act**; the ETA works alongside the Criminal Code 2074 and the Privacy Act 2075.
- **Cybercrime = the computer as target or as tool.** Most real Nepali cases are **tool** crimes, and **fake profiles and cyber-defamation are the Bureau's largest category**.
- Report through the **Cyber Bureau** — and **preserve the evidence first**. Deleting proof or retaliating are the two common mistakes.
- The **ETA has two halves**: it **enables** the digital economy (e-records, digital signatures) and **punishes** computer offences. Digital signatures give **authentication, integrity and non-repudiation**.
- The "**Section ~47**" electronic-publication offence is the most applied and most criticised provision — know **both sides** of the free-speech debate, and treat figures as "**verify**".
- **The Act is Parliament's binding law; the Rules are the executive's binding procedures; the IT Policy is non-binding direction.** Mixing these up is the classic exam trap.
- The **Controller (OCC) licenses and supervises CAs**, forming the **PKI trust chain** that makes Nepali digital signatures legally valid.
- **Information security protects the CIA triad before harm**, through a hierarchy of **policy → standards → procedures → guidelines**. **Law punishes after; policy prevents before** — they are complementary.

Course-Wide Quick Revision

Everything in IT 246, compressed. If you can explain every row below in your own words, you know the course.

R1. The arc of the whole course

> **ETHICS (what you *should* do) → SECURITY (protect it) → FORENSICS (investigate it) → LAW (govern and punish it)**

Unit	Focus	What to revise
1 Overview of Ethics	Ethics vs law; CSR	The 5-step decision framework; the four lenses; why IT ethics is distinct (PAPA)
2 Ethics for IT Workers and Users	Professionalism; privacy	The six relationships; cert vs licence vs code; AUP; privacy and anonymity
3 Intellectual Property	Protecting creations	Copyright, patent, trade secret, trademark; plagiarism; open source; cybersquatting
4 Software Development and IT Organizations	How software is built	Quality; QA vs QC; outsourcing; whistle-blowing; green computing
5 Fundamentals of Cybersecurity	Cyberspace and attacks	CIA triad; risk formula; attack types; coloured hats
6 Personal Cybersecurity	Protecting yourself	Posture; devices and IoT; 3-2-1 backups; passwords and MFA
7 Social Engineering and Cyber Terrorism	Exploiting trust	The six attack types; countermeasures; cyber terrorism vs crime
8 Digital Forensics	Investigating incidents	The six stages; chain of custody; mobile forensics; admissibility
9 Cyber Law in Nepal	Governing the digital world	ETA 2063; ETR; Controller and CAs; IT Policy; infosec policy

R2. The comparisons you must be able to write

#	Comparison	The one-line difference
1	**Ethics vs morals vs law vs etiquette**	A group's code · a person's beliefs · the state's rules · good manners
2	**Legal vs ethical**	**Law is the floor, not the ceiling** — watch the *legal but unethical* quadrant
3	**Shareholder vs stakeholder view**	Only the owners count · everyone materially affected counts
4	**Genuine CSR vs greenwashing**	Daily operations match the message · only the advertisement does
5	**The four ethical lenses**	Most good for most (utilitarian) · rights regardless of outcome (duty) · treat like cases alike (fairness) · what a good person does (virtue)
6	**Can vs should**	Technically possible · ethically defensible
7	**Certification vs licence vs code vs professional body**	Vendor skill proof · **government legal force** · ethical commitment · the standards organisation
8	**Privacy vs secrecy**	**Control over your data** · merely hiding something
9	**Monitoring vs spying**	**Disclosed and consented** (the AUP clause) · hidden
10	**Misinformation vs disinformation**	False, shared carelessly · false, shared **deliberately**
11	**Opinion vs criticism vs defamation**	Personal taste · honest evaluation · **a false statement of fact**
12	**Copyright vs patent vs trade secret vs trademark**	Expression · invention · kept secret · brand sign
13	**Idea vs expression**	Free to anyone · owned by its author

#	Comparison	The one-line difference
14	**Plagiarism vs copyright infringement**	An **ethical/academic** offence · a **legal** one
15	**Permissive vs copyleft licences**	Keep attribution (MIT, Apache) · **open your derivative too** (GPL)
16	**Competitive intelligence vs industrial espionage**	Public and honest sources · theft, bribery, hacking or **lies**
17	**QA vs QC**	Prevent defects (**process**) · catch defects (**product**)
18	**Permanent vs contingent worker**	Security with the firm carrying risk · flexibility with **the worker** carrying it
19	**Internal vs external whistle-blowing**	Report inside first · go outside when inside fails
20	**Threat vs vulnerability vs asset**	What could harm · **the weakness it exploits** · what you protect
21	**White vs grey vs black hat**	Authorised · **unauthorised but not malicious (still illegal)** · malicious
22	**Technical attack vs social engineering**	Hacking the machine · **hacking the person**
23	**Cybercrime vs hacktivism vs cyber warfare vs cyber terrorism**	Profit · protest · state conflict · **ideology plus terror**
24	**Target vs tool cybercrime**	The computer is the **victim** · the computer is the **weapon**
25	**Data recovery vs digital forensics**	Get the file back · **court-admissible proof**
26	**Physical vs logical image**	Every sector including deleted data · only the visible files
27	**Write blocker vs hashing**	**Prevents** alteration · **proves** nothing changed
28	**Act vs Rules vs Policy**	Parliament, binding · executive, binding · **direction, NOT binding**
29	**Law vs security policy**	Punishes **after** harm · prevents **before** harm
30	**Digital signature vs scanned signature**	Cryptographic and unforgeable · **just a picture**

R3. Every framework and list

Topic	The list
The legal/ethical grid	Legal+ethical · **legal+unethical (the danger zone)** · illegal+ethical · illegal+unethical
Carroll's CSR pyramid	Economic → legal → ethical → philanthropic
Why good people go wrong	Results pressure · normalization · weak oversight · diffusion of responsibility
Ethics program components	Ethics officer · board oversight · specific code · training · safe reporting · audits — plus **consistent enforcement**
The 5-step decision process	Facts → stakeholders and options → evaluate → act → reflect
The four ethical lenses	Utilitarian · rights/duty · fairness/justice · virtue/common good
The four decision traps	Rationalization · groupthink · slippery slope · blind obedience
What makes IT ethics distinct	Scale · speed · anonymity · permanence · the capability–regulation gap
PAPA	Privacy · Accuracy · Property · Access
The six IT-worker relationships	Employer · client · supplier · peers · users · society
The gift-vs-bribe test	Would it survive publicity? · is it timed around a decision? · could it influence judgement?
The four-part profession test	Specialized education · body of knowledge · code of ethics · **self-regulation (IT lacks this)**
What an AUP defines	Permitted use · prohibited use · monitoring · consequences
Forms of software piracy	Counterfeiting · unlicensed install · licence violation
The three privacy principles	Consent · purpose limitation · data minimization
Social-media amplifiers	Scale · speed · anonymity · virality · the bystander effect
The four IP families	Copyright · patent · trade secret · trademark

Topic	The list
The three patentability tests	Novelty · inventiveness (non-obviousness) · industrial applicability
The four traits of the patent system	Slow · costly · public · territorial
Software quality attributes	Correctness · reliability · usability · security · maintainability · performance
Testing levels	Unit → integration → system → acceptance (UAT), plus regression
Standards and models	ISO 9001 · ISO/IEC 25010 · CMMI · IEEE · Waterfall · Agile
Risk management	Risk register · likelihood × impact · mitigation **plus** contingency/rollback
The responsible whistle-blowing process	Facts → weigh the harm → internal → regulator (CIAA) → public (last resort)
The IT lifecycle (green computing)	Manufacture → use → disposal → recycle
The e-waste ladder	Reduce → reuse → refurbish → recycle (and **wipe data first**)
The three cybersecurity pillars	People · process · technology — **the weakest decides**
The CIA triad	Confidentiality · Integrity · Availability
The risk formula	**Risk = threat × vulnerability × impact** (they multiply)
Malware types	Virus · worm · trojan · ransomware · spyware · adware/PUP
Network poisoning attacks	MITM · ARP poisoning · DNS poisoning · rogue hotspot
The coloured hats	White (authorised) · grey (unauthorised, not malicious) · black (malicious)
Attacker types	Script kiddie · hacktivist · cybercriminal · state actor (APT) · insider (malicious and negligent)
The four posture layers	Patch → protect → back up → contain
The 3-2-1 backup rule	3 copies · 2 media types · 1 offsite — **plus a tested restore**
MFA strength ladder	Password only < SMS OTP < authenticator app (TOTP) < hardware key — **email first**
The six social-engineering types	Phishing · vishing · smishing · pretexting · baiting · tailgating
The influence levers	Authority · liking/rapport · social proof · reciprocity · familiarity · consistency
The close	Urgency · fear · scarcity
The three ingredients of cyber terrorism	Intent (ideological) · target (critical) · severity (serious harm)
Types of cyber terrorism	Infrastructure attack · data destruction · service denial · propaganda/psy-ops · recruitment · financing
Countering cyber terrorism	National (CERT, law) · organizational (segmentation, IR/BCP) · personal (awareness, don't amplify)
The six forensic stages	Identify → preserve → collect → examine → analyse → report
Forensic core principles	Don't alter the original · work on copies · document · chain of custody · repeatability · competence
Chain-of-custody log fields	Who · when · why · how · seal/label · signature
Properties of good evidence	Admissible · authentic · complete · reliable · believable
Order of volatility	RAM and live state → disk → backups
Mobile extraction levels	Manual → logical → file-system → physical
The admissibility checklist	Relevance · authenticity · integrity · lawful authorisation · expert testimony · correct handling
The ETA's two halves	**Enable** (e-records, signatures) · **punish** (offences chapter)
Digital signature functions	Authentication · integrity · non-repudiation
The PKI trust chain	Controller (OCC) → licensed CAs → certificates → users

Topic	The list
The policy hierarchy	Policy → standards → procedures → guidelines
Infosec policy components	AUP · access control and passwords · data classification · incident response · BYOD · backup and retention
Incident response	Prepare → detect → contain → eradicate → recover → review

R4. The Nepal fact file

Fact	Detail
CSR regulation	**Nepal Rastra Bank directs commercial banks to allocate part of profit to CSR**
Professional licensing	Doctors by the **NMC**, engineers by the **NEC**, lawyers by the Bar Council, accountants by **ICAN** — **IT workers are not licensed**
Nepali professional body	**CAN** — Computer Association of Nepal
Privacy law	**Individual Privacy Act, 2075 (2018)** — recognises privacy of personal information
Cybercrime law	**Electronic Transaction Act (ETA) 2063 (2008)** — the primary cyber law, plus the **Criminal Code 2074**
The debated provision	"**Section ~47**" on illegal electronic publication — most applied, most criticised *(verify specifics)*
Rules	**Electronic Transaction Rules (ETR 2064)** — procedures under the Act
Policy	**IT Policy 2072** and the **Digital Nepal Framework** — **non-binding**
Regulator of digital signatures	**Office of the Controller of Certification (OCC)** under **MoCIT**, licensing **CAs**
Cybercrime investigation	**Nepal Police Cyber Bureau**, established **2018**, Bhotahiti, Kathmandu
Largest complaint category	**Fake social-media accounts and cyber-defamation**
Incident response	**NPCERT** — Nepal's Computer Emergency Response Team
Anti-corruption route	**CIAA** — the escalation path for whistle-blowers (protection is **weak**)
IP administration	**Department of Industry (DoI)** under the **Patent, Design and Trademark Act 2022 BS (1965)**
Copyright	**Copyright Act 2059 (2002)**, Copyright Registrar's Office; term **life + 50 years**
Trade bloc	Nepal is a **WTO / TRIPS member**
Domains	`.np` managed by **Mercantile (register.com.np)**; `.com` disputes via **UDRP**
Academic integrity	**Tribhuvan University** anti-plagiarism rules on reports and theses
Nepali IT companies	Fusemachines, Leapfrog Technology, CloudFactory, Deerwalk, Genese Cloud, Yarsa Games
Platforms in examples	eSewa, Khalti, IME Pay, FonePay, ConnectIPS, Daraz, SastoDeal, Pathao, Foodmandu, Hamro Patro, Nagarik App
Telecoms and ISPs	NTC, Ncell; WorldLink, Vianet, Subisu
Trade secret example	**Wai Wai / CG Foods' masala ratio**
Trademark example	Fake **Goldstar** shoes; counterfeit **Wai Wai** packets
Named financial incident	The **NIC ASIA SWIFT** fraud — the standard high-impact example
Forensic lab	The central lab sits at the **Cyber Bureau**; **district-level access is limited**
Famous failures cited	**Therac-25 · Boeing 737 MAX MCAS (346 deaths) · Ariane 5 · WannaCry · Mirai botnet**
Whistle-blower cases cited	**Edward Snowden · Frances Haugen**

R5. Fifty-term glossary

Acceptable Use Policy (AUP) — the signed document setting what users may and may not do with an organisation's IT. **Adverse selection** — *(see Unit 3 economics context)* bad options dominating when quality cannot be judged. **Algorithmic bias** — systematic unfairness in automated decisions. **APT** — an advanced persistent threat; a well-resourced attacker who stays in a system. **Asymmetric cryptography** — a public/private key pair used to sign and verify. **Attack surface** — the sum of all points where an attacker could try to get in. **Baiting** — luring a victim with something tempting, such as a dropped USB. **Chain of custody** — the unbroken, documented record of who handled evidence, when, why and how. **CIA triad** — Confidentiality, Integrity, Availability. **Contingent worker** — a non-permanent worker: contractor, temp, consultant or gig worker. **Copyleft** — a licence requiring derivatives to stay open (GPL). **Credential stuffing** — replaying one leaked password across many accounts. **CSR** — a company's duty to act for society's benefit. **Cybersquatting** — registering a domain matching another's trademark in bad faith. **Defamation** — a false statement of fact that damages reputation. **Digital signature** — a cryptographic signature giving authentication, integrity and non-repudiation. **Disinformation** — false information spread **deliberately**. **Doxxing** — publishing someone's private details to expose them to harm. **e-WOM** — electronic word of mouth: online reviews and ratings. **Fair use** — limited use of copyrighted work for education, news, criticism or parody. **Faraday bag** — a signal-blocking bag that isolates a seized device. **File carving** — rebuilding files from their signatures without the file-system index. **Greenwashing** — advertising responsibility you do not practise. **Hashing** — a digital fingerprint (MD5, SHA-256) proving data is unchanged. **Information asymmetry** — one party knowing more than the other. **Insider risk** — harm originating from ordinary users, usually careless. **Intellectual property** — legal rights over creations of the mind. **Least privilege** — granting only the access actually needed. **MFA** — a second proof of identity beyond a password. **Misappropriation** — the theft or breach-of-confidence taking of a trade secret. **MITM** — an attacker secretly relaying and able to alter traffic. **Multi-homing** — *(platform context)* using several competing services at once. **Non-repudiation** — the signer cannot later deny signing. **Order of volatility** — the rule that the most fragile evidence (RAM) is captured first. **Pretexting** — inventing a role or story to extract information. **Phishing / vishing / smishing** — the same con over email, voice and SMS. **PKI** — the Controller → CA → certificate trust chain. **Plagiarism** — presenting another's work or ideas as your own. **Ransomware** — malware that encrypts files and demands payment. **Residual risk** — the risk left after all controls, consciously accepted. **Reverse engineering** — analysing a product to learn how it works; lawful for interoperability, security and learning. **Security posture** — how well your devices and habits resist and recover from threats. **SIM-swap** — porting a victim's number onto an attacker's SIM to steal OTPs. **Social engineering** — manipulating people rather than breaking technology. **Supply- chain risk** — inheriting a vendor's security weaknesses. **Tailgating** — following an authorised person through a secure door. **Trade secret** — confidential information protected purely by secrecy. **Whistle-blowing** — an insider revealing wrongdoing. **White blocker → write blocker** — hardware or software that permits reading but blocks any write to a drive. **Zero-day** — a vulnerability with no patch yet available.

R6. Exam technique

Question shape	How to answer	High-yield topics
Definition	Define → explain → **Nepal example**	Ethics vs law; the four IP types; the CIA triad
Compare / contrast	**Use a table structure**	Act vs Rules vs Policy; cert vs licence; QA vs QC; the hats
Applied Nepal case	Classify → name the concept → give the steps	Classify a cybercrime; apply the chain of custody
"Explain the provisions of the ETA"	The two halves → key offences → note "verify"	ETA 2063; the Controller's role
Attack and defence taxonomy	Name → mechanism → **countermeasure**	Unit 5 attack types; Unit 7 social engineering
Discussion / argue both sides	State both sides, then a reasoned view	"Section ~47": protection vs free speech; outsourcing; licensing IT

The answer formula that works across the course: define → explain → Nepal example → diagram where useful. For any ethical case question, run the **Unit 1 five-step process** explicitly.

The three pitfalls that cost the most marks:

1. **Confusing Act / Rules / Policy** — the IT Policy is **not** binding law.

2. **Misquoting ETA section numbers and penalties** — learn the **concept**, and cite the section as "Section ~47 — verify".
3. **Treating certification as a licence**, or **plagiarism as the same thing as infringement.**

R7. One sentence per unit

1. **Unit 1** — Ethics is a group's shared code, law is only the floor, and IT magnifies every ethical choice through scale, speed, anonymity and permanence.
2. **Unit 2** — Privileged access makes IT workers ethically distinctive; they owe duties to six parties, and privacy means control while anonymity cuts both ways.
3. **Unit 3** — Four IP families protect four different things — expression, invention, secrets and brands — and most "IP issues" are really questions about intent and how you obtained something.
4. **Unit 4** — Quality is fitness for real use, defects get ten times costlier at every stage, and an IT organisation's ethics show up in how it treats contingent workers, whistle-blowers and the planet.
5. **Unit 5** — Security protects Confidentiality, Integrity and Availability through people, process and technology, and is prioritised by multiplying threat, vulnerability and impact.
6. **Unit 6** — Your own posture is patch, protect, back up and contain — and most of your real risk is a reused password, a default IoT password, or an unlocked phone.
7. **Unit 7** — When machines get hard, attackers hack the person instead: they manufacture trust, apply urgency, and the defence is to refuse and verify independently.
8. **Unit 8** — Forensics turns data into court-admissible proof through a fixed six-stage process with chain of custody underneath, and in Nepal the principles are sound while capacity is the bottleneck.
9. **Unit 9** — The ETA 2063 both enables the digital economy and punishes computer offences; the Act and Rules bind, the IT Policy only directs, and organisational security policy prevents the harm the law can only punish afterwards.

R8. A note on the source material

These notes are built from the complete IT 246 session material for all nine units. Three points of honesty:

- **Legal specifics** — ETA and ETR section numbers, penalty amounts and dates — are reproduced as the course material presents them, and are flagged throughout as "**verify against the official text**". Nepal's cyber-law landscape has been changing through amendments and proposed replacement bills, so cite the **concept** confidently and the **number** cautiously.
- **Units 5 to 8 are deliberately defensive.** Attacks are described for recognition and defence only; there are no exploit or attack-execution instructions anywhere in these notes, by design.
- **Nepali statistics and case references** (the Cyber Bureau's largest complaint category, lab capacity, piracy rates) come from the lecture material rather than a cited published dataset. Attribute them accordingly in written answers.

> **Final advice.** Most IT 246 questions are answered by naming a concept, defining it in one line, giving a Nepali example and stating one consequence. The tables in R2 and R3 give you the concepts and the lists; the Nepal fact file in R4 gives you the examples. Practise the pairing.